

Ain Shams University
Faculty of Engineering
Computer Engineernig and Software Systems



CFI - Care: Collaborative Flow of Intelligence for Care

Graduation Project Thesis

Author: Mohamed Salah Fathy 21P0117
Youssef Tamer Hossam 21P0138
Salma Hisham Hassan Wagdy 21P0124
Salma Mohamed Abdelmonem 21P0148
Belal Anas Awad 21P0072

Supervisors: Dr Haitham Azmi

Submission Date: 27 January, 2026

Mohamed Salah Fathy 21P0117
Youssef Tamer Hossam 21P0138
Salma Hisham Hassan Wagdy 21P0124
Salma Mohamed Abdelmonem 21P0148
Belal Anas Awad 21P0072
Date: 27 January, 2026

Contents

Acknowledgments	IX
1 Introduction	1
1.1 The Global Digital Health Revolution	1
1.2 The Situation in Egypt	1
1.3 Problem Statement	1
1.4 The Proposed Solution: CFI Care	2
1.5 Thesis Objectives	2
1.6 Thesis Structure	3
2 Literature Review	4
2.1 Background and Context	4
2.1.1 State of Health Data in Egypt	4
2.1.2 Economic Imperative	4
2.1.3 Challenges to Implementation	4
2.2 Theoretical Framework	4
2.2.1 Patient-Centricity in Healthcare	4
2.2.2 Data Governance and Interoperability	5
2.2.3 Security: Role-Based Access Control	5
2.2.4 Artificial Intelligence: Retrieval-Augmented Generation	5
2.2.5 Version Control for Health Records	5
2.3 HL7 - Health Level Seven	6
2.3.1 Evolution of Standards	6
2.4 Fast Healthcare Interoperability Resources (FHIR)	7
2.4.1 Core Architecture	7
2.4.2 Key Technical Advantages	7
2.4.3 Comparison of Standards	7
2.5 Authentication and Authorization Standards	7
2.5.1 OAuth 2.0 and OIDC	7
2.5.2 JSON Web Tokens (JWT)	8
2.5.3 PKCE	8
2.6 Healthcare Security and Standards	8
2.6.1 FHIR and SMART on FHIR	8
2.7 Token-Based Authentication Patterns	8
2.7.1 Session Management	8
2.8 API Security	9
2.8.1 Rate Limiting	9

2.8.2	Input Validation and XSS	9
2.8.3	CSRF	9
2.9	Mobile Application Security	10
2.9.1	Secure Token Storage	10
2.10	Audit Logging and Compliance	10
2.10.1	Security Event Logging	10
2.10.2	Threat Modeling	10
2.11	Infrastructure and Deployment	10
2.11.1	API Gateway	10
3	Proposed Design Architecture	11
3.1	System Architecture	11
3.1.1	High-Level Architecture	11
3.1.2	Node.js Application Server	12
3.1.3	Data Persistence and Schema	13
3.1.4	Request/Response Flow and Data Transformation Pipeline	15
3.1.5	Error Handling and Fault Tolerance	20
3.1.6	Security and Infrastructure Layer	21
3.1.7	HAPI FHIR Server Implementation	22
3.2	API Design and Endpoints	23
3.2.1	RESTful Structure and Formats	23
3.2.2	FHIR-Compliant Endpoints	23
3.2.3	Custom History Graph Endpoints	23
3.3	Patient History Graph Implementation	24
3.3.1	Motivation: Beyond Linear Medical Records	24
3.3.2	Graph Data Model	25
3.3.3	Graph Construction Algorithm	26
3.3.4	Temporal Branching and Concurrent Episodes	28
3.3.5	Relationship Classification	29
3.3.6	Handling Edge Cases	29
3.3.7	Query Patterns and Optimization	30
3.4	Performance Optimization	30
3.4.1	Tier 1: Standard Resource Cache	31
3.4.2	Tier 2: Specialized Graph Cache	33
3.5	Frontend	36
3.5.1	Overview and Design Objectives	36
3.5.2	Technology Stack	36
3.5.3	Authentication Suite	37
3.5.4	Patients Dashboard	37
3.5.5	Clinical Summary View	38
3.5.6	Interactive Header	38
3.5.7	Patient Journey Dashboard	38
3.5.8	Patient Journey Dashboard – Categorical View	39
3.5.9	Patient Journey Dashboard – Chronological View	40
3.5.10	Complementary Roles of Categorical and Chronological Views	41
3.5.11	Summary	42
3.6	Mobile	42

3.6.1	Problem Statement	42
3.6.2	Data Fragmentation and the “Silo” Effect	42
3.6.3	Reliance on Analog Systems and Data Quality	42
3.6.4	Absence of Standardized Consent and Data Sovereignty	43
3.6.5	The Need for Continuous Monitoring	43
3.7	Mobile Application Goal and Methods	43
3.7.1	Digital Document Management	43
3.7.2	Doctor-Patient Data Sharing	43
3.7.3	Elimination of Physical Records	44
3.7.4	Caregiver and Family Involvement	44
3.7.5	Appointment Management	44
3.7.6	Wearable Device Integration	44
3.8	Related Work	44
3.8.1	Apple Health	44
3.9	Market Analysis: The Egyptian Landscape	45
3.9.1	Vezeeta	46
3.9.2	Lumi by Nextcare:	46
3.9.3	Our Competitive Advantage: The ”Medical History Tree”	46
3.10	Flutter and Dart	47
3.10.1	Clean Architecture in the Mobile Application	47
3.10.2	Layered Structure	48
3.10.3	Centralized Runtime Permission Handling	48
3.11	Requirements Engineering	52
3.11.1	Target Group and User Group	52
3.11.2	Stakeholder	53
3.12	System Sequence Diagram	55
3.13	System Requirements Specification	55
3.13.1	Functional Requirements	55
3.13.2	Non-Functional Requirements	56
3.13.3	Optional Requirements (Future Scope)	56
3.14	Use Cases	57
3.14.1	SignIn and SignUp Pages	57
3.14.2	Document Management	57
3.14.3	Medical History Navigation	58
3.14.4	Appointment Booking	61
3.15	My Profile Update	62
3.16	Quality Assurance and Testing	63
3.16.1	Unit Testing	63
3.16.2	Widget Testing	63
3.16.3	Integration Testing	63
3.16.4	Testing Architecture and Tools	63
3.16.5	Unit Testing Implementation	64
3.17	Future Work	66
3.17.1	Push Notifications	66
3.17.2	Wearable Data Integration	66
3.17.3	Objective: Remote Patient Monitoring (RPM)	67
3.17.4	Health Connect	67

4	Security	69
4.1	Introduction	69
4.2	Architecture & Design	69
4.2.1	Identity & Access Management	71
4.2.2	Authorization & Policy Enforcement	75
4.2.3	Doctor–Patient Consent & Access Grants	75
4.2.4	Session Management & Revocation	76
4.2.5	Defense-in-Depth	78
4.3	Implementation & Setup	79
4.3.1	Keycloak Configuration	79
4.3.2	Backend-for-Frontend (BFF) Security Implementation	80
4.3.3	nginx API Gateway	81
4.3.4	Container Security & Deployment	82
4.3.5	Frontend & Mobile Clients	82
4.3.6	Angular Frontend Security Implementation	85
4.3.7	Keycloak	86
4.3.8	Redis	86
4.3.9	nginx API Gateway	86
4.3.10	PostgreSQL	86
4.3.11	Node.js Backend-for-Frontend (BFF) Libraries	86
4.4	Challenges & Trade-offs	87
4.4.1	Session Management Across Client Types	87
4.4.2	Stateless Tokens vs. Revocation Needs	87
4.4.3	Balancing Consent Privacy & Usability	87
4.4.4	Clock Skew & Distributed Verification	87
4.5	Security Analysis	88
4.5.1	Attack Surface Analysis	88
4.5.2	Threat Model & Residual Risks	88
4.5.3	Mitigations Implemented & Gaps	89
4.6	Summary	90
5	AI	92
5.1	Problem Definition & Clinical Motivation	92
5.1.1	Clinical Workflow Breakdown	92
5.1.2	Failure Modes of Current Systems	92
5.1.3	Safety-Critical Nature of the Problem	93
5.2	System Objectives & Design Principles	94
5.2.1	Functional Objectives	94
5.2.2	Non-Functional Objectives (Architectural Principles)	94
5.2.3	Explicit Non-Goals	95
5.3	Related Work Gap Analysis	95
5.3.1	Traditional Clinical Decision Support Systems	95
5.3.2	LLMs in Healthcare	95
5.3.3	RAG in High-Risk Domains	96
5.3.4	Gap Statement	96
5.4	System Architecture	96
5.4.1	High-Level Architecture Overview	96

5.4.2	Data Ingestion & Normalization (TOON)	97
5.4.3	Retrieval Layer Design	97
5.4.4	Generation, Reasoning & Agentic Workflow	98
5.4.5	Architectural Diagrams	98
5.4.6	Evidence Grounding & Citation Enforcement	101
5.5	Use Cases & Clinical Scenarios	101
5.5.1	Clinical Synthesis and Retrieval-Augmented Generation	102
5.5.2	Diagnostic Evolution and Differential Reasoning	102
5.6	Evaluation & Benchmarks	103
5.6.1	Evaluation Dataset & Methodology	103
5.6.2	Component-Level Evaluation	104
5.6.3	End-to-End Task Evaluation	105
5.6.4	Summary of Evaluation Findings	106
5.7	Performance, Scalability & Deployment	106
5.7.1	Hardware & Infrastructure	106
5.7.2	Latency & Throughput	107
5.7.3	Cost & Scalability	107
5.8	Limitations & Open Challenges	108
5.8.1	Technical Constraints	108
5.8.2	Clinical and Operational Hurdles	108
5.9	Value Proposition & Impact	108
5.9.1	Clinical Efficiency and Burnout Mitigation	108
5.9.2	Organizational and Operational Impact	109
6	Testing and Verification	110
6.1	Backend Testing Overview	110
6.1.1	Execution Environment	110
6.1.2	Scope	110
6.1.3	API Route Coverage	110
6.1.4	Service and Integration Tests	111
6.1.5	Test Design and Data	111
6.1.6	End-to-End Workflows	111
6.1.7	Validation and Middleware	111
6.1.8	Caching and Redis	112
6.1.9	Database Checks	112
6.1.10	Gaps and Next Steps	112
6.1.11	Test Result Summary	112
6.1.12	Interpretation of Results	113
7	Conclusion and Future Work	114
7.1	Conclusion	114
7.2	Future Work	114
7.2.1	Security	114
	Appendix	116

A Lists	117
List of Abbreviations	117
List of Figures	119
References	120

Acknowledgments

We would like to extend our deepest gratitude to our esteemed supervisor, Dr. Haitham Azmi, whose guidance, support, and invaluable insights have been instrumental in the successful completion of this senior project thesis. His unwavering dedication and expertise have enhanced our understanding of the complexities involved in building an AI-Powered, Patient-Centric Healthcare Platform. Dr. Haitham Azmi provided us with the intellectual stimulation and encouragement necessary to navigate the challenges we encountered throughout this research. His constructive feedback and meticulous mindfulness have significantly improved the quality of our work.

We are also grateful to Ain Shams University (ASU) for providing us with the resources and environment necessary to pursue this project. Special thanks to the Faculty of Engineering and the Computer and Systems Engineering Department for their continuous support and encouragement throughout our academic journey.

We would like to acknowledge the contributions of our colleagues and friends who provided valuable feedback and assistance during the development of this project. Their support and collaboration have been invaluable in overcoming technical challenges and refining the final product.

Finally, we extend our heartfelt thanks to our families for their unwavering support, encouragement, and patience throughout this journey. Their belief in our abilities has been a constant source of motivation.

This project would not have been possible without the collective efforts and support of everyone mentioned above. We are truly grateful for their contributions.

Abstract

Healthcare today is characterized by fragmented experiences where patient medical information is often dispersed across various institutions and providers. This project proposes a comprehensive, patient-centric healthcare application designed to consolidate all medical reports into a single, secure, and unified platform. The system employs Role-Based Access Control (RBAC) to ensure privacy and controlled information sharing. To enhance clinical decision-making, the platform features a medical history visualization graph for tracking health trends and integrates a Retrieval-Augmented Generation (RAG)-enabled AI model to generate diagnostic reports and insights. By transforming isolated data into an interconnected ecosystem, this project aims to establish meaningful relationships between patients, caregivers, and doctors for personalized healthcare delivery.

Chapter 1

Introduction

1.1 The Global Digital Health Revolution

Healthcare is shifting from reactive treatment toward proactive, data-driven prevention. The global digital health market was valued at roughly USD 288 billion in 2024 and is projected to approach USD 946 billion by 2030, growing at more than 22% annually. This acceleration is powered by mobile health, telemedicine, and Artificial Intelligence (AI), which promise cheaper, faster, and more effective care. Yet adoption is uneven: while leading systems deploy AI for personalized care, many Low- and Middle-Income Countries (LMICs) still struggle with basic record keeping because of weak infrastructure, unclear policy, and fragmented data.

1.2 The Situation in Egypt

Egypt, home to over 106 million people and the largest healthcare market in MENA, has improved outcomes but faces a persistent data void. Records in many Public Health Centers (PHCs) remain paper-based, locked in filing rooms, and rarely interoperable across facilities. Digital systems that do exist often operate in silos, so a patient moving between providers loses continuity of care. Data quality is frequently incomplete or error-prone, and patients seldom provide formal written consent, reflecting limited trust and awareness of data value. This fragmentation prevents AI from learning accurate patterns and delivering benefits to Egyptian patients.

1.3 Problem Statement

When a patient sees multiple specialists, their medical records scatter across disconnected systems. Radiology images sit at one hospital, lab results at another, prescriptions at a third. Clinicians piece together incomplete histories from memory or phone calls. Patients have no way to track their own health trends over time. Care coordination breaks down because nobody has the full picture. Egypt needs modern, AI-enabled healthcare but lacks the foundational data ecosystem. The core challenges are:

- **Fragmentation:** Records scattered across clinics with no single longitudinal home.
- **Analog Dominance:** Paper-first workflows impede longitudinal tracking and lossless sharing.
- **Lack of Control:** Patients cannot easily access or share their own histories.
- **Privacy and Consent Gaps:** No standardized, auditable consent flows.
- **Missed AI Opportunities:** Absent or inaccessible digital data blocks safe clinical decision support such as Retrieval-Augmented Generation (RAG).

1.4 The Proposed Solution: CFI Care

CFI Care is an AI-powered, collaborative, patient-centric health record platform that unifies medical reports in one secure ecosystem while keeping patients in control.

- **Unified Records:** Consolidates data from disparate sources into a single, secure repository with timeline visualization.
- **Git-Inspired Version Control:** Tracks evolving treatment plans as a medical history graph to reveal branches, merges, and longitudinal trends.
- **Role-Based Access Control (RBAC):** Lets patients grant time-bound, role-specific access to clinicians or caregivers, creating a clear consent audit trail.
- **AI Integration (RAG):** Grounds generative summaries and answers in the patient's own records to support safer diagnostics and triage.
- **Mobile Digitization:** A camera scanner digitizes legacy paper reports, crowd-sourcing data ingestion despite PHC device constraints.

1.5 Thesis Objectives

This thesis aims to design and develop CFI Care to modernize health data management in Egypt by:

- Documenting digital health barriers in Egypt, including infrastructure gaps and consent practices.
- Designing a secure, scalable, and usable architecture for patient-centric records and clinician workflows.
- Implementing robust RBAC and consent enforcement to safeguard privacy while enabling necessary sharing.
- Engineering AI (RAG) services that can interpret medical records and deliver actionable insights.
- Empowering patients with tools for data ownership, appointments, caregiver sharing, and mobile digitization.

1.6 Thesis Structure

- Chapter 1: Introduction to the global digital health revolution, Egypt's healthcare challenges, and the CFI Care solution.
- Chapter 2: Standards (HL7/FHIR), governance, authentication, and security foundations.
- Chapter 3: CFI Care system architecture including backend, frontend, and mobile components.
- Chapter 4: Defense-in-depth security architecture with OAuth 2.0, JWT Tokens, RBAC, Rate Limiting on API endpoints, and audit logging.
- Chapter 5: AI integration using Retrieval-Augmented Generation for clinical decision support.
- Chapter 6: Testing methodology, implementation milestones, and validation.
- Chapter 7: Conclusion, expected impact, and future enhancements.

Chapter 2

Literature Review

2.1 Background and Context

2.1.1 State of Health Data in Egypt

Egypt's largest-in-MENA healthcare market still operates with a persistent data void. Many Public Health Centers (PHCs) rely on paper records stored in locked rooms, producing data silos that cannot be queried or shared across providers. Even when digital systems exist, they often function in isolation, so patients effectively lose their history when moving between facilities. Data quality is frequently incomplete, error-prone, and difficult to audit, and formal written consent is rarely collected, reflecting limited trust and awareness of data value. These factors prevent AI systems from learning reliable patterns and delivering safe support to clinicians.

2.1.2 Economic Imperative

Globally, the digital health market is projected to reach nearly USD 946 billion by 2030 at a growth rate above 22%. For Egypt, modernizing health data is both a clinical and economic opportunity to attract investment, improve efficiency, and close the gap with leading digital health adopters.

2.1.3 Challenges to Implementation

Key barriers identified in the Egyptian context include infrastructure limits, low digital literacy among frontline workers, organizational fragmentation, constrained funding, and cultural hesitancy around data sharing. Table 2.1 summarizes these obstacles.

2.2 Theoretical Framework

2.2.1 Patient-Centricity in Healthcare

Traditional institution-centric models keep data under provider control. A patient-centric approach shifts ownership to patients, ensuring portability and empowerment.

Table 2.1: Implementation Barriers in Egypt’s Health Data Landscape

Barrier	Description
Infrastructure	Limited connectivity and device availability in PHCs.
Digital literacy	Nurses and clerks often lack training on digital tools.
Fragmentation	Providers operate in silos and resist data sharing.
Funding	Budgets for devices and training are inadequate.
Culture and trust	Patients may hesitate to share data or perceive little value in doing so.

When patients upload documents, manage appointments, and share records, adherence and outcomes improve.

2.2.2 Data Governance and Interoperability

High-quality, ethical data use depends on governance principles that prioritize protection, value, and equity. Interoperability—particularly via FHIR—enables systems to exchange and reuse structured health information, avoiding vendor lock-in and enabling national-scale insights.

2.2.3 Security: Role-Based Access Control

Role-Based Access Control (RBAC) restricts access by clearly defined roles. Patients can grant time-bound access to doctors or caregivers, creating auditable consent and aligning with privacy requirements.

2.2.4 Artificial Intelligence: Retrieval-Augmented Generation

Retrieval-Augmented Generation (RAG) grounds AI outputs in a patient’s actual records. By retrieving relevant documents before generation, it reduces hallucinations and offers safer clinical decision support for summarization and question answering.

2.2.5 Version Control for Health Records

A Git-inspired model captures branching and merging in treatment histories, forming a medical history graph. This temporal view helps clinicians understand forks in care plans, compare outcomes, and track longitudinal trends.

2.3 HL7 - Health Level Seven

Health Level Seven (HL7) International is a standards development organization that has defined the framework for the exchange, integration, sharing, and retrieval of electronic health information for decades [2]. Understanding the evolution of these standards is crucial to appreciating the architectural shifts in modern healthcare applications.

2.3.1 Evolution of Standards

- **HL7 v2 (The Workhorse):** Established in 1989, HL7 v2 remains the most widely implemented standard for hospital workflows (e.g., ADT - Admission, Discharge, Transfer messages). It utilizes a non-XML, pipe-delimited syntax (e.g., MSH|^~\&|...). While highly efficient for legacy backend systems, its lack of semantic strictness leads to significant implementation variances, posing challenges for modern web and mobile application development [2].
- **HL7 v3 (The Theoretical Model):** Introduced in the 1990s to address the vagueness of v2, HL7 v3 was built on a rigorous Reference Information Model (RIM). It enforced strict semantic correctness using complex XML structures. However, this theoretical purity resulted in a steep learning curve and bloated message sizes, leading to poor adoption rates and a lack of backward compatibility with v2 [2].
- **HL7 CDA (Clinical Document Architecture):** A component of v3, CDA focuses on the exchange of clinical documents (such as discharge summaries). While effective for static snapshots of care, it is document-centric rather than data-centric, making it difficult to extract granular data (like a single heart rate reading) required for real-time interactive applications [4].

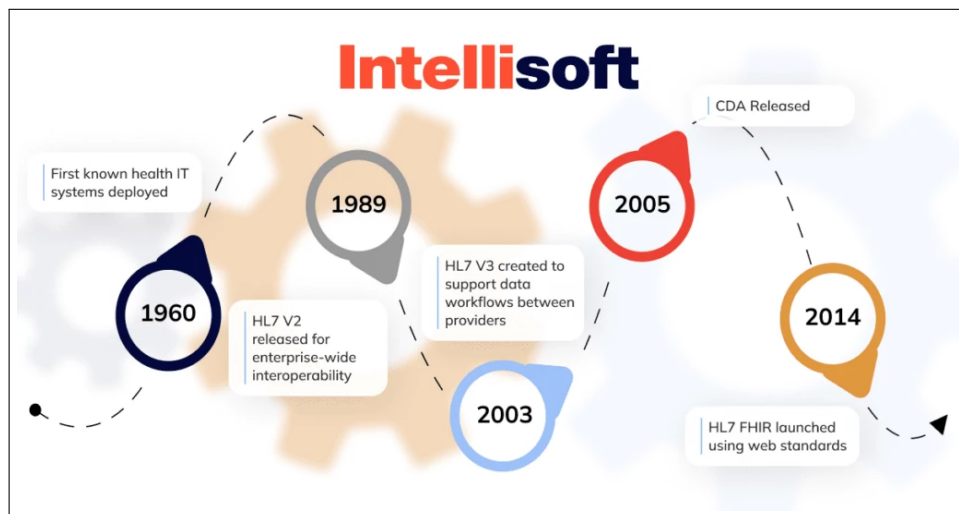


Figure 2.1: Evolution of HL7 Standards from Messaging to RESTful Resources.

2.4 Fast Healthcare Interoperability Resources (FHIR)

In response to the complexity of HL7 v3 and the limitations of v2, HL7 introduced **FHIR** (Fast Healthcare Interoperability Resources) in 2012. FHIR represents a paradigm shift from complex, custom healthcare protocols to modern web standards.

2.4.1 Core Architecture

Unlike its predecessors, FHIR is built on the RESTful API approach widely used in modern IT industries (e.g., by Google, Facebook, Twitter). It treats data elements as independent "Resources"—modular components like **Patient**, **Observation**, or **Medication**—that can be accessed and manipulated via standard HTTP methods (GET, POST, PUT, DELETE) [4].

2.4.2 Key Technical Advantages

- **Granularity via Resources:** FHIR allows systems to access specific data elements using unique URLs (e.g., `GET /Patient/123`), rather than exchanging entire heavy documents. This makes it ideal for mobile devices with limited bandwidth [4].
- **Modern Formats (JSON & XML):** While previous standards relied on complex XML or pipe-delimited text, FHIR natively supports JSON (JavaScript Object Notation), which is lightweight and directly parsable by web browsers and mobile apps [2].
- **The 80/20 Rule:** FHIR focuses on defining the 20% of requirements that satisfy 80% of common healthcare use cases. For the remaining complex or local requirements, it uses a built-in extension mechanism, ensuring the core standard remains simple and implementable [3].

2.4.3 Comparison of Standards

Table 2.2 highlights the fundamental differences between the major HL7 standards, illustrating why FHIR was chosen as the interoperability backbone for this project.

2.5 Authentication and Authorization Standards

2.5.1 OAuth 2.0 and OIDC

OAuth 2.0 [9] defines authorization grant flows: Authorization Code (web), Resource Owner Password (custom UI), Client Credentials (service-to-service). OpenID Connect (OIDC) [8] adds an identity layer with ID tokens and SSO. CFI-Care uses OAuth 2.0 Resource Owner Password flow with OIDC for token-based API access.

Table 2.2: Comparison of HL7 v2, v3, CDA, and FHIR Standards

Feature	HL7 v2	HL7 v3 / CDA	FHIR
Primary Paradigm	Event-Driven Messaging	Reference Model (RIM) / Documents	RESTful API & Resources
Data Format	Pipe-delimited text	Complex XML	JSON, XML, RDF
Transport	LLP / MLLP (TCP/IP)	SOAP / Web Services	HTTP / REST
Complexity	Moderate (Vague semantics)	High (Steep learning curve)	Low (Web-standard based)
Use Case	Hospital Backend (ADT, Orders)	Clinical Documents (Summaries)	Mobile, Web, Cloud, & Backend

2.5.2 JSON Web Tokens (JWT)

JWTs [11] are signed tokens encoding claims (iss, aud, exp, roles, scopes). Stateless API authentication validates signatures without database queries. Token revocation requires server-side tracking or short expiration windows.

2.5.3 PKCE

PKCE [15] prevents authorization code interception attacks via code verifier/challenge. Recommended for all OAuth 2.0 flows [12].

2.6 Healthcare Security and Standards

2.6.1 FHIR and SMART on FHIR

FHIR [5] defines RESTful APIs for healthcare data exchange. SMART on FHIR [7] applies OAuth 2.0 to FHIR with scoped access (e.g., `patient/Observation.read`). The FHIR consent resource [6] models patient-controlled access with time-bound and actor-specific rules.

2.7 Token-Based Authentication Patterns

2.7.1 Session Management

HTTP-only cookies prevent JavaScript access [14]; SameSite blocks CSRF. token revocation uses redis-backed session tracking or OAuth 2.0 server revocation.

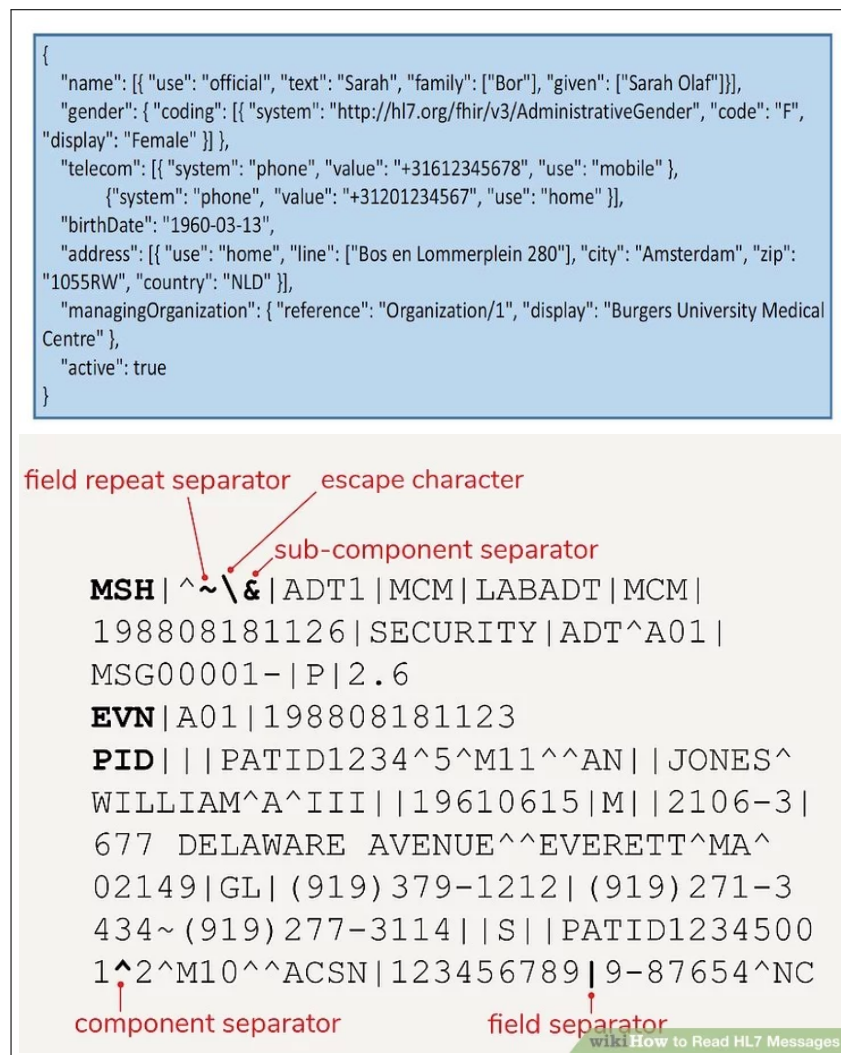


Figure 2.2: Visual Comparison of Data structure: HL7 v2 Message vs. FHIR JSON Resource.

2.8 API Security

2.8.1 Rate Limiting

Rate limiting mitigates brute-force and enumeration attacks via Redis-backed counters [25].

2.8.2 Input Validation and XSS

Schema validation (Joi) enforces format/complexity rules. OWASP [22] recommends output encoding and CSP headers.

2.8.3 CSRF

CSRF [23] is mitigated with SameSite cookies and CSRF tokens.

2.9 Mobile Application Security

2.9.1 Secure Token Storage

Android Keystore [33] provides OS-level encryption and access control, unlike browser `localStorage`.

2.10 Audit Logging and Compliance

2.10.1 Security Event Logging

OWASP [27] specifies what to log and exclude audit logs enable forensics and compliance.

2.10.2 Threat Modeling

RFC 6819 [16] outlines OAuth 2.0 threats: token theft, interception, phishing, CSRF, replay.

2.11 Infrastructure and Deployment

2.11.1 API Gateway

nginx[24] terminates TLS, routes requests, enforces rate limits, and sets security headers.

Chapter 3

Proposed Design Architecture

3.1 System Architecture

The CFI-Care system is built upon a robust three-tier architecture designed to facilitate secure and interoperable healthcare data management. The system integrates a modern frontend, a logic-heavy middleware layer, and a standards-compliant backend to ensure data consistency and security. The architecture adheres to the FHIR (Fast Healthcare Interoperability Resources) standard for all medical data exchange and utilizes OAuth 2.0 via Keycloak for identity management.

3.1.1 High-Level Architecture

The application operates through a strict separation of concerns. The Presentation Layer is an Angular-based Single Page Application (SPA) that serves as the user interface. It does not communicate directly with the data stores. Instead, all client requests are intercepted by an Nginx Reverse Proxy, which handles SSL/TLS termination and routes traffic to the appropriate internal services.

The core of the backend processing is handled by the Node.js Application Server. This server acts as the primary API gateway, implementing business logic, enforcing security policies, and managing user sessions. It communicates with the HAPI FHIR Server, a specialized Java-based component responsible for persisting clinical data in compliance with the FHIR R5 standard. Data storage is consolidated in PostgreSQL databases, while high-speed data access and session management are handled by Redis instances.

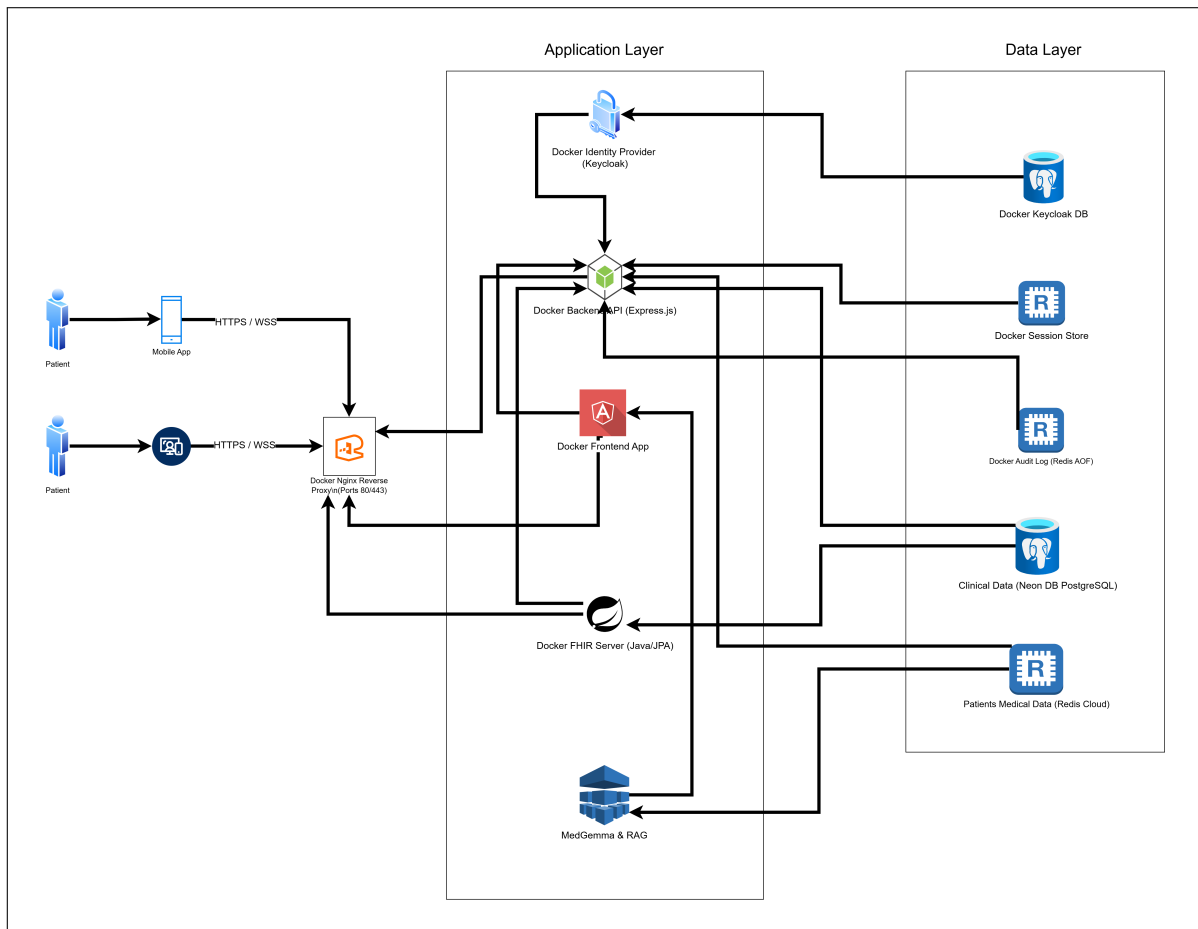


Figure 3.1: High-Level Container Architecture showing the interaction between the Nginx proxy, application services, and data persistence layers.

3.1.2 Node.js Application Server

The Node.js server, built with the Express.js framework, serves as the middleware layer that bridges the gap between the user interface and the standardized medical records. It is designed with a modular layered architecture to ensure scalability and maintainability.

Middleware and Security

Upon receiving a request, the server passes it through a comprehensive middleware stack. Security headers are applied using Helmet to prevent common web vulnerabilities. Cross-Origin Resource Sharing (CORS) is configured to restrict access to authorized domains. Crucially, the server implements rate limiting to protect API endpoints from abuse and utilizes a Redis-backed session store to manage user authentication states efficiently.

Routing and Services

The application is divided into specific route modules corresponding to healthcare domains. Dedicated endpoints manage Patients, Practitioners, Encounters, and Episodes of Care. A specialized "History Graph" module handles the retrieval and processing of graph visualization data.

Beneath the routing layer lies the service layer, which contains the core business logic. These services act as proxies to the FHIR server, transforming raw FHIR JSON into formats optimized for the frontend, such as the D3.js visualizations. They also handle document processing tasks, such as converting base64 strings to PDF files for binary storage.

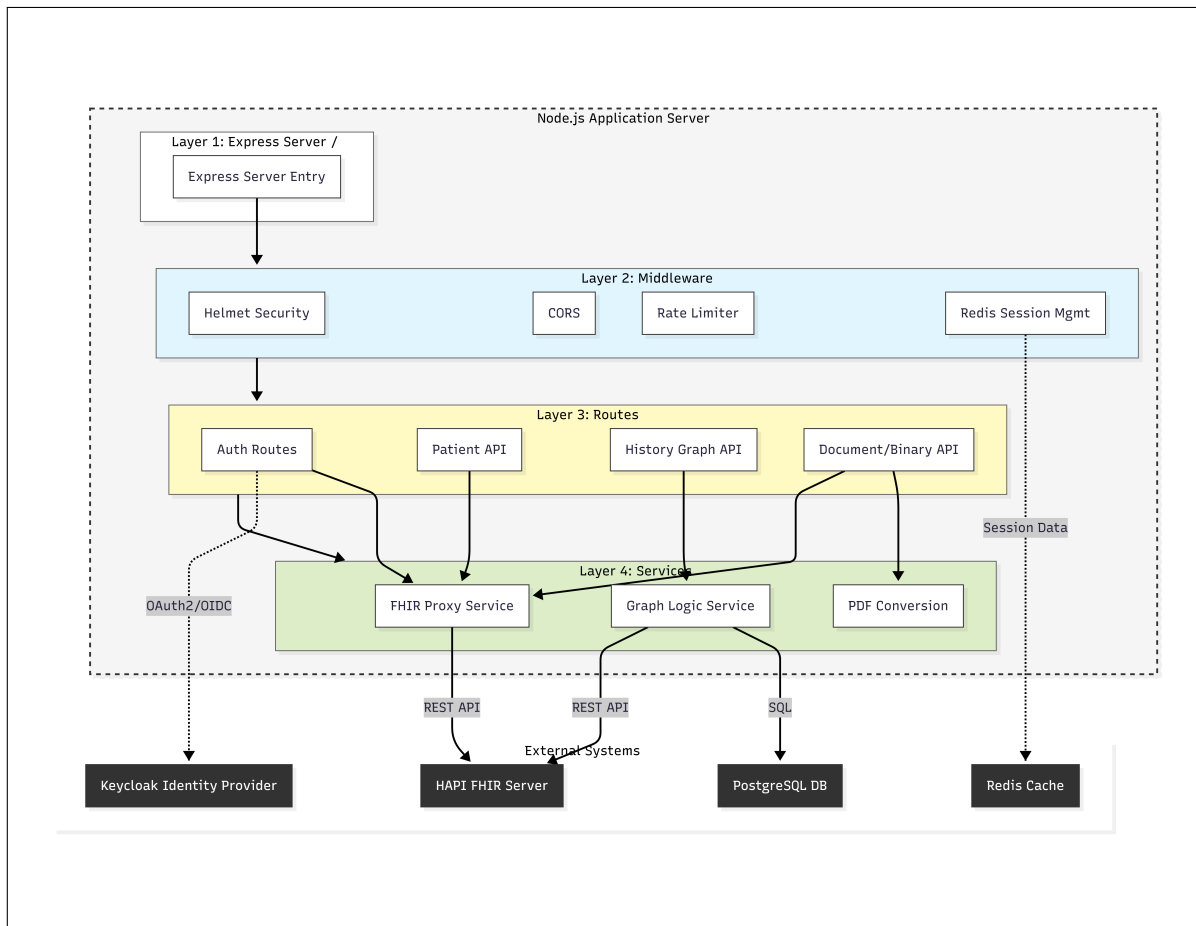


Figure 3.2: Internal layered architecture of the Node.js Application Server, detailing the middleware stack and service distribution.

3.1.3 Data Persistence and Schema

The system utilizes a polyglot persistence strategy, employing different database technologies for specific use cases to maximize performance.

Relational Data

The primary storage engine is PostgreSQL. It is divided into two logical segments. The first segment supports the HAPI FHIR server, storing all standard clinical resources (like Patients and Observations) in a highly structured format managed by Hibernate. The second segment supports the Keycloak identity provider, storing user credentials and realm configurations.

Custom Graph Schema

To support the unique "Medical History Graph" feature, a custom schema was designed alongside the standard FHIR tables. This schema consists of **encounter_nodes** and **node_relations**. These tables allow the system to map standard FHIR Encounters into a Directed Acyclic Graph (DAG), enabling the visualization of a patient's journey through time with causal links between medical events.

Caching and Auditing

Redis is utilized for ephemeral data storage. One instance is dedicated to storing user sessions, ensuring fast authentication checks. A second Redis instance operates in Append-Only File (AOF) mode to store audit logs, providing a persistent and high-speed trail of system activities.

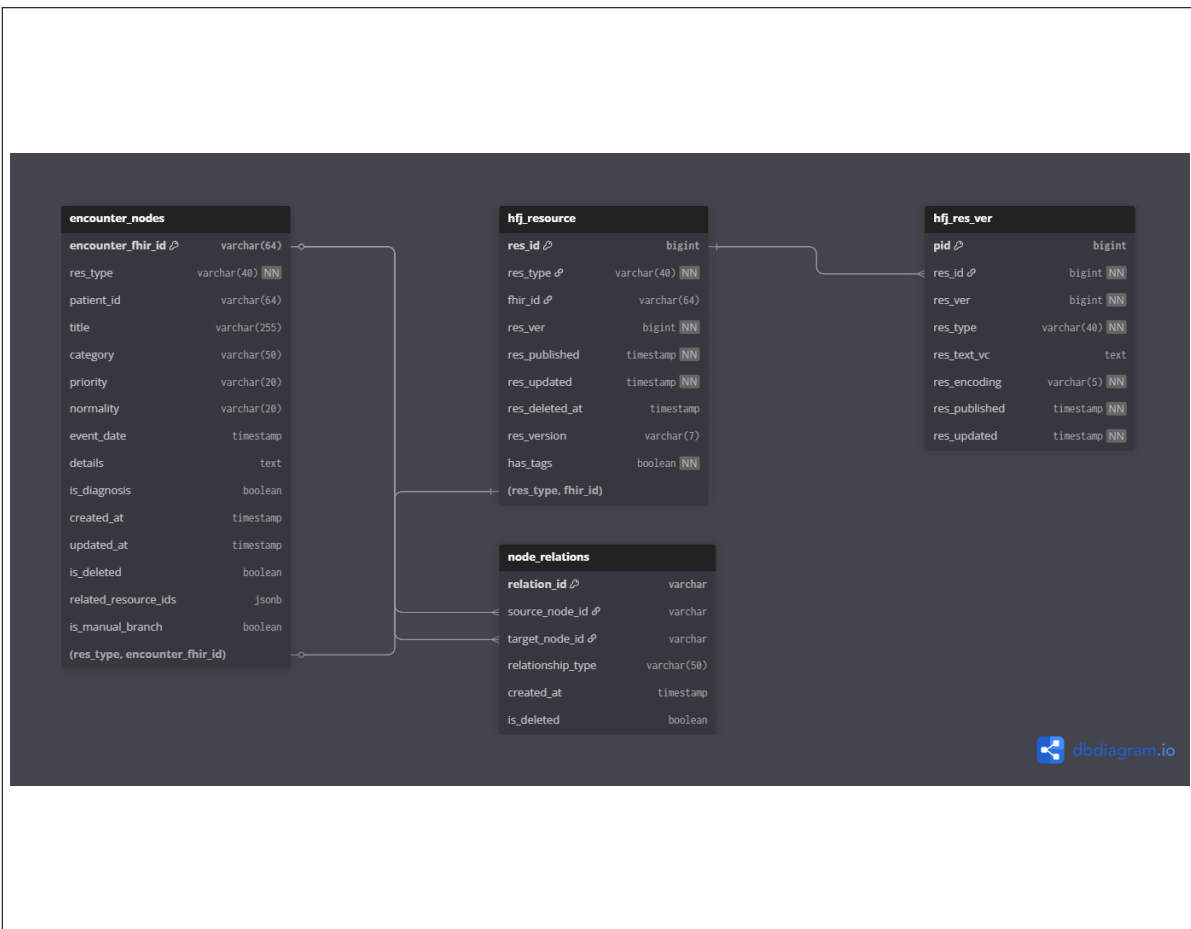


Figure 3.3: Entity-Relationship Diagram (ERD) illustrating the integration of custom graph tables with the standard FHIR resource table.

3.1.4 Request/Response Flow and Data Transformation Pipeline

Understanding how requests traverse the CFI-Care system is essential for comprehending the architecture’s design decisions. A typical request from the frontend follows a well-defined path through multiple layers, each contributing specific functionality: authentication verification, input validation, business logic execution, data transformation, and response formatting.

Request Ingress and Authentication

A request originates from the Angular frontend as an HTTP request, typically including a Bearer token in the Authorization header. The request first reaches the Nginx reverse proxy, which acts as the external-facing gateway. Nginx terminates the TLS/SSL connection, decrypts the HTTPS payload, and forwards the unencrypted request to the Node.js server over the private Docker network. Before the request reaches application logic, it passes through the Helmet middleware, which applies security headers to prevent common web vulnerabilities such as XSS (Cross-Site Scripting), CSRF (Cross-Site Request Forgery), and clickjacking. The CORS middleware then validates that

the request originates from an authorized frontend domain; requests from unauthorized origins are rejected immediately.

The next critical middleware validates the JWT token embedded in the Authorization header. The Node.js server maintains a cached set of public keys (JWKS) from Keycloak, updated periodically to handle key rotations. The token is cryptographically verified against these keys. If verification succeeds, the token claims (user ID, roles, permissions) are extracted and attached to the request context. If verification fails—due to an invalid signature, expired token, or missing token—the middleware returns a 401 Unauthorized response, and the request is rejected before reaching downstream services.

Concrete Example: Patient Data Retrieval

Consider a clinician’s request to retrieve a patient’s full medical history. The frontend issues a GET request to `/api/patients/:patientId`. After passing authentication and security middleware, the request reaches the routing layer, which dispatches it to the PatientService controller. The controller immediately implements input validation: the `patientId` parameter is checked to ensure it conforms to expected format (numeric ID or UUID, depending on the system design), and the authenticated user’s roles are verified to confirm they have permission to access that patient’s data (enforcing HIPAA privacy principles).

Before querying the database, the controller checks the Tier 1 cache (managed by `cacheHelper`). The middleware generates a deterministic cache key from the request URL: `cache:patients:patientId:{id}`. If a valid cache entry exists, the cached patient data is immediately returned with a 200 OK response, bypassing all downstream processing. This cache hit path typically completes in 20-50 milliseconds.

If a cache miss occurs, the request proceeds to the PatientService layer. The service constructs a FHIR query and forwards it to the HAPI FHIR server via an HTTP call: `GET /fhir/Patient/{patientId}`. The FHIR server retrieves the patient resource from PostgreSQL, performs any necessary transformations or computations required by the FHIR R5 standard, and returns the response in FHIR JSON format.

The PatientService receives the FHIR response and performs transformation operations: extracting relevant fields, formatting dates to match frontend expectations, computing derived values (e.g., age from birthdate), and sanitizing sensitive information if necessary. The transformed data is then stored in the Redis cache with a 1-hour TTL for future requests. Finally, the response is serialized to JSON and returned to the frontend with a 200 OK status code and appropriate cache headers to guide browser-side caching.

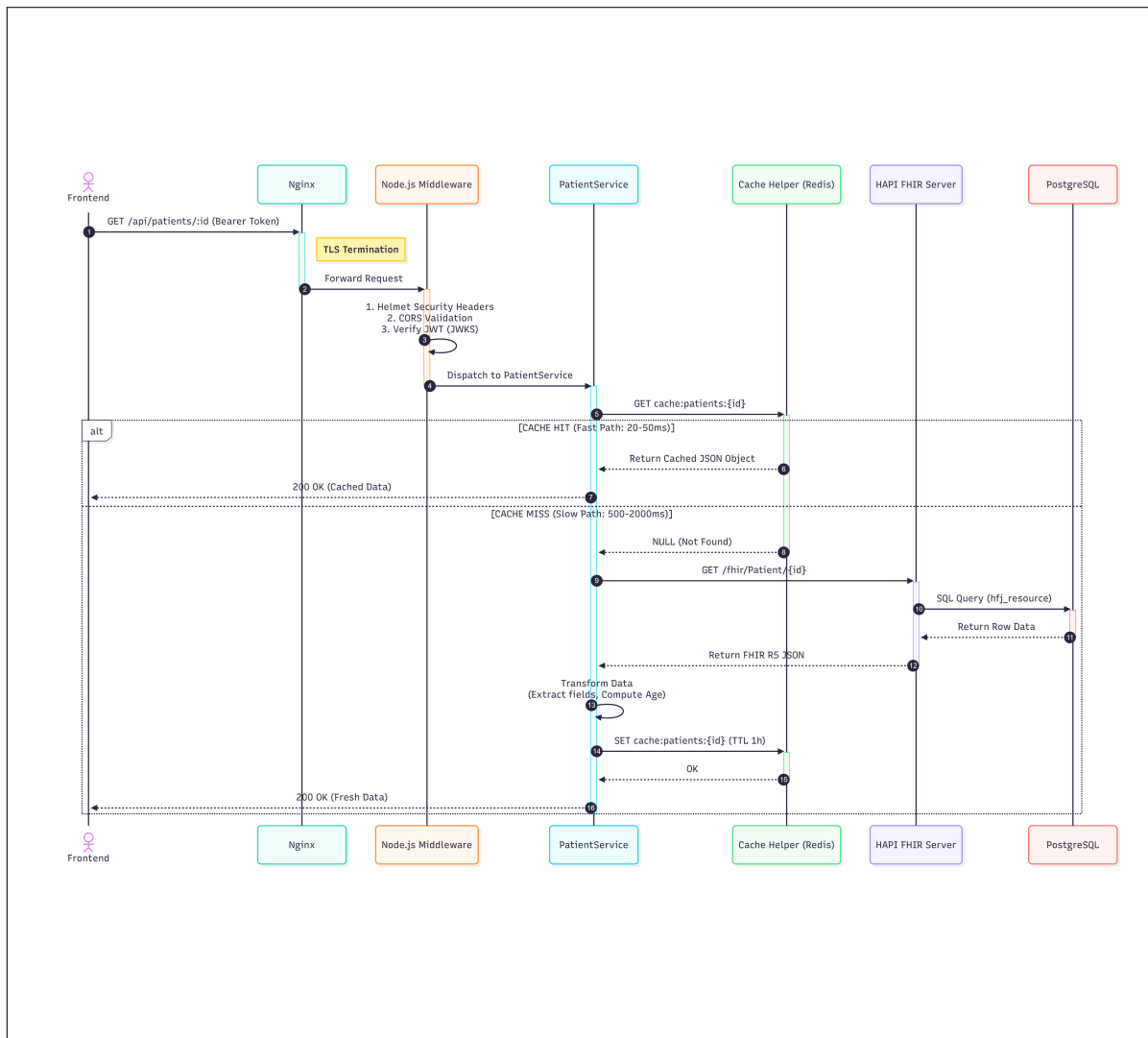


Figure 3.4: Request/Response flow for patient data retrieval, showing cache hit and miss scenarios with complete middleware pipeline.

Concrete Example: Encounter Creation and Graph Update

The encounter creation flow demonstrates more complex interactions across multiple system layers. When a clinician records a new consultation, the frontend issues a POST request to `/api/encounters` with a JSON payload containing encounter details (patient ID, encounter type, date, notes, etc.).

The request undergoes the same initial security and authentication pipeline as before. Upon reaching the `EncounterService` controller, the request enters the input validation phase. The encounter data is validated against a schema ensuring that all required fields are present and correctly formatted. The encounter date is verified to be a valid date and logically consistent (e.g., encounter date cannot be in the future). The patient ID is validated to ensure the patient exists in the system.

Next, the `EncounterService` constructs a FHIR Encounter resource conforming to the FHIR R5 standard and submits a POST request to the HAPI FHIR server: POST

/fhir/Encounter. The FHIR server validates the resource, generates a unique FHIR resource ID, persists the resource to PostgreSQL, and returns the created resource with its new ID.

The encounter creation triggers a cascade of downstream operations. The `EncounterService` receives the FHIR response and extracts the newly created encounter's ID. It then invokes the `historyGraphService`, passing the new encounter data. The `historyGraphService` performs a temporal scan of existing nodes for the patient, identifies potential parent nodes based on clinical rules and temporal windows, and creates appropriate edges in the `node_relations` table. This graph construction may take several hundred milliseconds to several seconds depending on the patient's history size.

Concurrently, multiple cache entries are invalidated. The patient-specific Tier 2 graph cache is cleared immediately, ensuring that the next graph visualization request triggers a fresh reconstruction. The Tier 1 cache entry for the `/api/patients/{patientId}` endpoint is also invalidated, forcing a fresh FHIR server query for updated patient data.

Finally, the `EncounterService` returns the newly created encounter resource to the frontend with a 201 Created status code. The response includes the encounter's FHIR ID, allowing the frontend to reference this specific encounter in subsequent requests.

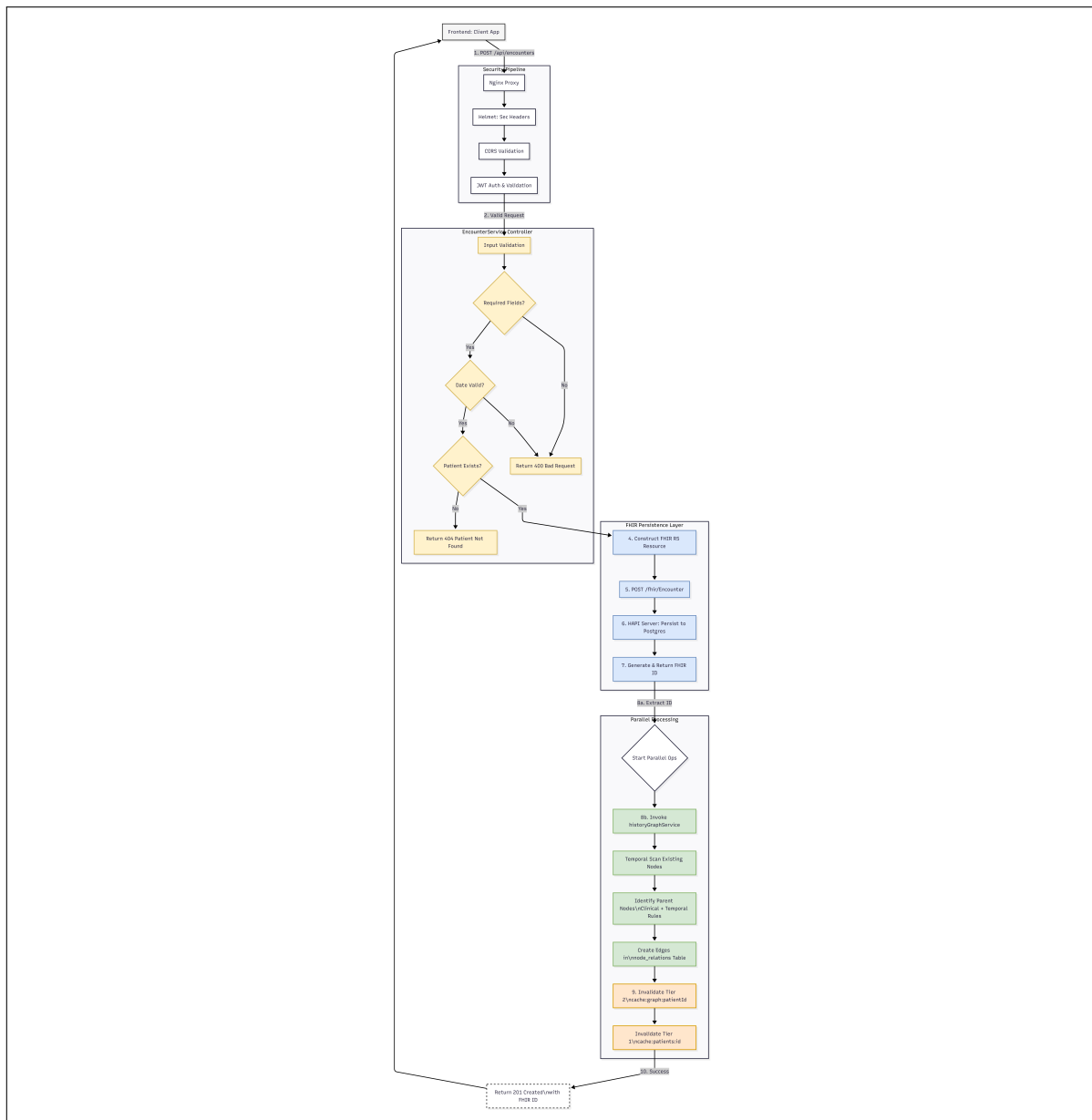


Figure 3.5: Complete encounter creation workflow showing FHIR resource persistence, graph construction, and cache invalidation cascade.

Validation Points and Error Conditions

Throughout this flow, validation occurs at multiple critical junctures. Input validation at the controller layer ensures that user-supplied data conforms to expected types and ranges. Business logic validation in the service layer verifies that operations are consistent with clinical rules (e.g., an encounter date cannot precede a patient’s birth date). FHIR resource validation at the HAPI FHIR server ensures that resources conform to the FHIR R5 specification, preventing invalid data from being persisted.

Error conditions at any stage result in appropriate HTTP status codes and error messages: 400 Bad Request for input validation failures, 403 Forbidden for authorization violations, 404 Not Found for missing resources, 409 Conflict for data consistency

violations, and 500 Internal Server Error for unexpected server failures. Each error response includes a structured JSON object with a unique error code, human-readable message, and optionally, detailed information about the nature of the failure, enabling clinicians and developers to understand and address issues.

3.1.5 Error Handling and Fault Tolerance

The CFI-Care architecture recognizes that healthcare systems cannot tolerate downtime or data loss. Error handling and fault tolerance are designed into every layer to ensure reliable operation and graceful degradation under failure conditions.

Layered Error Handling Strategy

Errors propagate through the CFI-Care system in a controlled, layered manner. At the lowest layer, database operations (PostgreSQL queries, Redis operations) can fail due to connection timeouts, query errors, or resource unavailability. The Node.js middleware layer implements error handlers that catch these exceptions, log them for diagnostics, and transform them into appropriate HTTP error responses that safely communicate the failure to clients without exposing internal implementation details (such as database error messages or stack traces).

The service layer implements domain-specific error handling. When a FHIR server call fails, the service layer attempts to determine whether the failure is transient (temporary network issue) or persistent (FHIR server down, resource not found). For transient failures, the service implements exponential backoff retry logic: the first retry occurs after 100 milliseconds, the second after 200 milliseconds, and subsequent retries double the wait time, capped at a maximum of 30 seconds. This approach allows temporary outages to resolve while avoiding overwhelming a recovering server with immediate retry attempts. For persistent failures, errors are returned to the client immediately rather than consuming retry attempts.

The controller layer handles errors from services and formats them appropriately for the client. A service that cannot retrieve a patient record returns an error code; the controller translates this into a 404 Not Found HTTP response with descriptive messaging.

Fallback Mechanisms and Graceful Degradation

When the FHIR server becomes temporarily unavailable, the CFI-Care system implements fallback strategies to maintain partial functionality. The caching layer becomes the primary data source: clinicians can still access patient records that were recently viewed, as these records remain in the Redis cache. While cached data may not reflect the absolute latest updates, it permits continued operation during brief FHIR server outages.

For the Patient History Graph, if the graph reconstruction fails due to FHIR server unavailability, the system returns a cached version of the graph if one exists, even if it

is slightly stale. This allows clinicians to view previously computed graphs rather than receiving a complete failure. A notification is displayed to indicate that the graph may not reflect recent changes.

For new operations that require FHIR server access (creating encounters, adding diagnoses), if the FHIR server is unavailable, the system cannot proceed and returns a 503 Service Unavailable response, informing the clinician that the action cannot be completed at this moment. Rather than accepting incomplete or invalid data, the system fails safely, requiring the user to retry when the service recovers.

Resilience for Cache Operations

Redis provides the caching infrastructure for both session management and data caching. If Redis becomes unavailable, the system implements fallback strategies. For session caching, a secondary in-memory session store provides a fallback mechanism, allowing authentication to continue for users with active sessions, though new sessions cannot be created. For data caching, cache misses gracefully trigger direct queries to the FHIR server, bypassing the cache entirely but maintaining functionality.

Both Redis instances (session store and audit log store) are configured with persistence mechanisms. The session Redis instance uses RDB snapshots to periodically save state to disk, enabling recovery of active sessions if the instance restarts. The audit log Redis instance operates in AOF (Append-Only File) mode, ensuring every write is persisted to disk before acknowledging the write, guaranteeing that audit logs are never lost even if the Redis instance crashes.

Logging and Observability for Error Diagnosis

All errors are logged with structured logging that includes timestamp, error level (ERROR, WARN, INFO), service component generating the error, error code and message, request context (user ID, patient ID, operation being performed), and stack trace for unexpected exceptions. This structured logging enables rapid diagnosis of issues: operators can search logs by error code to identify all instances of a particular failure, by user ID to understand a user's experience during an outage, or by component to focus on specific services.

Critical errors are propagated to alerting systems, enabling operators to be notified of failures in real-time. For instance, if the FHIR server becomes unavailable, an alert is triggered within seconds. If error rates exceed thresholds, alerts notify operators that the system is degrading. This proactive monitoring enables rapid response to emerging issues before they impact clinicians' ability to deliver care.

3.1.6 Security and Infrastructure Layer

The infrastructure is secured through a centralized Identity and Access Management (IAM) system using Keycloak. Keycloak handles all OAuth 2.0 and OpenID Connect

flows, issuing JSON Web Tokens (JWT) that the Node.js backend validates against a public key set (JWKS).

All components are containerized using Docker and orchestrated via Docker Compose. The environment is isolated within a private bridge network, with Nginx acting as the sole entry point. Nginx enforces SSL/TLS encryption using locally generated certificates, ensuring that all data in transit is encrypted. Containers are configured with read-only file system mounts and strict privilege limitations to minimize the security attack surface.

3.1.7 HAPI FHIR Server Implementation

The core component responsible for standardizing healthcare data within the CFI-Care system is the FHIR Server. This server is implemented using the HAPI FHIR JPA Server Starter framework. It is built upon the Java Spring Boot ecosystem and provides a fully compliant implementation of the FHIR Release 5 (R5) standard. This choice ensures that all clinical data, regardless of its source, adheres to international interoperability protocols and persists reliably within the database.

To tailor the server for the specific needs of this project, several important configuration changes were applied to the default setup. To maintain a lightweight and efficient runtime, advanced features that were not immediately required were explicitly disabled. This includes the Clinical Reasoning module and the CDS Hooks service. Similarly, bulk export and import operations were deactivated to prevent unnecessary resource consumption. Conversely, the OpenAPI documentation endpoints were enabled. This configuration allows developers to inspect the API structure and test endpoints directly through a web interface.

The persistence layer is powered by a PostgreSQL database connected via the Hibernate JPA engine. Specific configurations were applied to the Hibernate settings to optimize performance. The system uses the dedicated `HapiFhirPostgresDialect` to ensure efficient SQL generation. Additionally, the database schema management is configured to automatically update the table structures upon server startup, ensuring that the database remains synchronized with the code.

The server is responsible for managing a wide array of clinical resources necessary for the application. These include foundational entities such as Patient and Practitioner, as well as clinical events like Encounters, Procedures, and Observations. It also handles complex data types, including MedicationRequests for prescriptions and Binary resources for storing documents like PDF files.

For deployment, the server utilizes a secure multi-stage Docker build process. The first stage uses Maven to compile the application code and generate the necessary artifacts. The final runtime image is built upon a "distroless" Java 17 base image. This approach significantly reduces the final container size and improves security by removing unnecessary operating system tools and shells from the production environment.

3.2 API Design and Endpoints

The communication between the frontend client and the backend server is established through a structured RESTful API. This design ensures that the system remains stateless and scalable, utilizing standard HTTP methods to perform operations on resources. The Node.js application server acts as the centralized gateway, exposing a unified set of endpoints that handle both standard clinical data and custom graph logic.

3.2.1 RESTful Structure and Formats

All API interactions strictly adhere to the Javascript Object Notation (JSON) format for both request bodies and response payloads. The system utilizes standard HTTP verbs to define the nature of the operation. GET requests are used exclusively for retrieving data without side effects, while POST requests handle the creation of new resources. PUT methods are employed for updating existing records, and DELETE methods remove specific resources when permitted.

Responses from the server are standardized to ensure predictability for the client application. Successful operations return a 200 OK status code accompanied by the requested data object. In cases of resource creation, a 201 Created status is returned. Error handling is centralized, ensuring that any failure creates a consistent JSON error object containing a human-readable message and a specific error code, rather than exposing raw server stack traces.

3.2.2 FHIR-Compliant Endpoints

A significant portion of the API is dedicated to proxying standard FHIR resources. Endpoints such as `/api/patients` and `/api/encounters` act as a validation and caching layer sitting in front of the HAPI FHIR server. When the frontend requests patient details, the Node.js server intercepts this call, validates the parameters, and then forwards the request to the underlying Java server. The response is strictly compliant with the FHIR R5 standard, ensuring that the data structure remains interoperable with other external healthcare systems.

3.2.3 Custom History Graph Endpoints

Beyond standard FHIR resources, the API exposes specialized endpoints designed to support the Patient History Graph visualization. The primary endpoint, `/api/historyGraph`, does not return a simple list of records. Instead, it aggregates data from multiple FHIR resources and transforms them into a graph structure containing nodes and relational edges. This allows the frontend to render the complex temporal relationships between medical events without needing to perform heavy data processing in the browser.

Method	Endpoint	Description
GET	/api/patients	Retrieve list of patients with pagination support
POST	/api/patients	Register a new patient with FHIR validation
GET	/api/encounters/:id	Get specific encounter details including clinical observations
GET	/api/historyGraph/:id	Get patient history graph nodes and causal relationships
POST	/auth/login	Authenticate user and obtain JWT token via Keycloak

Table 3.1: Key REST API Endpoints provided by the Node.js Backend.

3.3 Patient History Graph Implementation

A core distinguishing feature of the CFI-Care backend is the Patient History Graph, which visualizes a patient’s medical journey as a Directed Acyclic Graph (DAG). Unlike standard FHIR lists, which present data linearly, this graph models causal and temporal relationships between medical events. This representation provides clinicians with a sophisticated tool for understanding the evolution of a patient’s condition, particularly in complex cases involving multiple concurrent diagnoses or extended treatment histories.

3.3.1 Motivation: Beyond Linear Medical Records

Traditional Electronic Health Records (EHRs) typically present patient data as chronologically ordered events: a consultation on January 1st, a lab test on January 3rd, a prescription on January 5th, and so forth. While this linear representation is straightforward to implement and understand, it obscures the causal relationships that are essential to clinical reasoning. Consider a patient with Type 2 Diabetes presenting with hypertension and elevated cholesterol levels. In a linear record, these appear as separate events without explicit connection. However, a clinician recognizes that these conditions are causally related—elevated cholesterol and hypertension may be comorbidities stemming from the underlying metabolic dysfunction of diabetes.

The Patient History Graph addresses this limitation by explicitly modeling causality and temporal dependencies. Each medical event is represented as a node in the graph, and directed edges represent causal or temporal relationships. This graphical representation allows clinicians to trace the progression of a specific condition across multiple encounters and interventions, identify temporal clusters of related events that may indicate disease progression or treatment response, visualize the impact of therapeutic

interventions on subsequent clinical outcomes, and differentiate between independent medical episodes and related sequences of events. By making these relationships explicit, the graph transforms raw temporal sequences into clinically meaningful narratives that support more effective decision-making.

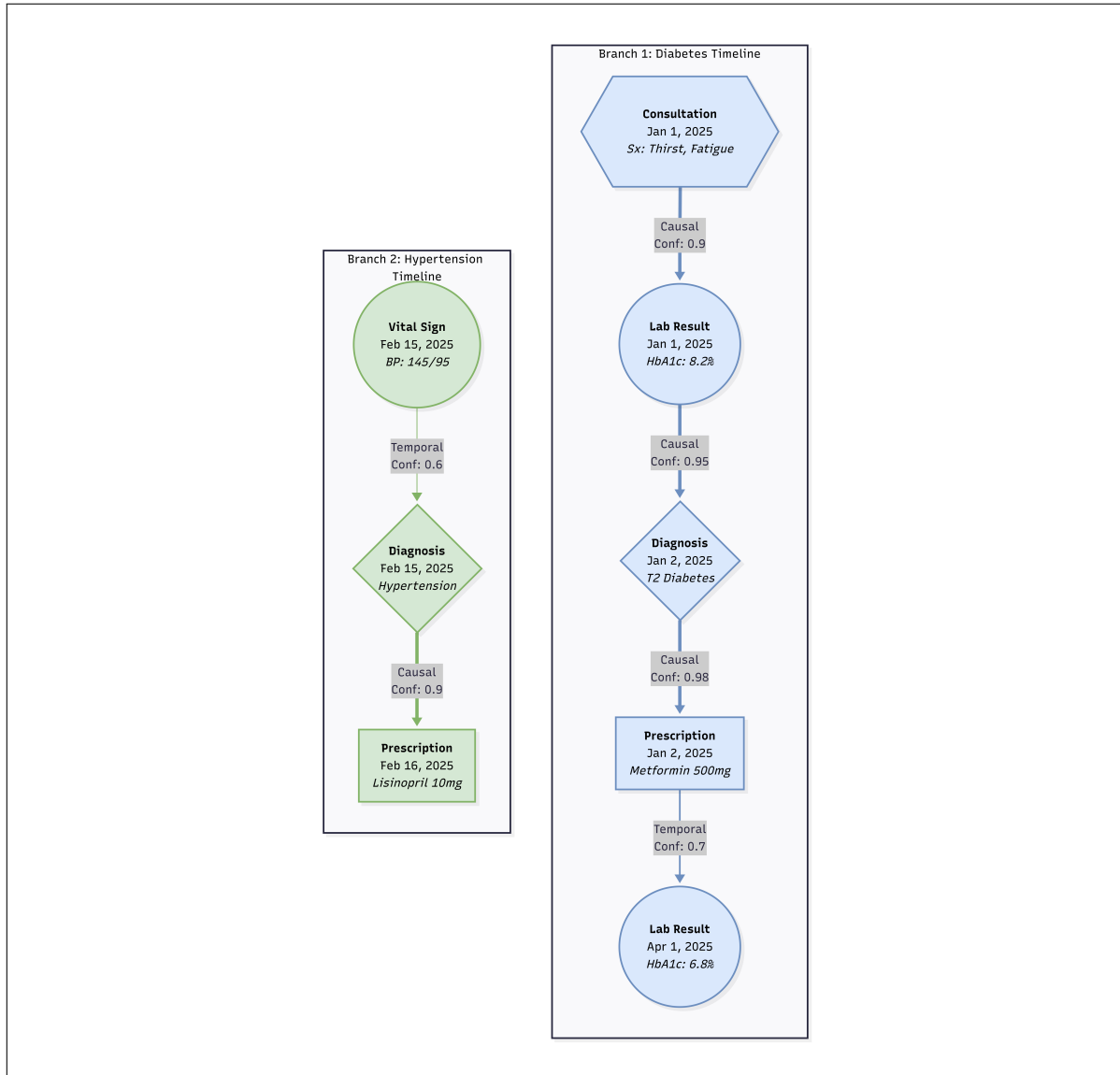


Figure 3.6: Example Patient History Graph showing a diabetes patient with concurrent hypertension, demonstrating temporal branching and multiple relationship types.

3.3.2 Graph Data Model

The Patient History Graph is built upon a relational foundation with two primary tables: `encounter_nodes` and `node_relations`.

Node Representation

Each node in the graph represents a distinct clinical event or observation. The system recognizes six primary node types: **Consultation** represents a clinical encounter between patient and clinician; **Diagnosis** denotes a confirmed medical condition recorded during or after a consultation; **Prescription** indicates a medication prescribed to address a specific condition; **LabResult** captures laboratory or diagnostic test results; **Vital** encompasses blood pressure, temperature, and other vital signs; and **Symptom** represents patient-reported subjective findings.

Each node stores rich metadata including its creation timestamp, an associated FHIR resource ID for traceability, its clinical category, and the patient to which it belongs. A fundamental design principle of the Patient History Graph is immutability: nodes, once created, cannot be modified or deleted. This architectural choice ensures that the graph preserves a complete and auditable record of the patient's medical journey, enabling clinicians to understand not just what happened, but also when records were created and by whom.

Edge Representation

Edges in the graph represent causal or temporal relationships. An edge from node *A* to node *B* indicates that event *A* preceded and potentially caused or informed event *B*. The system maintains an explicit `node_relations` table storing parent-child pairs, enabling efficient graph traversal for visualization and analysis.

3.3.3 Graph Construction Algorithm

The graph construction logic is encapsulated within the `historyGraphService`, a core backend service invoked whenever a new medical event is recorded. The algorithm operates in several stages:

Stage 1: Node Creation

When a new clinical event is received from the FHIR server (such as a new prescription, lab result, or consultation record), the system creates a corresponding node in the `encounter_nodes` database table. This node captures essential event information: the patient to which the event belongs, the clinical category of the event (Consultation, Diagnosis, Prescription, etc.), the timestamp indicating when the event occurred, a reference ID linking back to the source FHIR resource for data provenance, and structured clinical details extracted from the FHIR resource including diagnosis codes, medication specifications, laboratory values, and other relevant clinical parameters.

Stage 2: Temporal Scanning and Parent Identification

After node creation, the algorithm performs a critical temporal backward scan of all existing nodes for the patient to identify potential parent nodes. This scan is bounded

by three sets of clinical rules that determine what types of events can meaningfully be causally related. First, event type rules enforce domain-specific constraints: for instance, a Prescription node can only have a Consultation, Diagnosis, or another Prescription as a parent, while a Consultation cannot have a Prescription as a parent. These rules prevent semantically meaningless relationships from being created. Second, temporal window constraints ensure that relationships are only established between events within a clinically relevant time window. A prescription issued more than six months after a consultation is statistically unlikely to be causally related unless additional context suggests otherwise. Third, specificity matching ensures that the algorithm correctly associates events with their most clinically relevant predecessors. For example, a prescription for metformin (used in diabetes management) is linked to the most recent Diabetes diagnosis rather than to an unrelated hypertension diagnosis, even if both diagnoses exist in the patient’s history.

The algorithm identifies the most recent “eligible” parent node based on these constraints. In cases where multiple candidates exist with similar temporal proximity, the system selects the most clinically specific match, prioritizing condition-specific diagnoses over generic symptoms or vice versa depending on the event context.

Stage 3: Edge Creation

Once a parent node is identified, a directed edge is created from parent to child in the `node_relations` table. The edge stores metadata including the relationship type (causal, temporal, or associative) and a confidence score indicating the algorithm’s certainty in the relationship.

Algorithm Pseudocode

The following pseudocode formalizes the algorithm:

```
function constructGraphNode(newEvent, patientId):
    // Stage 1: Create node
    node = createNode(newEvent, patientId)

    // Stage 2: Scan for parents
    existingNodes = queryNodesByPatient(patientId)
    candidateParents = []

    for existingNode in existingNodes:
        if isValidRelationship(newEvent.type, existingNode.type):
            if isWithinTemporalWindow(newEvent, existingNode):
                if matchesClinicalContext(newEvent, existingNode):
                    candidateParents.add(existingNode)

    // Stage 3: Select and link parent
    if candidateParents is not empty:
```

```

        parentNode = selectMostRelevantParent(candidateParents)
        createRelation(parentNode, node)
    end if

    // Invalidate cache
    invalidateGraphCache(patientId)

    return node
end function

```

3.3.4 Temporal Branching and Concurrent Episodes

Real-world patient histories are rarely linear. A patient may have multiple concurrent health issues being managed in parallel. For example, a patient may simultaneously receive treatment for diabetes, hypertension, and arthritis. In a traditional linear EHR, this complexity is flattened; all events appear chronologically without indication of which episode they belong to.

The CFI-Care graph model handles this through an explicit branching mechanism:

Head Node Concept

A "Head Node" is a node with no outgoing edges to other nodes in the current timestamp window. When a new clinical event arrives that does not fit within any existing causal chain (i.e., no valid parent is found), the system creates a new Head Node, effectively initiating a new branch in the history graph.

For example, consider a patient's history:

1. Consultation for chest pain (2025-01-01)
2. EKG test (2025-01-01)
3. Cardiology referral (2025-01-02)
4. New consultation for joint pain (2025-02-15) — **New Branch**
5. X-ray of knee (2025-02-15)
6. Rheumatology referral (2025-02-16)

The system recognizes that the joint pain consultation on 2025-02-15 cannot be causally linked to the earlier cardiology events (temporal gap exceeds threshold, clinical context is unrelated). Therefore, it creates a new Head Node for the rheumatology branch, allowing clinicians to visually separate the two episodes.

Visual Implications

From a visualization perspective, branching creates a multi-root forest structure (multiple separate trees within the graph). The frontend rendering engine positions these branches side-by-side or in hierarchical layout, enabling clinicians to track multiple concurrent conditions without visual clutter or confusion.

Clinical Advantages

Explicit branching provides significant clinical benefits that improve the utility of the Patient History Graph. Clinicians immediately recognize which events belong to which condition through visual separation, substantially reducing cognitive load compared to linearly ordered records. The system can provide condition-specific recommendations by analyzing the isolated branch rather than considering the entire patient history, enabling more targeted and relevant clinical decision support. Additionally, each branch can be summarized independently for specialist-to-specialist referrals, allowing specialists to focus on the specific problem domain without irrelevant context from other concurrent conditions.

3.3.5 Relationship Classification

Not all edges in the Patient History Graph carry the same semantic weight or clinical significance. The system classifies relationships into three distinct types to preserve this important distinction. Causal relationships represent situations where Node *A* directly caused or necessitated Node *B*. For example, a Diabetes Diagnosis directly necessitates a Metformin Prescription. These edges carry high confidence scores and strong clinical significance, indicating a clear cause-and-effect relationship. Temporal relationships occur when Node *A* preceded Node *B* within the same clinical episode, but causality is not explicitly established. For instance, a Consultation followed by a Blood Pressure Reading taken during the same visit represents a temporal relationship rather than a causal one. Associative relationships capture scenarios where Node *A* and Node *B* are related through shared clinical context—such as both addressing the same underlying condition—but neither directly causes the other. For example, a High Cholesterol Lab Result and a Diabetes Diagnosis both present in the same patient might be associated through their shared metabolic dysfunction.

Each relationship in the graph stores a confidence score ranging from 0.0 to 1.0, generated by the construction algorithm based on how well the relationship satisfies the various constraint criteria. High-confidence relationships with scores exceeding 0.8 are displayed prominently in the visualization, while lower-confidence relationships are shown with reduced visual emphasis or as optional links that the clinician can explore if desired.

3.3.6 Handling Edge Cases

The Patient History Graph implementation must gracefully handle several challenging scenarios that arise in real-world clinical practice. Retroactive diagnosis occurs when

a patient receives a diagnosis that applies to earlier symptoms after those symptoms have already been recorded. For example, a patient might experience chest pain on January 1st and only receive a diagnosis of coronary artery disease on March 1st. The algorithm detects this temporal mismatch and retroactively relinks the symptom node to the new diagnosis, maintaining causal clarity and preventing the false impression that the symptom was unexplained.

Conflicting information presents another challenge. When new FHIR data contradicts previously recorded information—such as a diagnosis being changed, retracted, or corrected—the system must handle this gracefully. Rather than deleting nodes (which would violate the immutability principle and destroy the audit trail), the system creates a new node representing the correction and links it appropriately to existing nodes. This approach preserves the complete historical record while accurately reflecting the current clinical understanding.

Circular references represent a potential structural problem. Although directed acyclic graphs (DAGs) cannot, by definition, contain cycles, the algorithm must validate that no accidental cycles are introduced during edge creation. This validation is enforced through topological sorting checks performed before persisting relationships to the database, preventing data consistency issues that could arise from cycles.

3.3.7 Query Patterns and Optimization

The frontend visualization layer requires efficient access to the graph structure through several common query patterns, each optimized for specific clinical use cases. Full Graph Retrieval fetches all nodes and edges for a patient, which is necessary during the initial page load when clinicians first view a patient’s complete medical history. This operation is optimized through caching strategies discussed in Section 3.4. Ancestor Traversal answers questions such as “What led to this prescription?” by fetching all ancestor nodes of a specific event. This pattern is implemented via recursive queries that are bounded by depth to prevent unbounded traversals. Branch Isolation allows clinicians to focus on specific medical episodes, such as “Show only cardiology-related events,” by fetching all nodes within a specific branch. This operation uses topological partitioning to efficiently isolate branches without scanning the entire graph. Temporal Range Queries retrieve nodes within a specific date range, enabling clinicians to analyze disease progression over a specific time period. These queries leverage indexed timestamp columns to achieve $O(\log n)$ lookup time complexity, ensuring responsiveness even for patients with extensive histories.

3.4 Performance Optimization

To ensure low-latency responses for the frontend visualizations, the backend implements a specialized Two-Tier Caching Strategy using Redis. This hierarchical caching approach balances data freshness with response times, recognizing that different types of medical data have different update frequencies and computational costs.

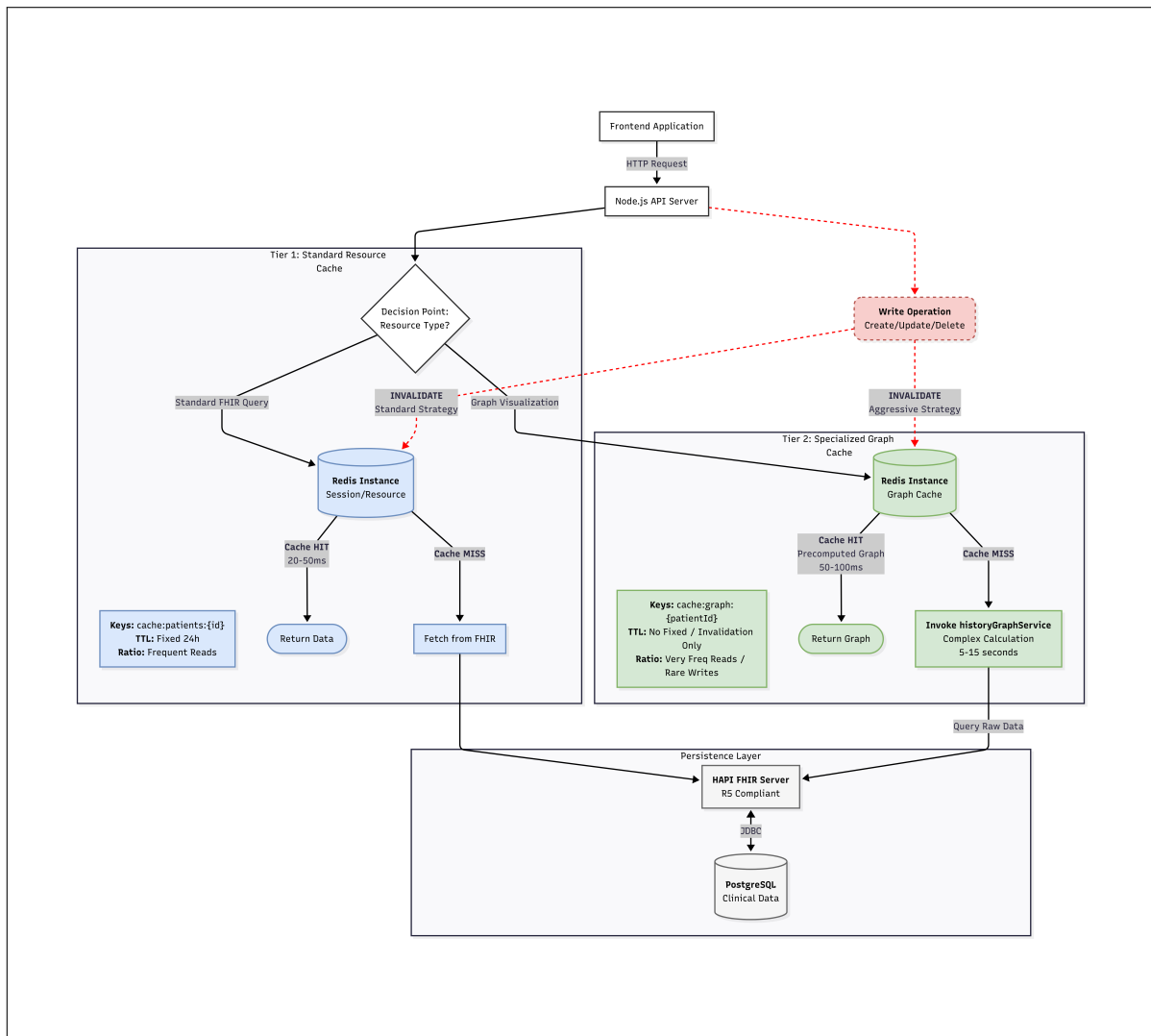


Figure 3.7: Two-Tier Caching Architecture showing distinct strategies for standard FHIR resources (Tier 1) and complex graph structures (Tier 2).

3.4.1 Tier 1: Standard Resource Cache

The first tier utilizes a generic `cacheHelper` middleware that intercepts HTTP requests for standard FHIR resources. This middleware operates at the request level, functioning as a transparent cache layer between the frontend client and the backend processing pipeline.

Mechanism and Interception

When an HTTP request arrives at the backend (such as a GET request to `/api/patients`), the `cacheHelper` middleware performs a sequence of operations to determine whether a cached response can be served. The middleware first generates a deterministic cache key from the request URL and query parameters—for example, a request to `/api/patients?page=1&limit=20` generates the key `cache:patients:page:1:limit:20`.

The middleware then queries the Redis cache for an entry matching this key. If a valid cache entry exists, meaning the entry has not expired, the cached response is immediately returned to the client, entirely bypassing the FHIR server, database query execution, and all downstream processing. This direct cache-to-client path reduces latency from potentially 500-2000ms (database query time) to sub-50ms (Redis in-memory retrieval). If no entry exists or the entry has expired, the request proceeds through the normal processing pipeline: the backend queries the FHIR server, processes the response, and returns it to the client. Before returning, the response is stored in Redis for future requests, repopulating the cache.

Time-To-Live (TTL) Management

Cached FHIR resources are assigned a default Time-To-Live (TTL) of 1 hour, representing a clinically acceptable window where cached data is considered sufficiently fresh for clinical use. This 1-hour window is chosen based on several practical considerations. From a clinical workflow perspective, most healthcare workflows operate on new fresh data every hour. A patient's medication list, diagnosis history, and vital signs are statistically unlikely to change multiple times within a single hour in most clinical scenarios. From a system load perspective, a 1-hour TTL significantly reduces the query volume to the underlying FHIR server and database, minimizing computational load during peak usage hours when many clinicians are accessing patient data simultaneously. While the 1-hour window does introduce some degree of data staleness, this tradeoff is clinically acceptable for read-heavy operations on relatively stable data that changes infrequently.

However, the TTL is configurable on a per-resource-type basis to accommodate different data freshness requirements. Real-time vital signs or active medication adjustments might use a shorter TTL of one hour to ensure clinicians see recent changes, while historical diagnoses that rarely change might use a longer TTL of 12 hours to reduce computational overhead.

Cache Invalidation for Tier 1

Although Tier 1 uses a fixed TTL-based expiration, certain write operations trigger explicit cache invalidation to ensure data consistency. When a patient record is modified—such as contact information changes or new allergies being recorded—the corresponding cache entries for that patient are immediately removed, forcing a fresh fetch on the next request. Similarly, when a new encounter is recorded or an existing one is updated, the cache entries for `/api/encounters` are invalidated to reflect the changes. The system maintains a comprehensive mapping of dependencies between cache keys and FHIR resources. When a resource is modified, all dependent cache entries are invalidated simultaneously, preventing scenarios where multiple cache entries contain stale references to the same resource.

Practical Impact

The practical benefit of Tier 1 caching becomes apparent in typical clinic workflows where healthcare providers request the same patient's record multiple times during a

single day. Without caching, each request would trigger a database query taking 500-1000ms, and checking the same patient 5 times would incur 2500-5000ms of cumulative latency. With Tier 1 caching in place, the first request incurs the full latency of 500-1000ms, but subsequent requests within 24 hours are served from cache in approximately 20-50ms each. For five checks of the same patient, the total latency becomes 500-1000ms plus 80-200ms for the cached requests, totaling 580-1200ms. This represents a 75-80 percent reduction in latency, dramatically improving the responsiveness of the system and reducing clinician wait times during patient data retrieval.

3.4.2 Tier 2: Specialized Graph Cache

The second tier is specifically designed for the computationally intensive Patient History Graph. While Tier 1 caches simple resource retrieval, Tier 2 caches the results of complex graph construction and relationship mapping.

Computational Cost of Graph Construction

Constructing a Patient History Graph from raw FHIR resources is computationally expensive for several interconnected reasons. Data aggregation requires retrieving all FHIR resources for a patient, including consultations, diagnoses, prescriptions, lab results, vitals, and symptoms, potentially from multiple FHIR repositories. A patient with an extensive medical history might have hundreds of such resources, necessitating multiple server calls and database queries. Relationship inference constitutes the most computationally intensive phase. For each new node, the algorithm must scan all existing nodes for that patient, evaluate whether causal relationships should exist by checking temporal windows, clinical context compatibility, and event type rules, compute confidence scores for each potential relationship, and determine the most relevant parent. This represents an $O(n)$ operation where n is the number of existing nodes, and complex patients with 500+ nodes can require significant computational resources. Graph formatting transforms the raw graph structure into a visualization-ready format suitable for the frontend rendering library. This transformation includes computing optimal node positions in the visual layout, determining visual attributes such as color, size, and emphasis, serializing the entire structure to JSON, and applying any additional formatting for the specific frontend framework. For a patient with 500 nodes, these cumulative operations can collectively require 5-15 seconds of computational time—far too slow for the responsive interactive experience that clinicians expect.

The Graph Cache Manager: `toonNodesCacheHelper`

The `toonNodesCacheHelper` service manages caching specifically for the Patient History Graph. Unlike the generic Tier 1 cache which uses simple TTL expiration, the graph cache is patient-specific and extensively optimized for the unique characteristics of graph data. Each patient has a dedicated cache entry with the key `cache:graph:{patientId}`, containing their complete precomputed graph structure. The cache value stores a comprehensive JSON object containing all nodes with their associated metadata (type,

timestamp, clinical details), all edges with their relationship types and confidence scores, and precomputed visual attributes including node positions and branch assignments. Unlike Tier 1 caching which relies on fixed TTL expiration, the graph cache does not use time-based expiration at all. Instead, it relies entirely on explicit invalidation to ensure that cached data always reflects the current patient history.

Aggressive Invalidation Strategy

The graph cache employs an aggressive invalidation approach that prioritizes data consistency over computational efficiency. Any write operation to a patient’s medical history immediately invalidates their corresponding graph cache entry. This design reflects a fundamental tradeoff in the caching strategy: write operations are relatively rare compared to read operations in clinical workflows, while read operations dominate. A single patient might have their graph read hundreds of times per day across multiple clinicians viewing the same patient from different workstations or different clinical contexts, yet the patient’s medical history is modified only a few times per day. Given this asymmetry, it is computationally more efficient to invalidate the cache upon writes (an immediate operation) than to maintain cache staleness during reads or to implement complex update-in-place strategies. The invalidation is triggered by several categories of events: recording a new clinical event such as a consultation, diagnosis, prescription, or lab result; updating or correcting an existing node; modifying relationships between nodes; or retracting or changing a diagnosis or medication. Any of these operations immediately removes the cached graph, forcing reconstruction on the next request.

Cache Reconstruction Workflow

When a graph cache miss occurs, either due to invalidation from a write operation or because the cache has never been populated for that patient, a well-defined reconstruction workflow is executed. The frontend or backend first requests the graph for the patient. The `toonNodesCacheHelper` detects the cache miss and invokes the `historyGraphService` to reconstruct the graph from scratch. The reconstruction process retrieves all FHIR resources for the patient, executes the complete graph construction algorithm including temporal scanning and parent identification, and computes visual attributes. Once complete, the entire graph structure is serialized to JSON and stored in Redis. The fully reconstructed cache is then returned to the requesting client. Subsequent requests within the same session or from other clinicians viewing the same patient retrieve the cached graph in sub-100ms latency, providing responsive interactive performance.

Hit Rate and Performance Impact

The effectiveness of the graph cache in improving system performance depends heavily on the read-to-write ratio, which varies depending on the clinical workflow pattern. In read-heavy workflows, which represent the typical clinical use case, a clinician views a patient’s graph multiple times during a consultation, compares it with previous snapshots to track disease progression, and discusses findings with colleagues or consulting

specialists. The same graph may be read 10-20 times before any modification to the patient record occurs. In these scenarios, the graph cache achieves hit rates of 85-95 percent, resulting in dramatic performance improvements. A graph that would normally require 15-20 seconds of computational time to construct is served from cache in 50-100ms, a 100-200x latency reduction. In contrast, write-heavy workflows are rare but do occur, such as when a clinician is entering comprehensive historical data for a newly-registered patient, recording 20-30 events that generate new medical events in quick succession. Each new event triggers cache invalidation, causing multiple cache misses and requiring full reconstructions. In these scenarios, the cache hit rate drops to 20-30 percent. The aggressive invalidation strategy in this case sacrifices caching efficiency to ensure that data consistency is always maintained. In typical clinical workflows, the combination of read-heavy access patterns and Tier 2 caching provides a 100-200x latency improvement for graph visualization, translating to substantially more responsive clinical interfaces and reduced clinician wait times.

Coordination Between Tier 1 and Tier 2

The two caching tiers work in close coordination to maximize performance across different types of requests. When the frontend requests standard FHIR resources such as a patient list or individual patient demographic data, Tier 1 cache is checked first, providing rapid responses for frequently accessed basic information. When the frontend requests the complex Patient History Graph visualization, Tier 2 cache is consulted, serving the precomputed graph structure with all relationships and visual attributes already prepared. Invalidation operations propagate across both tiers simultaneously. For example, recording a new prescription invalidates both the Tier 1 cache entry for `/api/prescriptions` (which would now be stale relative to the 24-hour TTL) and the Tier 2 cache for that patient's history graph (which must be reconstructed to include the new node and relationships). This coordinated invalidation ensures that regardless of which API endpoint a clinician accesses, the data reflects the most recent state of the patient's record.

Memory Management and Cache Eviction

Redis is configured with a maximum memory limit to prevent unbounded growth and to integrate into production server resource constraints. To manage memory efficiently, the CFI-Care backend employs an LRU (Least Recently Used) eviction policy. When Redis approaches its configured maximum memory capacity, the system automatically evicts the least recently accessed cache entries to make space for new data. This dynamic approach to cache management creates a natural working set where the cache automatically retains entries for patients with active clinical workflows (frequently accessed by multiple clinicians) while entries for inactive patients are evicted and subsequently reconstructed on-demand if and when those patients are accessed again. This ensures that memory usage remains bounded and predictable while simultaneously maximizing cache hit rates for the active subset of patients. In practice, this means that high-volume clinical workflows benefit from maximum cache coverage, while less frequently accessed patients gracefully degrade to on-demand reconstruction without requiring administrator intervention or manual cache management.

3.5 Frontend

3.5.1 Overview and Design Objectives

The frontend of *CFI-Care* was designed as an interactive medical information system aimed at enabling healthcare professionals to efficiently explore, manage, and reason about patient data. The primary objective was to transform fragmented medical records into a coherent, visual, and navigable representation of a patient’s medical journey, while maintaining clinical clarity, responsiveness, and usability.

The frontend follows a component-based architecture implemented using the Angular framework. Advanced data visualization is achieved through the integration of D3.js and Treviz, while Bootstrap and Bootstrap Icons are used to ensure responsive layout, visual consistency, and accessibility across devices.

The main design goals of the frontend include:

- Clear separation of concerns between navigation, visualization, and data manipulation.
- Visual prioritization of clinically critical events.
- Support for both categorical and temporal reasoning over patient medical data.
- Extensibility to support future backend integration and advanced analytics.

Component-based frontend architectures have been shown to improve scalability, maintainability, and development efficiency in large-scale systems [?, ?].

3.5.2 Technology Stack

Table 3.2 summarizes the main technologies used in the frontend implementation.

Table 3.2: Frontend Technology Stack

Technology	Purpose
Angular	Core frontend framework and state management
D3.js	Data-driven visualization and interaction logic
Treviz	Hierarchical graph layout abstraction
Bootstrap	Responsive layout and UI consistency
Bootstrap Icons	Visual indicators and interaction affordances

Angular’s declarative templates and reactive change detection model make it suitable for highly interactive, state-driven medical interfaces [?].

3.5.3 Authentication Suite

Sign In Interface

The Sign In page serves as the primary entry point to the system and was designed to establish trust and professionalism, which are critical factors in healthcare software adoption.

The interface follows a split-view layout, as shown in Figure ??:

- **Left Pane:** Reinforces the system’s value proposition through concise messaging emphasizing security, collaboration, and patient-centered care.
- **Right Pane:** Contains a modern authentication card inspired by glassmorphism design principles.

Supported features include standard credential authentication. Research indicates that early user impressions significantly influence perceived reliability in clinical systems [?].

Create Account Interface

The Create Account page maintains visual consistency with the Sign In interface to reduce cognitive load and ensure continuity. The registration form collects the user’s full name, email address, and password confirmation, enabling a low-friction onboarding process. Minimizing onboarding complexity has been shown to improve professional software adoption [?].

3.5.4 Patients Dashboard

Overview

The Patients Dashboard functions as the primary data-management hub of the system. It enables clinicians to search, select, and review patient profiles efficiently.

Master–Detail Layout

The dashboard follows a master–detail layout, a design pattern widely adopted in medical information systems [?]. The layout consists of:

- **Patient Navigator (Left Sidebar):** Includes a search bar and a list of patient cards displaying key metadata such as age and last update timestamp.
- **Clinical Summary View (Main Panel):** Displays structured patient information using a card-based layout.

3.5.5 Clinical Summary View

The clinical summary view organizes patient data into clearly defined sections:

- Demographics: name, age, gender, and patient identifier.
- Clinical data: primary diagnosis, active conditions, and current medications.
- Expandable sections for recent laboratory results and procedures.

Card-based layouts improve information scanability and retrieval in dense clinical interfaces [?].

3.5.6 Interactive Header

A global action header provides filtering capabilities and a prominent control for opening the MedGraph, transitioning the user from record-based inspection to journey-based visualization.

3.5.7 Patient Journey Dashboard

While traditional medical dashboards present patient data as isolated records, clinical decision-making often requires understanding how events evolve, relate, and unfold over time. To address this limitation, CFI-Care introduces the *Patient Journey Dashboard*, a dedicated interactive environment that provides a holistic view of a patient’s medical history.

The Patient Journey Dashboard enables clinicians to:

- Explore relationships between medical events.
- Understand disease progression from initial presentation to treatment.
- Analyze alternative diagnostic or treatment paths.
- Identify clinically critical events without losing contextual awareness.

Rather than enforcing a single representation, the dashboard provides two complementary visualization modes: *Categorical* and *Chronological*. Each mode offers a distinct analytical perspective over the same underlying patient data, allowing clinicians to switch between structural and temporal reasoning as needed.

This multi-perspective approach aligns with established visualization principles that emphasize coordinated views to reduce cognitive load and improve analytical accuracy [?, ?].

3.5.8 Patient Journey Dashboard – Categorical View

Purpose and Conceptual Model

The categorical view presents the patient journey as a hierarchical, relationship-oriented structure similar to a family tree. Its primary purpose is to visualize **clinical relationships, causality, and dependency** between medical events.

In this mode, clinicians can clearly observe:

- How diagnostic steps lead to subsequent decisions.
- Which medical events are logically connected.
- Complete clinical paths from disease onset to treatment.

This representation is particularly effective for understanding the structure of a case, rather than its temporal sequence.

Hierarchical Graph Representation

Medical events are represented as nodes within a node-link hierarchical graph. A single root node represents the patient case, from which first-level categories branch out. These categories group related clinical events such as consultations, laboratory investigations, imaging studies, or AI-generated recommendations.

Graph-based representations have been shown to support reasoning over complex medical workflows and dependencies more effectively than linear lists [?].

Expand and Collapse Semantics

Only first-level nodes directly connected to the root support expand and collapse interactions. This constraint limits visual complexity while preserving a stable mental model for the user. Deeper levels remain structurally intact but are revealed only when their parent category is expanded.

High-Priority Propagation Mechanism

Clinically critical events are visually marked using a red circular border. When a high-priority node exists within a collapsed branch, the priority indicator propagates upward to the corresponding first-level parent node. This ensures that urgent information is never visually hidden.

Upon expansion of the branch, the priority indicator is removed from the parent and restored to the exact node where the priority originates. This mechanism preserves both visibility and accuracy of clinical alerts, supporting patient safety and rapid risk identification [?].

Node Relationship Indicators

Each node explicitly indicates whether it represents a single-child event or a sibling event within a group. This is conveyed through a labeled rectangular visual marker with distinct colors and text. These indicators allow clinicians to quickly infer structural relationships without expanding the entire hierarchy.

Filtering and Actions

The categorical view supports filtering by event category, normality, priority level, and date range. Clinicians can add, edit, or delete nodes using structured modal dialogs. Destructive actions such as deletion require explicit confirmation to prevent accidental data loss, following safety-oriented interface guidelines [?].

3.5.9 Patient Journey Dashboard – Chronological View

Purpose and Conceptual Model

The chronological view reorganizes the same patient data into a time-oriented representation. Its purpose is to support **temporal reasoning** by allowing clinicians to read the patient journey as a sequential narrative.

Unlike the categorical view, which emphasizes relationships, the chronological view emphasizes:

- The order of events.
- Time intervals between clinical decisions.
- The progression of care across time.

This mode is particularly useful for auditing cases, reviewing treatment timelines, and understanding how a patient’s condition evolved over time [?].

Temporal Layout and Event Stacking

Events are displayed along a horizontal timeline. When multiple events occur on the same date, they are stacked vertically above one another to preserve temporal accuracy while avoiding overlap. This design allows dense clinical activity to be represented without sacrificing readability.

Branching Mechanism for Clinical Reasoning

A key feature of the chronological view is its branching mechanism. By default, the timeline contains a primary branch representing the main clinical pathway followed during patient care.

When uncertainty arises, such as alternative diagnostic hypotheses or treatment strategies, clinicians can create separate branches. These branches represent exploratory or tentative paths that may later be completed or rejected based on clinical validation.

Branches are rendered using smooth curved linkage lines and maintain a constant vertical spacing to avoid visual overcrowding. This design enables parallel reasoning while preserving clarity and navigational stability. Branching supports clinical decision exploration and aligns with established models of hypothesis-driven medical reasoning [?].

High-Priority Visualization

High-priority events are highlighted using prominent red labels positioned beneath nodes. This visual hierarchy ensures that urgent clinical issues remain immediately noticeable within the temporal flow.

Stateful Mode Switching

A toggle control allows instant switching between categorical and chronological views. This interaction is fully stateful and does not require page reloads, enabling clinicians to seamlessly transition between structural and temporal perspectives during analysis.

3.5.10 Complementary Roles of Categorical and Chronological Views

The categorical and chronological views address fundamentally different cognitive tasks. The categorical view focuses on **structural understanding**, enabling clinicians to reason about relationships, dependencies, and complete clinical paths. In contrast, the chronological view focuses on **temporal understanding**, enabling clinicians to interpret the sequence and timing of events.

Providing both views allows clinicians to:

- Understand how events are connected (categorical).
- Understand when events occurred (chronological).
- Reduce cognitive load by selecting the most appropriate representation for the task at hand.

This dual-view approach follows established guidelines for multiple coordinated visualizations, which have been shown to improve usability and analytical effectiveness in complex systems [?].

3.5.11 Summary

The CFI-Care frontend successfully transforms complex medical data into an interactive and extensible visualization system. By combining structured dashboards with intelligent graph-based representations, the frontend supports both high-level clinical overview and detailed event analysis. The design and architecture established in this phase provide a strong foundation for the backend integration and advanced decision-support features.

3.6 Mobile

3.6.1 Problem Statement

The digital transformation of healthcare in Egypt faces significant structural challenges that directly impact patient care and safety. Despite national initiatives for modernization, the current healthcare ecosystem remains characterized by fragmentation, reliance on analog documentation, and a lack of standardized data governance. This thesis addresses these critical gaps by proposing a patient-centric mobile application designed to bridge the current digital fragmentation.

3.6.2 Data Fragmentation and the “Silo” Effect

A primary challenge facing Egyptian patients is the lack of interoperability between healthcare providers. Research indicates that Egyptian health entities operate in “silos,” utilizing discrete data collection systems that do not integrate or complement one another [?]. Consequently, patient data is scattered across various hospitals, private clinics, and diagnostic laboratories. In the absence of a unified national medical record, the patient is forced to assume the role of the sole custodian of their medical history. This places an undue burden on patients—particularly those with chronic conditions—to physically transport scattered paper reports and diagnostic films between providers, increasing the risk of information loss and discontinuity of care.

3.6.3 Reliance on Analog Systems and Data Quality

The persistence of paper-based (analog) data collection mechanisms significantly undermines data quality and accessibility. Current policy assessments reveal a fundamental lack of proper health-data collection mechanisms within the sector [?].

Collected low-quality data are characterized by incomplete fields, data entry errors, and reliance on manual updates. [?].

When transitioning between doctors, patients must rely on their memory to verbally relay complex medical histories. This often results in “information asymmetry,” where crucial clinical details—such as drug allergies or previous surgical interventions—are omitted, leading to potential misdiagnoses or redundant diagnostic testing.

3.6.4 Absence of Standardized Consent and Data Sovereignty

Furthermore, the current landscape lacks a robust framework for patient data rights and privacy. There is a notable absence of standardized consent practices; written consent for data usage is rarely obtained, and patients often lack awareness regarding how their health data is utilized or stored [?]. Patients currently possess no granular control over who accesses their records once they are handed over to a facility. This lack of transparency and control fosters a reluctance among patients to share sensitive health information, further hindering the effectiveness of clinical consultations.

3.6.5 The Need for Continuous Monitoring

Finally, traditional healthcare models in Egypt often fail to capture the patient's daily health status. Current protocols rely on sporadic clinical visits, missing the continuous physiological data that modern wearable technology can provide. By failing to integrate real-time vitals into the formal medical record, the system misses critical opportunities for preventative monitoring and early intervention.

3.7 Mobile Application Goal and Methods

The primary objective of developing the proposed mobile application is to provide a secure, efficient, and patient-centered platform for managing personal health information within the digital medical ecosystem integrated with a FHIR-compliant backend.

3.7.1 Digital Document Management

The application enables patients to digitally capture, upload, and store medical reports, diagnostic scans, and other relevant health documents using their mobile devices. These documents are maintained within the application's local storage and synchronized with the backend system when required, thereby reducing reliance on physical medical records.

3.7.2 Doctor-Patient Data Sharing

A core objective of the system is to support controlled and consent-based data sharing. Doctors may submit requests to access a patient's medical data, which the patient can explicitly approve or reject. Upon approval, patients are able to define granular access permissions, such as read-only or read-write access, as well as specify a time-bound duration for which the access remains valid. This approach ensures patient data privacy while enabling physicians to effectively review and update medical records when authorized.

3.7.3 Elimination of Physical Records

By digitizing medical documentation and access workflows, the system aims to eliminate common issues associated with traditional paper-based records, including loss, damage, and the burden of carrying extensive physical reports during medical visits.

3.7.4 Caregiver and Family Involvement

In addition to doctor access, the application supports caregiver and family member involvement. Patients may grant designated caregivers permission to monitor their health status, subject to explicit consent. Similar to doctor access, patients can define the level of access (read-only or read-write) and set temporal constraints for each caregiver, ensuring full control over shared medical information.

3.7.5 Appointment Management

The application further facilitates appointment management by allowing patients to schedule medical appointments directly through the mobile interface. During the booking process, patients may optionally attach relevant medical documents to provide physicians with preliminary information prior to consultation.

3.7.6 Wearable Device Integration

Finally, the system is designed to support integration with wearable and smart health devices, such as smartwatches, to collect physiological data including heart rate and other vital signs. This data can be incorporated into the patient's health profile to support continuous monitoring and more informed clinical decision-making.

3.8 Related Work

This section provides an overview of a selection of mobile applications comparable to the one in this work.

3.8.1 Apple Health

The closest existing commercial application to our proposed *AI-Powered Collaborative Patient-Centric Health Record Platform* is **Apple Health**. It serves as the global standard for patient-centric data aggregation. Below is an analysis of its core features which serve as a baseline for our project:

- **Centralized Health Hub:** It acts as a single repository for mobility data, sleep history, and vital signs collected from wearable devices. It also allows users to personalize their experience by storing demographics and basic health details [?].

- **Record Management:** Users can manually input data or download health records directly from supported healthcare institutions. Key features include searching for specific clinical categories (like allergies or vitals) and pinning important lab results for quick access [?].
- **Data Sharing & Privacy:**
 - *Provider Integration:* Users can share specific data points (e.g., heart rate trends) with doctors who view it on their own dashboards [?].
 - *Family Access:* The system allows for data sharing with trusted contacts (e.g., caregivers or family members) for monitoring, with granular control over what is shared [?].
- **Medication & Cycle Tracking:** Built-in modules allow for medication adherence logging and reproductive health tracking to predict fertile windows and track symptoms [?].

System Differentiation: The "Full Integrated Ecosystem"

While Apple Health excels as a *Patient-Side Aggregator*, our proposed system is fundamentally different because it is a **bidirectional, fully integrated ecosystem**.

The Missing Link: Doctor Web Interface

Apple Health relies on third-party integration; it does not provide the medical tools for the doctor itself. In contrast, our system includes a dedicated **Web Interface for Doctors**, creating a closed-loop environment:

- **Active Collaboration:** Unlike Apple Health, where data is passively "shared," our system allows doctors to actively write to the patient's record, with the patient consent, and update treatment plans.
- **Data shared with Doctor:** Our AI component does not just categorize data; it assists the doctor by analyzing the patient's inputs, to help the doctor in diagnosing the disease, a feature absent in standard health aggregators.

3.9 Market Analysis: The Egyptian Landscape

In the context of Egypt, our system addresses a significant gap. While there are successful health-tech players, none offer the complete *Full Integrated Ecosystem* we are proposing.

3.9.1 Vezeeta

- Vezeeta currently has around 1 million users. The application can be downloaded for free in the Google Play-Store and the Apple Store.
- *Focus*: Primary focus is on **booking and telemedicine**.
- *Limitation*: These platforms function primarily as marketplaces. They do not typically offer a persistent, longitudinal health record that stays with the patient across different providers, nor do they utilize advanced AI, used by doctors, for clinical decision support during the collaboration.

3.9.2 Lumi by Nextcare:

- *Market Reach*: A widely used application in the region with over 1 million downloads [?].
- *Focus*: Specialized primarily in insurance management, approvals, and pharmacy benefits, with some telehealth features.
- *Limitation*: It lacks a "full closed system" for clinical management. Crucially, it does not structure medical history as a connected longitudinal record. Documents and visits are often treated as isolated transactional events (e.g., a claim or a prescription) rather than a continuous medical narrative.

3.9.3 Our Competitive Advantage: The "Medical History Tree"

The most distinct differentiator of our system is the data architecture, designed to solve the fragmentation found in apps like Lumi:

- **Graph Visualization (Doctor's View)**: Unlike existing solutions that show simple lists, our Web Interface presents the patient's history as a **Graph/Tree Structure**. Doctors can traverse this graph where each "node" represents a specific medical event (visit, procedure, or test) containing all attached documents and AI summaries. This allows for rapid correlation between past and present conditions.
- **Major Events Timeline (Patient's View)**: On the mobile application, the patient sees a simplified, chronological view of "Major Events." Each event expands into a detailed node containing the specific visit info and documents, ensuring they own a complete, navigable copy of their medical history, rather than just a list of insurance claims.

3.10 Flutter and Dart

3.10.1 Clean Architecture in the Mobile Application

To ensure a scalable, maintainable, and testable codebase for the patient mobile application, this project adopts principles of Clean Architecture.

Clean Architecture is a layered software design paradigm that promotes clear separation of concerns, dependency management, and modularization of application logic. The fundamental goal of this approach is to isolate core business rules from implementation details and platform-specific frameworks, thereby improving long-term maintainability and facilitating unit testing [42].

According to the Flutter documentation on application architecture, well-structured applications organize code into logical layers that separate the user interface, application logic, and data handling. The documentation emphasizes the importance of isolating state management, dependency injection, and data access concerns to support growth and complexity in larger applications [41].

As illustrated in Figure 3.8, the application is structured into three principal layers: the presentation layer, the domain layer, and the data layer. Each layer has a distinct responsibility and communicates with adjacent layers through abstract interfaces, ensuring that dependencies always point inward toward business logic rather than outward toward infrastructure or frameworks [42].

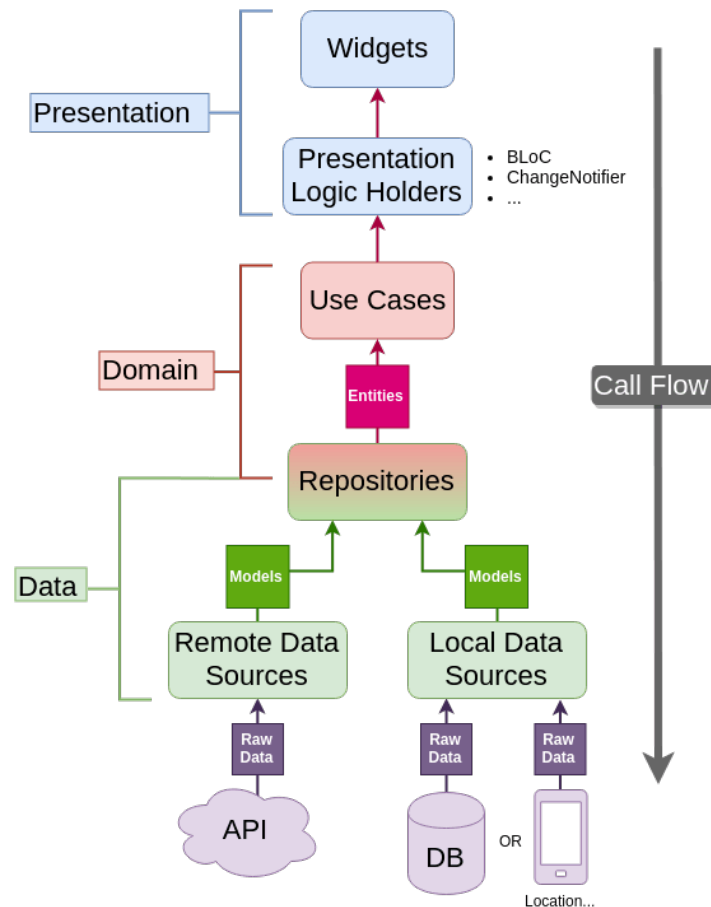


Figure 3.8: Layered Clean Architecture adopted in the mobile application

3.10.2 Layered Structure

Presentation Layer This outermost layer contains code that directly interacts with the user interface. In the context of this Flutter application, it includes widgets, screens, routing logic, and Riverpod providers to manage application state when implemented. The presentation layer orchestrates the flow of data from use cases in the domain layer to the UI and captures user interactions for processing. Presentation logic is kept distinct from business rules and data access to avoid tightly coupling UI changes with core system logic [42].

Domain Layer The domain layer encapsulates the core business logic and entities of the system. It is independent of Flutter or any external dependencies. This layer defines use cases that represent application-specific operations, such as requesting document access or scheduling appointments, and serves as the central coordinator of business rules. The domain layer's independence from external libraries and frameworks enhances testability and ensures that business logic can be validated in isolation [42].

Data Layer The data layer is responsible for integrating with external systems, including APIs, local storage, and the backend FHIR server. It provides implementations of repository interfaces defined in the domain layer and manages data transformation between network responses, local models, and domain entities. The layered separation ensures that external dependencies do not leak into the domain or presentation layers [42].

3.10.3 Centralized Runtime Permission Handling

To ensure a secure and seamless interaction with device hardware, the application implements a centralized asynchronous mechanism for managing runtime permissions. This approach abstracts the complexity of the `permission_handler` library and follows established patterns for robust permission management [44]. The function `handlePermission` provides a unified interface for requesting access to sensitive resources such as the camera, storage, or microphone.

The function operates as a `Future<bool>`, returning a boolean value to indicate the success or failure of the authorization process. Upon invocation, the function executes the following logic flow:

1. **Asynchronous Request:** It initiates a request to the underlying operating system using `permission.request()`. The execution yields until the user interacts with the system dialog or the operating system returns the current status.
2. **Status Evaluation:** The returned `PermissionStatus` is evaluated against standard authorization states:
 - **Granted:** If the user approves the request (`isGranted`), the function immediately returns `true`, allowing the calling process to proceed.

- **Permanently Denied:** If the permission is flagged as `isPermanentlyDenied` (a state where the operating system suppresses further prompts due to repeated denials), the system intervenes to prevent a silent failure. It displays a toast notification instructing the user to enable the permission manually and invokes `openAppSettings()` to redirect the user to the device's settings menu.
- **Denied:** In cases of a standard denial, a feedback message is displayed via `Fluttertoast` to inform the user of the restriction, and the function returns `false`.

By encapsulating this logic, the system ensures that permission failures are handled gracefully, guiding users through recovery steps when necessary rather than causing application crashes or unresponsive features. The implementation of this logic is demonstrated in Listing 3.1.

Listing 3.1: Asynchronous Permission Handling Function

```

import 'package:permission_handler/permission_handler.dart';
import 'package:fluttertoast/fluttertoast.dart';

Future<bool> handlePermission(
  Permission permission,
  String name,
) async {
  final status = await permission.request();

  // Case 1: Permission Granted
  if (status.isGranted) {
    return true;
  }

  // Case 2: Permanently Denied (Requires Settings)
  if (status.isPermanentlyDenied) {
    Fluttertoast.showToast(
      msg: '$name␣permission␣permanently␣denied.␣Enable␣it␣in␣settings
        .',
    );
    openAppSettings();
    return false;
  }

  // Case 3: Standard Denial
  Fluttertoast.showToast(msg: '$name␣permission␣denied');
  return false;
}

```



Figure 3.9: using handlePermission For Camera Access In code

Best Practices for handling Permissions in Flutter

- Contextual Permission Requests:** To avoid overwhelming the user and to establish context, the application rejects the traditional “up-front” permission model (where all permissions are requested at launch). Instead, a *Contextual Request* pattern is employed. Permissions are only requested at the specific moment a feature is invoked. For example, access to the **Camera** is requested solely when the user attempts to scan a medical report.
- Transparent Rationale and Trust Building:** In compliance with privacy best practices, the application explains the “Why” before the “How.” Prior to triggering the system permission dialog, the application presents a custom UI

explanation detailing exactly why a specific permission is needed and how it benefits the user. This transparency is critical in a healthcare context, increasing the likelihood of approval and reinforcing the patient’s understanding that their data is being used strictly for medical management.[?]

- **User Agency and Graceful Degradation:** The system is designed to respect user choices without compromising the core functionality of the application. If a user denies a non-critical permission, the app enters a state of *Graceful Degradation*.

The application avoids repetitive prompting (“nagging”), ensuring a respectful user experience. [?]

- **Comprehensive State Handling:** The application logic accounts for the full lifecycle of permission states, ensuring stability across different scenarios[?][?]:
 - **Granted:** The feature proceeds immediately.
 - **Denied:** The feature is disabled, and the user is informed of the limitation.
 - **Permanently Denied:** In cases where the user has selected “Don’t ask again,” the application detects this state and provides a subtle option to guide the user to the system **App Settings** menu for manual enablement, should they choose to do so later.

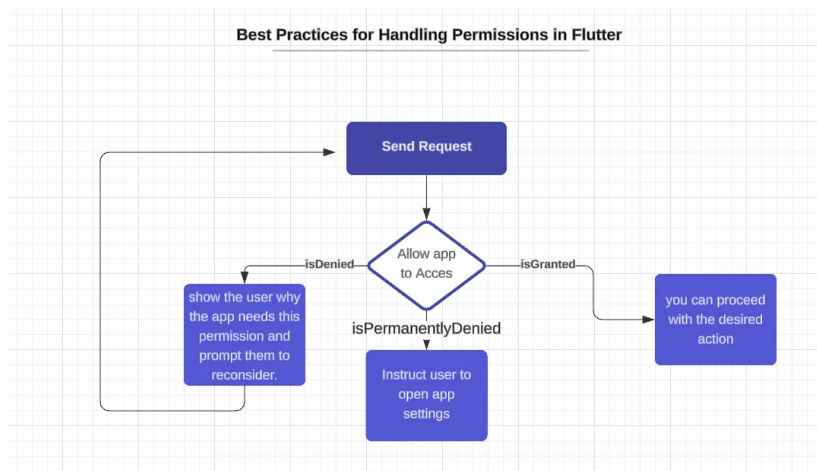


Figure 3.10: Best Practices for Handling Permissions in Flutter

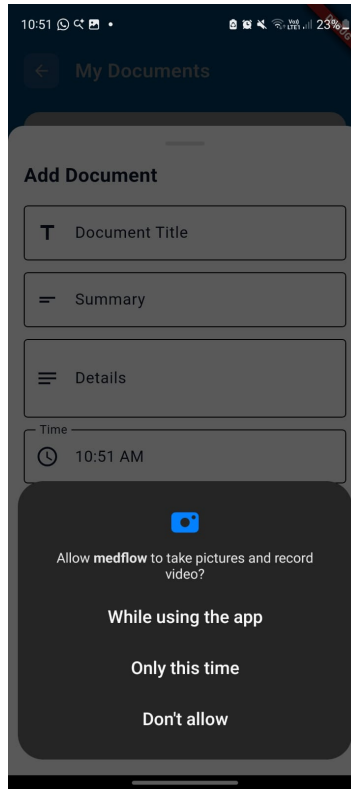


Figure 3.11: Dialog to allow the app to access the camera

3.11 Requirements Engineering

To ensure the delivery of a viable and effective application, the development lifecycle begins with a stakeholder analysis to establish the system context. This is followed by a comprehensive definition of the functional, non-functional, and optional requirements. Synthesizing this information facilitates the creation of a domain model, which acts as the foundational blueprint for the subsequent database design.

3.11.1 Target Group and User Group

The mobile application is designed for a broad demographic, targeting two key user segments:

- **Primary Users (Patients):** Individuals seeking a digital solution to store and organize their medical history, accessible via any standard smartphone.
- **Secondary Users (Caregivers/Family):** Family members or guardians who require shared access to monitor the patient's health status and assist in managing their care plan.

By digitizing medical records, the application serves anyone looking to transition from fragmented paper records to a structured, accessible mobile archive.

3.11.2 Stakeholder

Stakeholders are categorized into Internal Stakeholders, who are directly involved in the development and operation of the system, and External Stakeholders, who utilize the system's end products.

External Stakeholders

External stakeholders are the primary users of the system. Their interaction drives the application's core functionality.

1. Patients (Primary Users) Interaction:

- **Data Management:** Patients interact with the mobile interface to upload medical documents (lab results, scans) and view their historical data presented in a structured "Major Events" timeline.
- **Access Control:** They possess full authority over their data privacy. Patients receive requests from doctors for data access and can grant permissions (Read-Only or Read-Write) for a specific duration. Crucially, they retain the ability to revoke this access at any time.
- **Family Management:** Patients can authorize family members to view their health records for monitoring purposes.

Benefits:

- **Centralized History:** Eliminates the need for physical paperwork by consolidating all medical history into a single, organized mobile repository.
- **Data Ownership:** Empowers patients with absolute control over who views their medical information and for how long.
- **Continuity of Care:** Ensures that any new doctor can immediately access a complete medical background, reducing diagnostic errors.

2. Family Members (Secondary Users) Interaction:

- **Monitoring:** Through shared access granted by the patient, family members can view health trends and documents to assist in care.
- **Administrative Support:** Unlike doctors, family members have the permission to book appointments on behalf of the patient, facilitating care for elderly or incapacitated users.

Benefits:

- **Remote Assurance:** Provides peace of mind by allowing real-time monitoring of a loved one's health status.
- **Care Coordination:** Simplifies the logistical burden of managing appointments and records for dependents.

3. Doctors (Service Providers) Interaction:

- **Session Initiation:** While doctors primarily use the Web Interface, their actions directly trigger updates on the mobile app. A doctor initiates a "New Encounter Node" in the patient's history tree during a visit.
- **Access Requests:** Doctors request permission to view a patient's historical records. If granted "Write" access, they can add new diagnoses and prescriptions to the encounter node.
- **Limitation:** Doctors strictly cannot book appointments; this function is reserved for patients and their families to prevent conflict of interest or scheduling errors.

Benefits:

- **Informed Decision Making:** Instant access to a verified, comprehensive medical history allows for more accurate diagnoses.
- **Efficiency:** Reduces time spent interviewing patients for past medical details, allowing more focus on current treatment.

Internal Stakeholders

Internal stakeholders are responsible for the technical construction, maintenance, and security of the platform.

1. Mobile Application Developers (Flutter Team) Interaction:

- **Frontend Implementation:** Responsible for building the cross-platform mobile interface using the Flutter framework.
- **API Integration:** They implement the communication layer that sends authentication requests and data queries to the backend.
- **UX/UI Design:** They translate the complex "Medical History Tree" concept into a user-friendly mobile timeline.

2. Backend & System Architects Interaction:

- **Authentication Flow:** They manage the identity management integration. The Flutter app sends credentials to the Node.js backend, which acts as an intermediary to communicate with **Keycloak** for secure Single Sign-On (SSO) and token validation.
- **Data Orchestration:** They maintain the Node.js middleware that fetches data from the **FHIR Server** and formats it for the mobile client.
- **Standardization:** They ensure that all medical data stored and retrieved adheres to HL7 FHIR standards for interoperability.

3.12 System Sequence Diagram

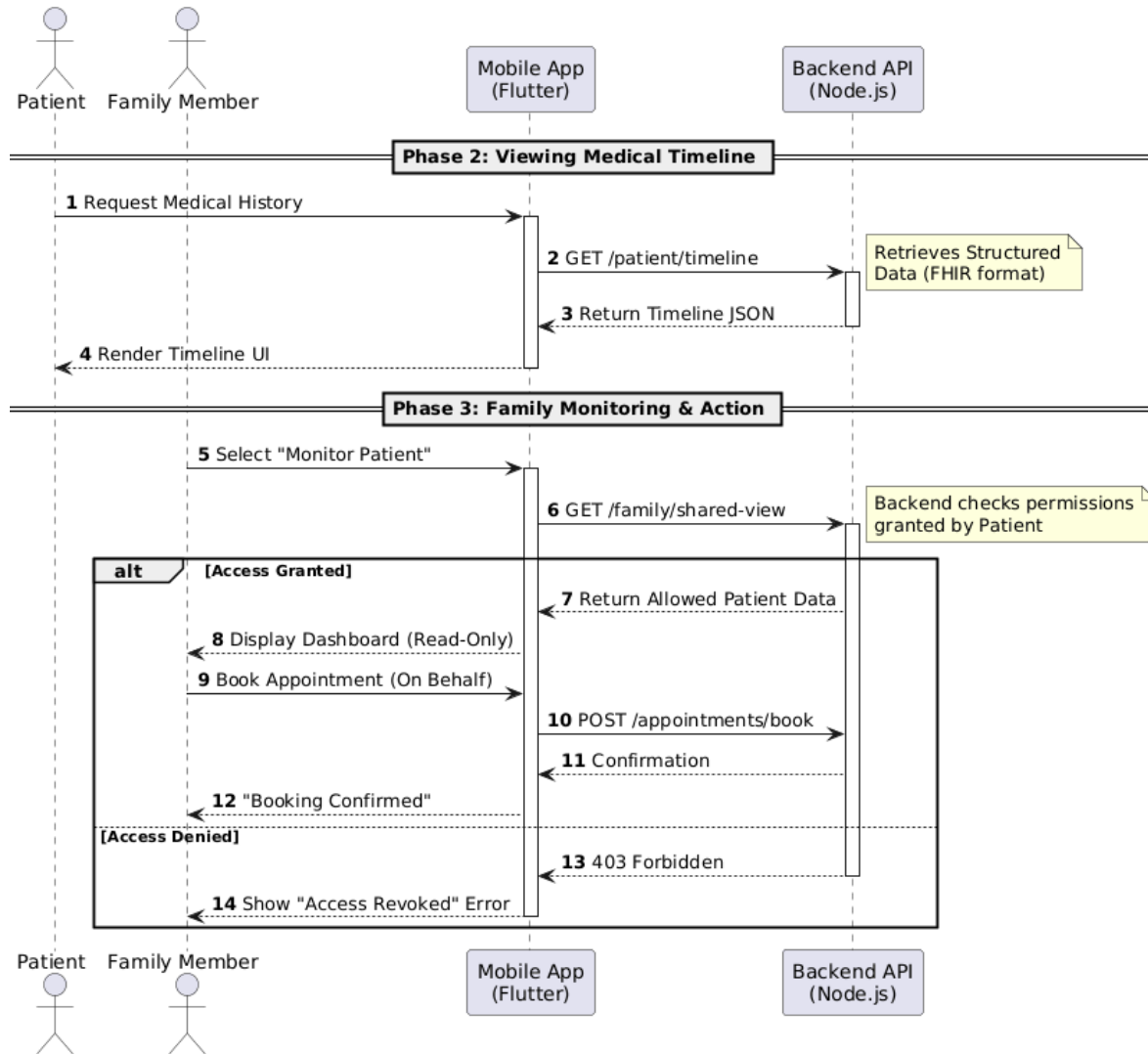


Figure 3.12: Sequence Diagram for Mobile Application

3.13 System Requirements Specification

The requirements for an application can be divided into three categories: functional requirements, non-functional requirements, and optional requirements. In this section all 3 requirements will be discussed.

3.13.1 Functional Requirements

The functional requirements define the specific behaviors and functions of the mobile application.

Patient Capabilities

- **FR-01 Document Management:** The system shall allow patients to upload, categorize, and tag medical documents (e.g., Lab Results, Radiography) into their personal repository.
- **FR-02 History Visualization:** The application shall present medical history as a "Major Events" timeline. Each event must be expandable to reveal detailed encounter notes and attached files.
- **FR-03 Access Control Management:**
 - The system shall notify patients of incoming access requests from doctors.
 - Patients shall be able to grant *Read-Only* or *Read-Write* permissions.
 - Patients shall be able to define the duration of access and revoke permissions immediately at any time.

Family & Caregiver Capabilities

- **FR-04 Monitoring Dashboard:** Authorized family members shall have a read-only view of the patient's medical timeline to monitor health trends.
- **FR-05 Proxy Booking:** Unlike doctors, family members shall have the authority to search for providers and schedule appointments on behalf of the patient.

3.13.2 Non-Functional Requirements

- **NFR-01 Interoperability:** The application must parse and render data compliant with HL7 FHIR standards to ensure seamless integration with the Node.js backend.
- **NFR-02 Localization:** To serve the local demographic, the interface must fully support Arabic (RTL) and English (LTR) languages.
- **NFR-03 Performance:** The medical history timeline uses "Lazy Loading" to ensure the application remains responsive even for patients with extensive medical records.

3.13.3 Optional Requirements (Future Scope)

- **OR-01 Medication Adherence System:** Automated push notifications to remind patients of medication schedules derived from their prescriptions.
- **OR-02 Wearable Device Sync:** Integration with native health APIs (Google Fit / Apple Health) to import real-time vitals like heart rate and step count.

3.14 Use Cases

This section describes the primary interactions between the users (Actors) and the mobile application system.

3.14.1 SignIn and SignUp Pages

Actors: Patient, Family Member

Description: The entry point for identifying users and securing the session. Given the sensitive nature of medical data, this process integrates with Keycloak for secure identity management.

- **Sign Up:** New users register by providing personal details (Name, National ID, Email) and creating a secure password. The system creates a new FHIR Patient resource on the backend upon successful registration.
- **Sign In:** Registered users authenticate using their credentials. Upon success, the app retrieves a secure access token to authorize subsequent API requests.

3.14.2 Document Management

Figure 3.13 illustrates the patient's interactions with their personal medical history data.

1. **View Document List:** The user requests to see their existing medical files. This action requires the system to query the database using the user's secure authentication token.
2. **Upload Document:** The user adds new records to their profile. This involves selecting a file and assigning title.
3. **Scan Document:** The user adds scans new records to their profile. This involves giving camera permission and scan the file and assigning title. Scanned Documents can be accessed through file manager in the phone.
4. **Refresh List:** Upon a successful upload, the system automatically triggers a refresh of the document view to reflect the new entry immediately.

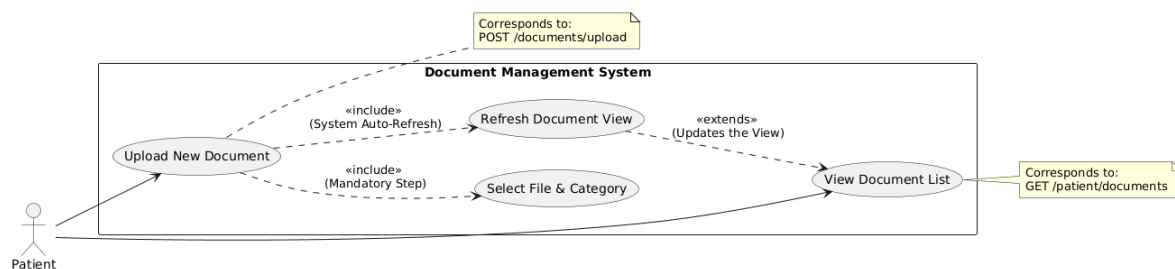


Figure 3.13: Documents Management Use Case

3.14.3 Medical History Navigation

Figure 3.17 illustrates how a patient can navigation to explore a their medical history.

1. **View Major Events (Dashboard):** The entry point where the patient views high-level summaries of their active medical contexts (e.g., Cardiac Workup).

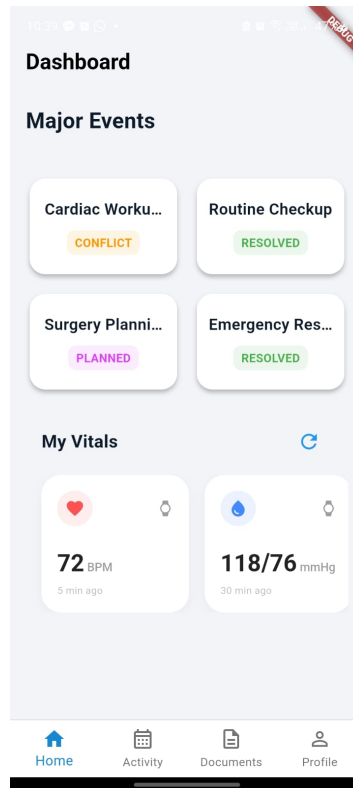


Figure 3.14: Major Events

2. **View Event Nodes:** By selecting a specific major event, the user extends their interaction to view a chronological list of related encounters (the "Nodes").

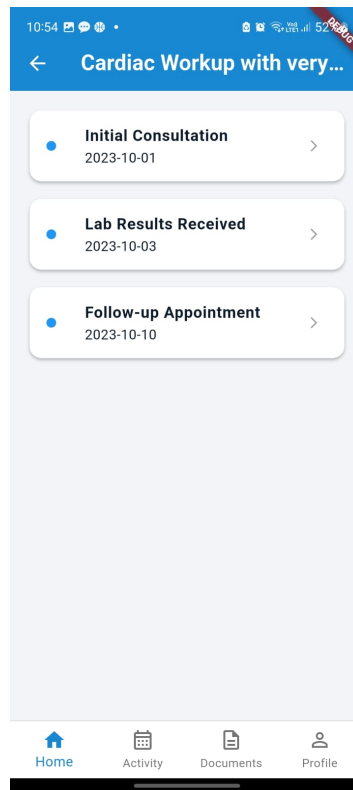


Figure 3.15: List of Nodes

3. **View Encounter Details:** Selecting a specific node allows the user to inspect the full clinical details of that visit.
4. **View Attached Documents:** Within the details view, the user can optionally retrieve and view specific medical files (PDFs/Images) associated with that encounter.

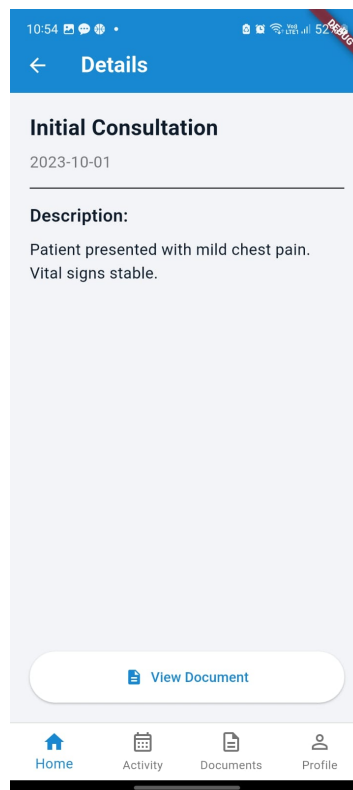


Figure 3.16: Node Details

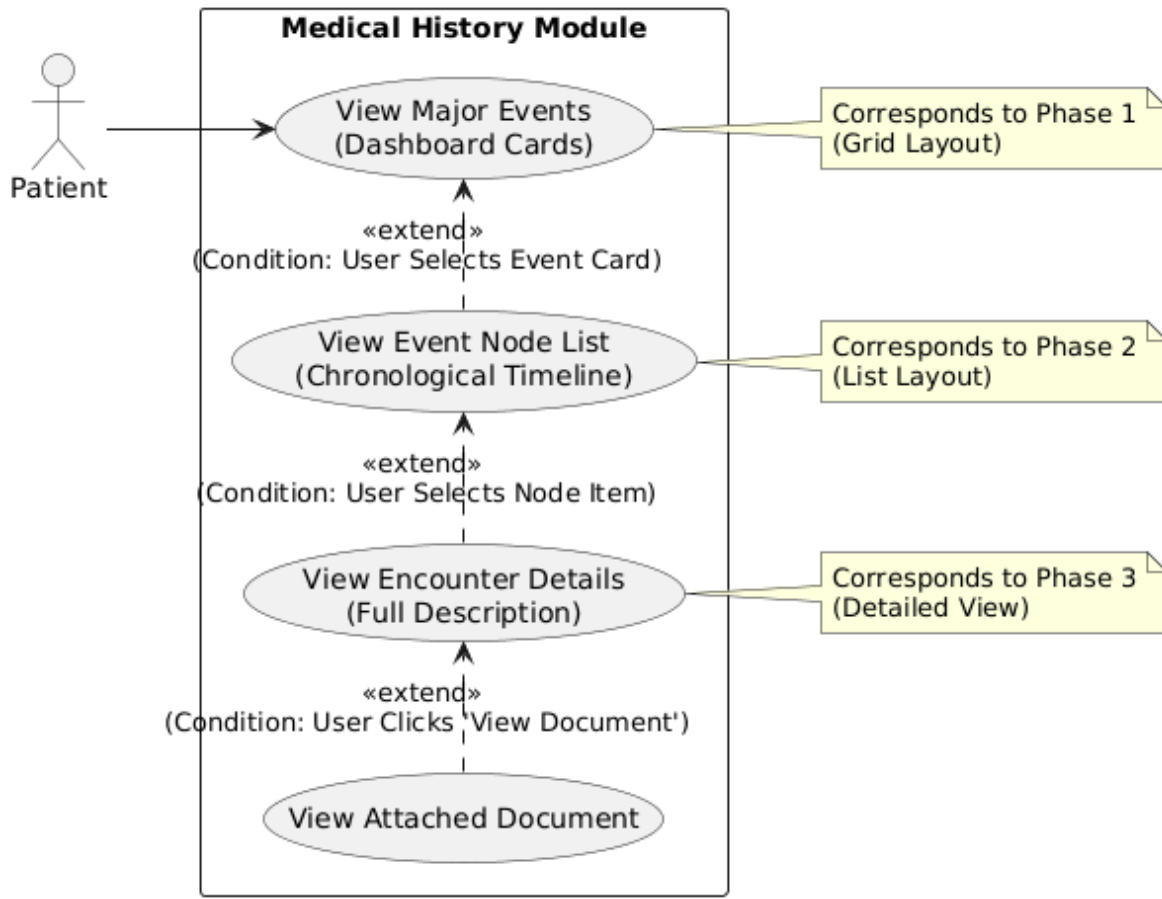


Figure 3.17: History Navigation Use Case

3.14.4 Appointment Booking

Figure 3.18 depicts the functional capabilities available to the Patient during the scheduling process.

1. **Core Functionality:** The primary goal is the *Book Appointment* use case. To complete this, the system mandates several included steps: searching for a specialist, selecting a valid time slot, and confirming the details.
2. **Optional Extension:** The *Attach Documents* use case is modeled as an extension. It is not required to complete a booking but provides optional value (sending scans/PDFs) upon successful completion.
3. **Actors:** The *Patient* is the primary initiator. The *Family Member* also inherits these capabilities, allowing them to perform the same actions on behalf of the patient.

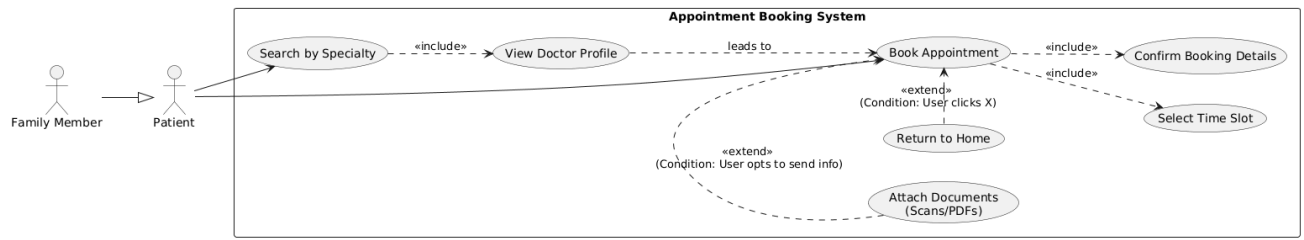


Figure 3.18: Booking Appointments Usecase

3.15 My Profile Update

Figure 3.19 details the data consistency mechanism.

1. **Local Commit:** When the user saves changes, the application first updates the local SQLite database. This ensures the user interface is responsive and works even with poor internet connectivity.
2. **Remote Synchronization:** Immediately following the local commit, the application initiates an asynchronous API call to update the backend server.
3. **Consistency Check:** Upon a successful server response, the application confirms the synchronization status, ensuring the patient's data is consistent across all platforms.

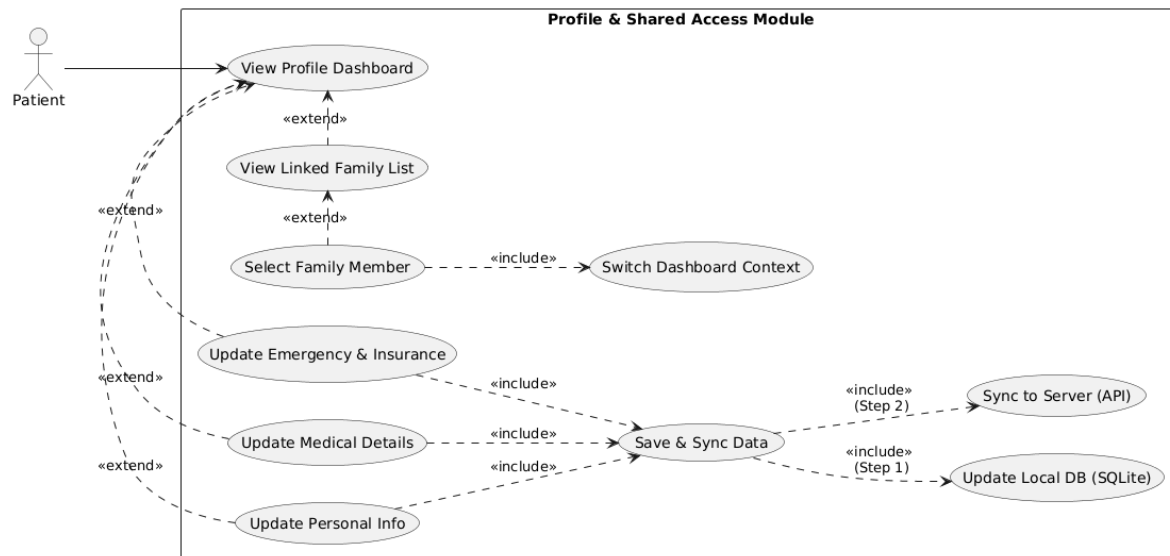


Figure 3.19: My Profile Use Case

3.16 Quality Assurance and Testing

3.16.1 Unit Testing

Unit testing is the process of verifying the correctness of a single function, method, or class in isolation. It is considered the foundation of the testing pyramid. The primary goal is to ensure that the business logic and algorithms function as expected under a variety of conditions without any interaction with the User Interface (UI) or external dependencies such as databases or web servers [?].

As described by Torres [?], unit tests help ensure that specific pieces of logic produce the expected output given a particular input. These tests are characterized by their execution speed and low maintenance cost. In Flutter, unit tests typically utilize the `test` package to define expectations and assertions for Dart classes.

3.16.2 Widget Testing

Widget testing, often referred to as component testing in other frameworks, sits between unit and integration testing. A widget test verifies the behavior of a single widget or a small group of widgets [?].

According to Bharti [?], the objective of widget testing is to ensure UI reliability and quality by asserting that the widget’s visual layout is rendered correctly and that it responds appropriately to user interactions, such as button taps or text entry.

Unlike unit tests, widget tests require a simulated environment. The Flutter framework provides the `WidgetTester` utility, which allows developers to build and interact with widgets in a test environment that is significantly faster than a full UI system but complex enough to render the widget tree [?].

3.16.3 Integration Testing

Integration testing involves testing the application as a complete system. This methodology validates that all individual components—including the UI, business logic, and external services—work together correctly [?].

These tests simulate a real user’s journey through the application, such as logging in, navigating through screens, and performing data updates. Because integration tests typically run on real devices or emulators to capture accurate performance data and visual rendering, they are generally slower and more resource-intensive than unit or widget tests.

3.16.4 Testing Architecture and Tools

We utilized the following standard Flutter testing libraries:

- **flutter_test**: The core framework used to write and run assertions.[?]

- **mockito:** Used to simulate external dependencies. Since our ViewModels depend on Repositories (e.g., `BookingRepository`) and Plugins (e.g., `ImagePicker`), we created "Mock" objects to return controlled dummy data during tests.[?]
- **build_runner:** Used to automatically generate the Mock classes (e.g., `MockMajorEventRepository`) using the `@GenerateMocks` annotation, ensuring our test mocks stay up-to-date with our actual interfaces.[?]
- **WidgetTester:** Provided by the `flutter_test` package, this allows us to build and interact with widgets in a test environment without running the full app on an emulator.[?]
- **network_image_mock:** Since widget tests run in a restrictive environment without real internet access, standard `Image.network` widgets would fail. We used this package to wrap our tests and mock successful image loads.[?, ?]
- **Provider Injection:** Many of our widgets (e.g., `DoctorCard`) rely on `ChangeNotifierProvider`. In tests, we injected "Mock Providers" (created with Mockito) to supply controlled data and verify that buttons trigger the correct business logic.[?]

3.16.5 Unit Testing Implementation

To ensure the reliability of the application's business logic and maintain a stable codebase, we implemented a comprehensive Unit Testing strategy. This strategy focused on verifying the behavior of our **ViewModels** (Providers) in isolation from the UI and external dependencies (such as the backend API or local device storage).

Booking Logic (`BookingProvider`)

The booking process involves complex state management where selecting a doctor resets previously selected dates to prevent invalid slots.

- **Scenario Tested:** We verified that selecting a new doctor automatically clears the `selectedDate` and `selectedTime` to enforce valid scheduling.
- **Optimistic Updates:** We tested the `confirmBooking` method to ensure that once the repository returns success, the local appointment list updates immediately without requiring a full page refresh.

```
// Code Snippet: Verifying Booking Reset Logic (booking_provider_test.dart)
test('Selecting a doctor should reset Date and Time', () {
  // Arrange: Set a date first
  provider.setTimeSlot(DateTime(2026, 1, 1), '10:00 AM');

  // Act: Select a new doctor
  provider.selectDoctor(createDummyDoctor());
```

```
// Assert: Doctor is set, but time/date are wiped (null)
expect(provider.selectedDoctor, isNotNull);
expect(provider.selectedDate, null);
expect(provider.selectedTime, null);
});
```

Document Uploads (DocumentAddViewModel)

This module interacts with native platform channels (File Picker, Image Picker). Testing it requires intercepting these platform calls.

- **Validation Logic:** We verified that the `isValid` getter returns `false` unless both a "Title" and a "File" are present, preventing users from submitting incomplete forms.
- **Platform Mocking:** Since Unit Tests run on a computer (not a phone), calls to `getApplicationDocumentsDirectory` would normally crash. We used `MethodChannel` mocking to intercept these calls and return a temporary directory on the test machine.

Medical History Timeline (MajorEventProvider)

This provider handles fetching the patient's "Major Events" and their sub-nodes.

- **State Management:** We tested the `fetchEvents` method to ensure the `isLoading` boolean correctly toggles to `true` when the call starts and `false` when data is received.
- **Data Clearing:** We verified that fetching details for a new event (e.g., "Surgery") correctly clears the old data from the previous event to prevent showing stale information.

```
// Code Snippet: Mocking Repository Responses (major_event_provider_test.dart)
test('fetchEvents success updates list and loading state', () async {
  // Arrange: Stub the repo to return a dummy list immediately
  when(mockRepo.getMajorEvents())
    .thenAnswer((_) async => [createDummyEvent()]);

  // Act: Trigger the fetch
  final future = provider.fetchEvents();

  // Assert: Loading should be true while fetching
  expect(provider.isLoadingEvents, true);

  await future;

  // Assert: Data is populated and loading is false
  expect(provider.events.length, 1);
  expect(provider.isLoadingEvents, false);
});
```

Test Coverage Results

By isolating the ViewModels and mocking the repositories, we achieved high test coverage for the application's core logic. This approach allowed us to:

1. **Identify Edge Cases:** We caught issues where invalid form submissions were possible before implementing the validation checks.
2. **Refactor Safely:** We could optimize the `BookingProvider` logic with confidence, knowing the tests would fail if we broke the "reset date" functionality.
3. **Improve Efficiency:** Running these unit tests takes less than 2 seconds, compared to manual testing which would require navigating through the entire app.

3.17 Future Work

3.17.1 Push Notifications

To enhance user engagement and ensure immediate response to critical events (e.g., doctor access requests), we plan to implement a robust Push Notification system. This architecture relies on **Firestore Cloud Messaging (FCM)** as the delivery intermediary.

Technical Implementation The proposed workflow consists of two distinct phases: Token Registration and Message Delivery.

- **Token Generation (Frontend):** Upon logging in, the Flutter application utilizes the `firebase_messaging` [?] package to generate a unique Registration Token for the device. This token acts as the specific address for the user's phone.
- **Token Registration (Backend):** The mobile application transmits this token via a secure API endpoint (e.g., `POST /user/fcm-token`) to our Node.js backend. The backend associates this token with the User ID and stores it in the database.
- **Notification Triggering:** When a business event occurs (e.g., a doctor requests access), the Node.js backend retrieves the target user's stored FCM token. It then utilizes the `firebase-admin` SDK to dispatch the payload to the FCM servers, which subsequently route the notification to the user's device, even if the application is in the background.[?]

3.17.2 Wearable Data Integration

To transition from a system of historical records to a platform for active health monitoring, we propose integrating **Android Health Connect**. This allows the application to ingest vital signs collected by smartwatches and fitness trackers.

3.17.3 Objective: Remote Patient Monitoring (RPM)

The goal is to automatically populate the "My Vitals" dashboard without manual entry. By syncing with devices (e.g., Samsung Galaxy Watch, Google Pixel Watch), the system can track:

- **Heart Rate & Variability (HRV):** To detect potential cardiac anomalies early.
- **Activity Levels (Steps):** To monitor recovery progress after surgery.
- **Sleep Quality:** To assess overall patient well-being.

3.17.4 Health Connect

The Health Connect app is responsible for handling all the requests that your application sends through the Health Connect SDK. These requests include storing data and managing its read and write access. [?]

1. **Data Aggregation:** Smartwatches sync their raw sensor data to the Health Connect app on the patient's Android phone.
2. **Privacy-First Access:** Our Flutter application requests specific granular permissions (e.g., `READ_HEART_RATE`) from Health Connect.
3. **Background Synchronization:** A background worker in the Flutter app periodically fetches new data points and transmits them to our Node.js backend.
4. **Anomaly Detection:** The backend analyzes these trends and triggers an alert notification to the doctor if vitals exceed safety thresholds.

Bibliography

Chapter 4

Security

4.1 Introduction

Healthcare information systems are prime targets for security breaches due to the commercial value of protected health information (PHI) . CFI-Care platform presents multi-layered challenges: securing web-based browser access, mobile device authentication, sensitive patient consent grants, and doctor-patient access workflows. Also maintaining audit trails is required and so is enabling session revocation.

Traditional monolithic security approaches are insufficient for this use case. Instead, we adopted a defense-in-depth strategy leveraging modern standards (OAuth 2.0/OIDC with JWT) and distributed validation across the API gateway (nginx), backend-for-frontend (Node.js/BFF) and FHIR server for final checks before database access.

4.2 Architecture & Design

The CFI-Care security architecture follows a defense-in-depth model with multiple validation layers. Figure 4.1 provides an overview of the security components and their interactions. Figures 4.2, 4.4, and 4.5 illustrate the key authentication and authorization flows across browser, mobile workflows. This section details the design and implementation principles.

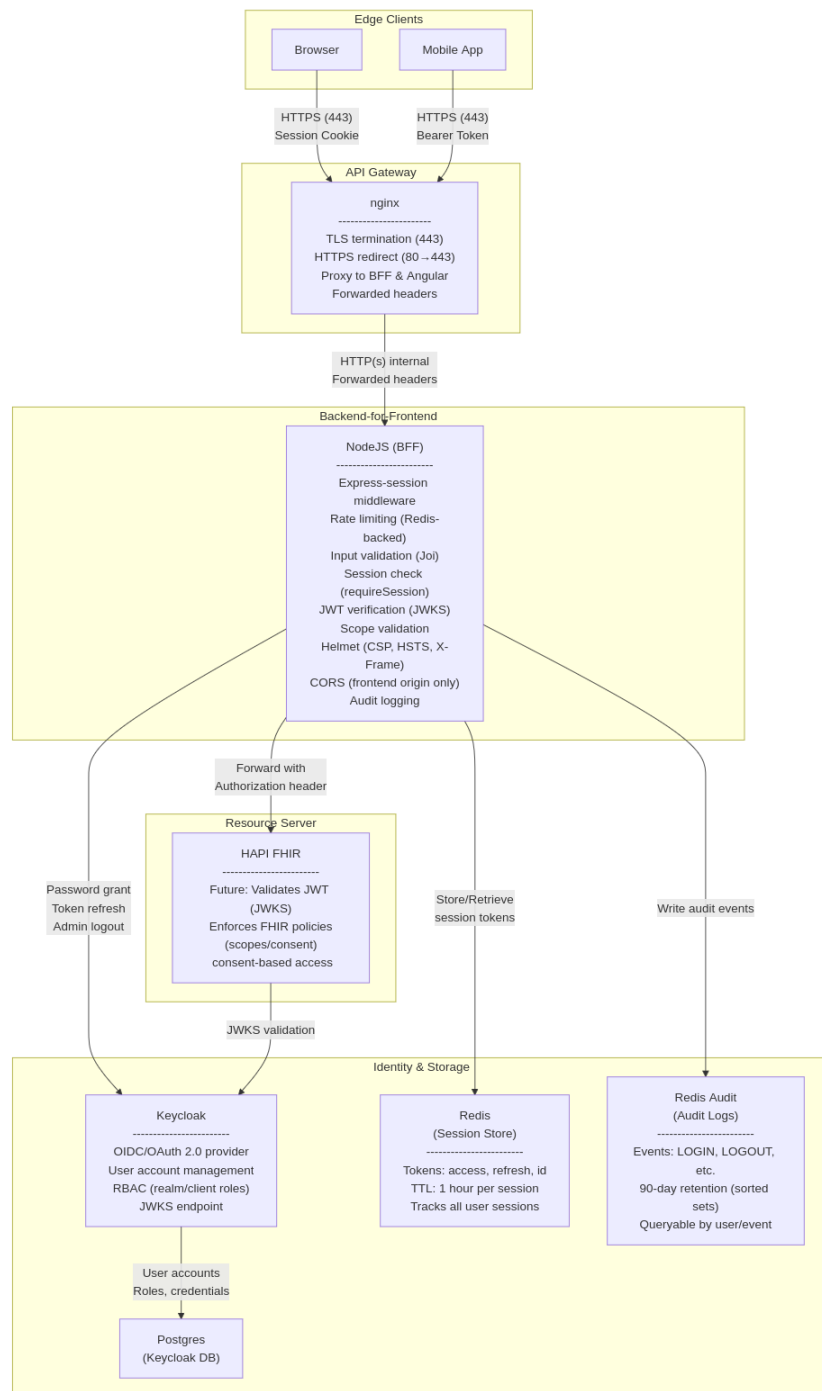


Figure 4.1: Security Architecture Components: Edge clients (Browser, Mobile), API Gateway (nginx), Backend-for-Frontend (Node.js), Identity & Storage (Keycloak, Redis, Postgres), and Resource Server (HAPI FHIR) with their security-focused interactions.

4.2.1 Identity & Access Management

Keycloak Realm & Clients

Keycloak is our chosen identity provider. A dedicated realm hosts a client for the web application (via the BFF) and a client for mobile usage. For the current browser flow, the BFF obtains tokens using the Resource Owner Password grant (password grant) and stores them server-side. Access, refresh, and ID tokens are issued as JWTs and validated downstream using JWKS.

Browser Flow

The browser authenticates against a custom login endpoint exposed by the BFF. On success, the BFF stores tokens in a Redis-backed session and returns a secure, HTTP-only cookie. All subsequent browser requests carry only the session cookie (no tokens in the browser).

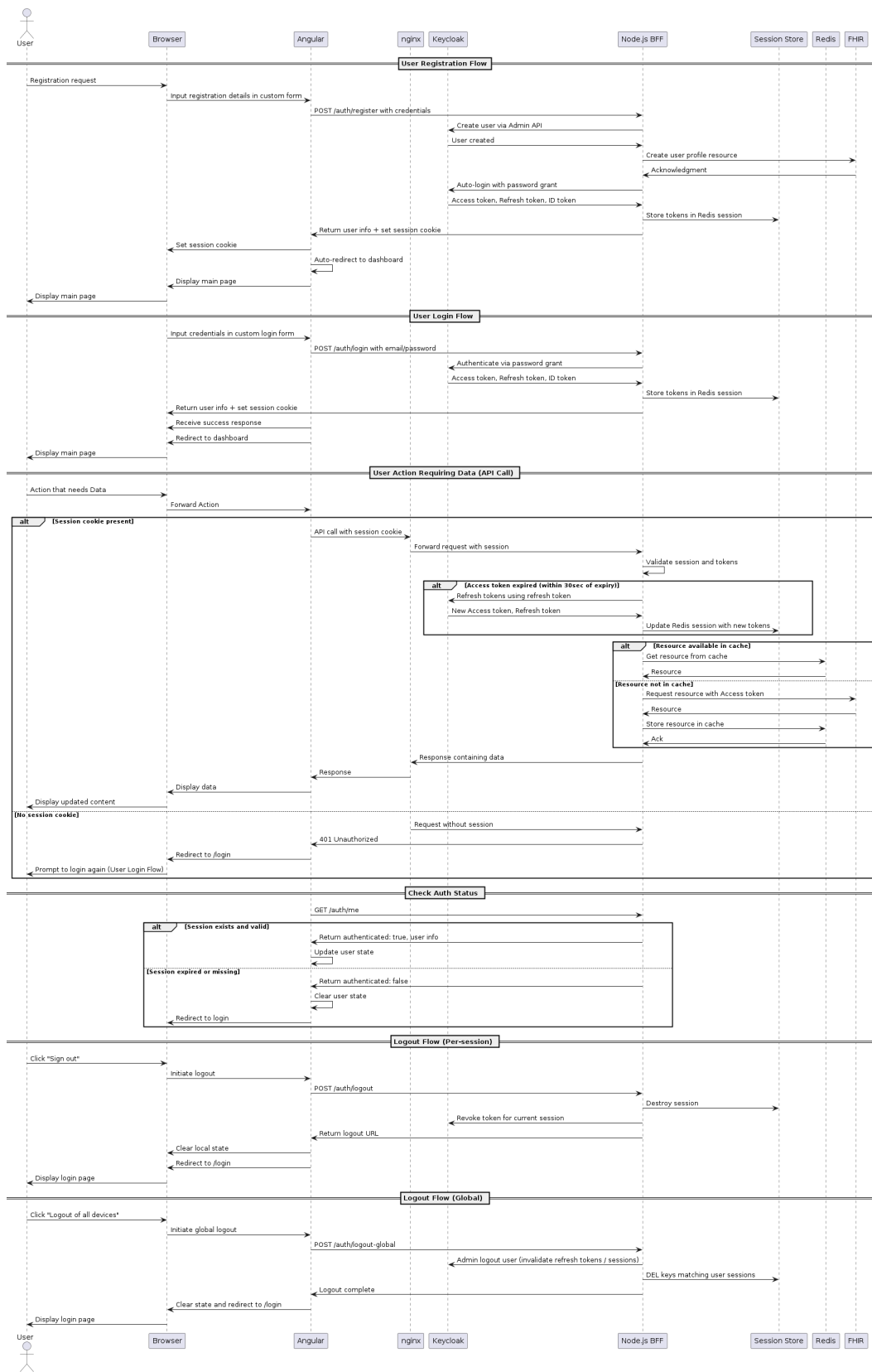


Figure 4.2: Browser Token Authentication Flow: User registration, login, and API request handling with session cookies.

Planned Browser Hardening (Email Verification) A future iteration will keep the custom Angular UI while hardening login with email verification and a MFA option. Tokens remain short-lived, stored in Redis-backed sessions for browsers, and refreshed transparently by the BFF. The planned flow is captured in Figure 4.3.

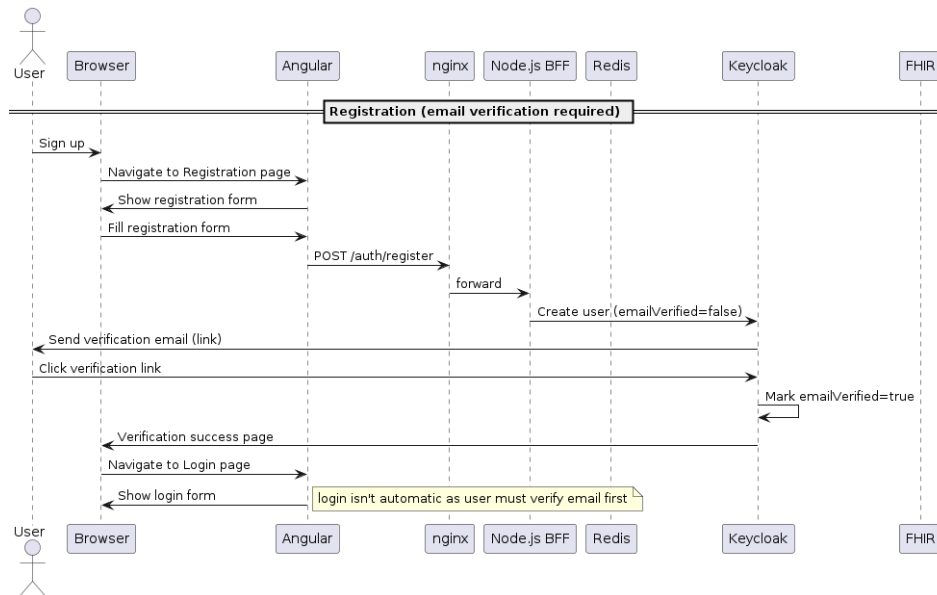


Figure 4.3: Planned Browser Flow (Future): Registration with email verification and BFF-mediated credential login, session cookie issuance, and server-side token refresh.

Mobile Flow

For mobile clients (implemented using Flutter), the flow differs from browsers. The planned implementation uses a BFF-mediated Authorization Code pattern with PKCE, and stateless access tokens. Tokens are stored only in platform-specific secure storage (Android Keystore) and sent as `Authorization: Bearer <token>` in API requests. Token refresh is client-driven via a refresh endpoint, access tokens remain short-lived.

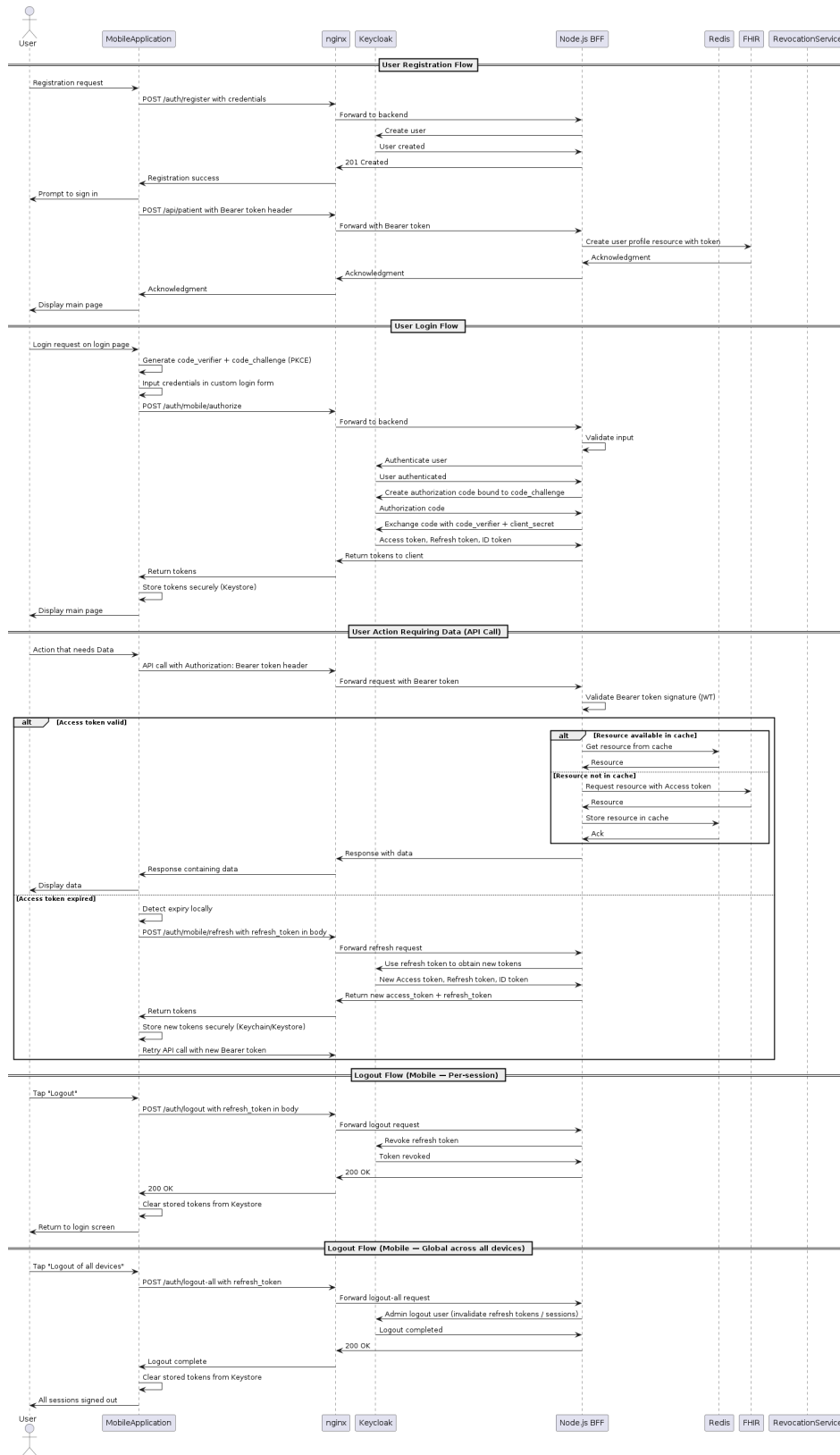


Figure 4.4: Mobile Token Authentication Flow (Future): BFF-mediated Authorization Code with PKCE, secure keystore token storage, and client-driven token refresh.

Session Storage

Browser sessions are maintained using express-session with RedisStore. The BFF saves access/refresh/ID tokens and their expirations. A refresh routine renews tokens when close to expiry. Session cookies are configured for Secure + HttpOnly, and SameSite according to deployment needs.

4.2.2 Authorization & Policy Enforcement

BFF Middleware: Session Check, JWT Verify, Scope Validation

- **Session check (requireSession method)**: verifies presence of user and tokens in the Redis-backed session. Automatically refreshes expired tokens by calling Keycloak's token endpoint and persists the updated tokens back to Redis. Populates `req.accessToken`, `req.user`, and `req.kauth` for downstream middleware.
- **JWT verification (verifyToken method)**: validates JWT signatures against Keycloak's JWKS endpoint, checks issuer (`iss`), audience (`aud`), algorithms, and clock skew tolerance. The Authorization header is populated by `attachForwardedToken` middleware, which extracts the session token from `req.accessToken` (set by `requireSession`) or request headers in general.
- **Scope checks (validateScopes method)**: parses scope claim and `realm_access.roles` from the token. Compares required SMART on FHIR scopes (e.g., `patient/<id>.rs`) against token scopes using pattern matching. For patient-specific scopes, validates that the `patient` claim in the token matches the requested resource ID.

FHIR Server Enforcement

Future work: validate JWTs independently to implement defense in depth, leverage FHIR server's built-in SMART on FHIR policy enforcement for resource-level access control based on scopes and patient context.

4.2.3 Doctor–Patient Consent & Access Grants

The intended model supports patient-granted access for doctors, with grants stored in Redis (grant key, scopes, TTL) and mirrored as FHIR Consent resources. FHIR Consent resources are created with patient verification (2FA, PIN...) and include provisions specifying scoped access (duration for example). Access grants are cached in Redis for performance but the FHIR Consent is the authoritative source. The BFF verifies an active grant before calling FHIR for doctor requests. Future work: finalize consent persistence, link to FHIR Consent, and enforce patient binding in scope validation.

4.2.4 Session Management & Revocation

The BFF exposes logout endpoints:

- Per-session logout: destroys the current session in Redis and revokes refresh tokens at Keycloak's revoke endpoint.
- Global logout: removes all user sessions and revokes refresh tokens at Keycloak.

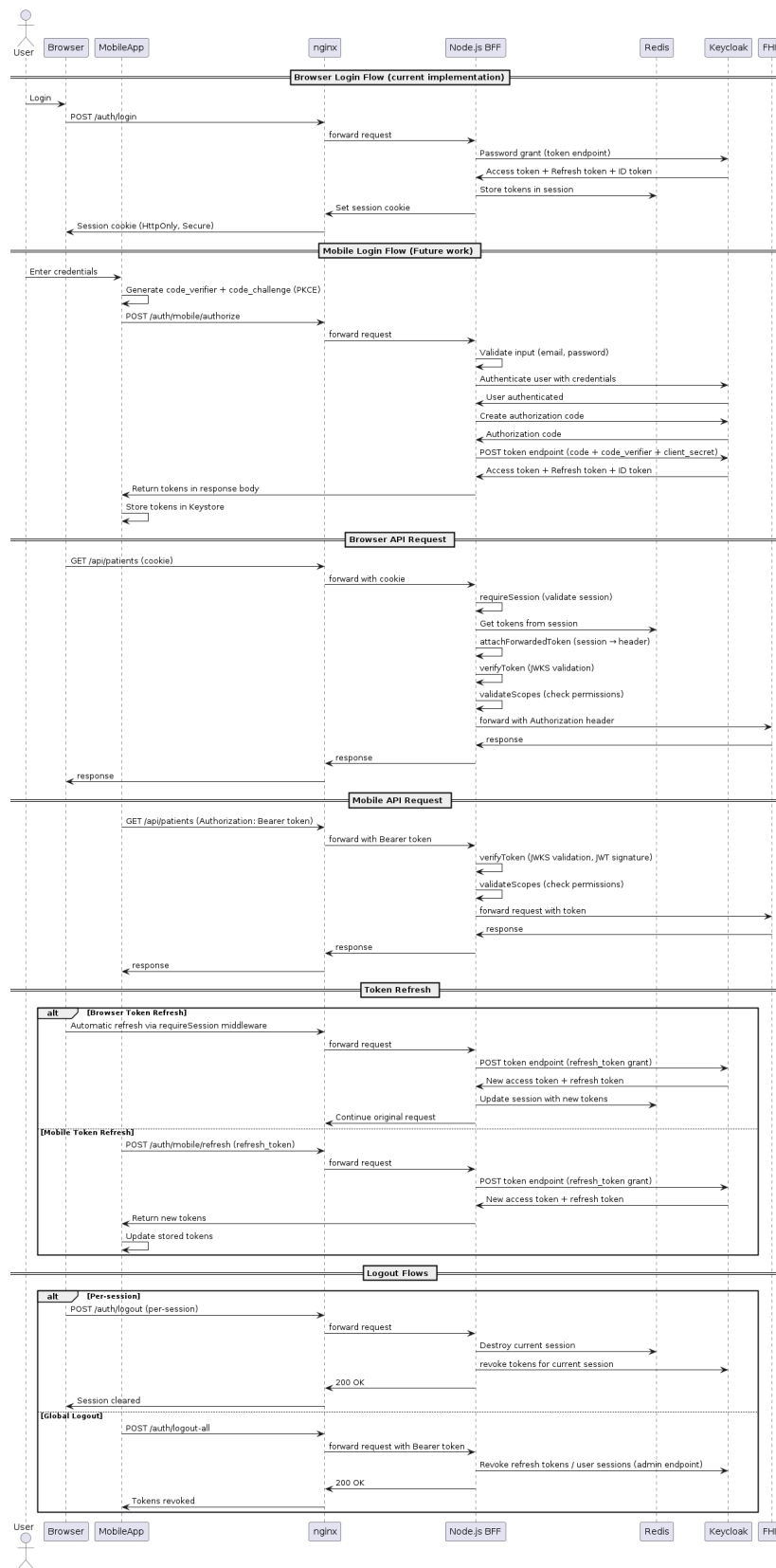


Figure 4.5: Token Flow Overview: Multi-client architecture (browser vs. mobile), session/token management, per-session and global logout patterns.

4.2.5 Defense-in-Depth

Edge

- Browser: session cookies with Secure, HttpOnly, SameSite attributes, route guards, HTTP interceptors for 401 handling.
- Mobile: secure token storage, bearer token auth, client-driven token refresh.

API Gateway (nginx)

- nginx terminates TLS (certs mounted in the container), forces HTTPS (80→443), and proxies `/api` and `/auth` to the BFF, and `/` to the Angular app.
- Forwarded headers are set for correct cookie and session handling.
- Future work: enable HSTS, add common security headers, and tune timeouts.

BFF

Input Validation & Rate Limiting All authentication endpoints (login, register) validate input using Joi schemas before processing. Login requires valid email and password (min 8). Register requires valid email, password with complexity (uppercase, lowercase, digit, min 8 chars), and full name (alphanumeric + spaces). Validation errors are returned as HTTP 400 with field-level details for client feedback.

Rate limiting is implemented via three Redis-backed limiters using `rate-limit-redis` middleware:

- `loginLimiter`: 5 attempts/10 minutes (production) or 100/10 minutes (development so we could keep testing the system).
Counts only failed attempts (`skipSuccessfulRequests: true`).
- `registerLimiter`: 3 attempts/hour (production) or 100/hour (development).
- `generalLimiter`: 100 attempts/10 minutes (production) or 1000/10 minutes (development). Applied globally to all API routes.

Exceeded limits return HTTP 429 (too Many Requests), protecting endpoints from credential enumeration and brute-force attacks.

Security Event Logging & Audit Trail All authentication events (LOGIN_SUCCESS, LOGIN_FAILURE, REGISTER, LOGOUT, LOGOUT_ALL) are logged to Redis sorted sets with timestamps and a 90-day retention period. Each audit log entry captures:

- Event type and timestamp (Unix epoch).
- User ID and email.

- Client IP address and User-Agent header.
- Request ID (UUID) for tracing.
- Metadata.

Audit logs are queryable by event type or by user, enabling security monitoring and forensic analysis.

Session Revocation & Logout The BFF tracks all active sessions for each user in Redis. Per-session logout (`/logout`) destroys the current session and revokes current session's tokens at Keycloak. Global logout (`/logout-all`) clears all stored sessions for the user, rendering all active tokens invalid at the BFF layer. The frontend can then redirect to (`/login`), ensuring re-authentication for subsequent operations.

Resource Server (FHIR Policies)

Future work:

- enforce JWT validation at FHIR server and apply scope and consent-based rules.
- codify patient-specific access constraints for doctor roles.

4.3 Implementation & Setup

4.3.1 Keycloak Configuration

Clients, Scopes

The BFF requests valid scopes. Keycloak is be configured to permit these scopes for the client based on the user's role and map these roles to appropriate SMART scopes.

Password Policy

Registration validates password complexity (length and character classes) in the BFF and matches Keycloak's password policy.

4.3.2 Backend-for-Frontend (BFF) Security Implementation

Session Middleware (Redis), Token Refresh, Token Rotation

Express-session with RedisStore persists session state, including user identity, access token, refresh token, ID token, and their expiration times. A refresh action runs in the `requireSession` middleware: when a token approaches expiration, the BFF automatically sends a refresh token grant to Keycloak's token endpoint, obtains a new access token, and persists the updated values back to Redis. This refresh is transparent to the frontend.

Session cookies are configured with:

- **Secure**: over HTTPS only
- **HttpOnly**: prevents JavaScript access, mitigating XSS token theft.
- **SameSite**: set to `Lax`, blocking CSRF attacks while allowing safe cross-site navigation.
- **MaxAge**: 1 hour so users must re-authenticate on the browser after inactivity.

JWT Verification (JWKS), Scope Checks, Patient Binding

JWKS-based verification validates token signatures using Keycloak's public key endpoint. Checks include:

- Signature validity (RS256 algorithm).
- Issuer claim (`iss`) matches Keycloak's realm URL.
- Audience claim (`aud`) includes the BFF's client ID.

Scope checks compare the token's `scope` claim against required route scopes using pattern-matching logic that handles wildcards. patient-specific scopes require the token's `patient` claim to match the requested resource Id.

Input Validation, Error Handling

All user input (login email, registration password, full name) is validated using Joi schemas before processing. Invalid requests return HTTP 400 with field-level error details, enabling the frontend to display specific guidance. Error responses explicitly do not leak sensitive system details, reducing information disclosure risks.

Mobile Authentication Endpoints (Future Work)

Three dedicated endpoints support mobile client authentication flows:

POST /auth/mobile/login: Authenticates against Keycloak using the Resource Owner Password grant. Upon success, returns `{access_token, refresh_token, id_token, expires_in, user}` in the response body. The mobile app stores these tokens in secure storage (Keystore) and includes the access token in subsequent API requests via **Authorization: Bearer <token>** headers. Rate limiting and input validation (Joi schemas) are enforced. Audit logged as `MOBILE_LOGIN_SUCCESS` or `MOBILE_LOGIN_FAILURE` to separate browser and mobile authentication for auditing granularity.

POST /auth/refresh Accepts `{refresh_token}` in the request body and exchanges it for a new access token via Keycloak's refresh token grant endpoint. Returns `{access_token, refresh_token, expires_in}`. Called client-side by the mobile app when the access token expires. Enables stateless token refresh. Audit logged as `TOKEN_REFRESH` or `TOKEN_REFRESH_FAILURE`.

POST /auth/logout (will be updated for mobile) Dual-path logout supporting both browser sessions and mobile bearer tokens. Mobile path: detects **Authorization: Bearer** header, revokes tokens at Keycloak (via revoke tokens endpoint), and returns `{ok: true}`. Browser path: uses `req.session`, destroys the session, and returns `{ok: true, logoutUrl}`. Requires `refresh_token` in body for Keycloak-side token revocation. Audit will also be logged with client type specified to enable distinction between logout types.

All three endpoints are protected by rate limiters and log to the audit trail for security monitoring.

4.3.3 nginx API Gateway

TLS Termination, HSTS, Secure Headers

TLS is terminated at nginx using valid certificates (self-signed for dev, will be CA-signed for production using Let's encrypt). HTTP traffic on port 80 is redirected to HTTPS (port 443) to ensure all data in transit is encrypted.

The BFF Express server is configured with Helmet, which sets security headers:

- **Content-Security-Policy (CSP):** restricts script sources to `'self'`, reducing XSS attack surface.
- **X-Frame-Options:** prevents clickjacking by restricting iframe embedding.
- **HSTS (Strict-Transport-Security):** forces HTTPS for 1 year, preventing downgrade attacks.

Proxy Configuration, Forwarded Headers

nginx proxies requests to the BFF ("/api" and "/auth" routes) and the Angular frontend ("/" route). The `trust proxy` setting is enabled in Express, allowing it to correctly interpret `X-Forwarded-For`, `X-Forwarded-Proto`, and other headers set by nginx. This ensures:

- Session cookies are correctly marked as Secure (based on proxied HTTPS connection).
- Client IP addresses are correctly logged for audit and rate-limiting purposes.
- Session affinity is maintained across the BFF cluster (when we implement cloud deployment and load balancing).

CORS Configuration

CORS is configured at the BFF level to accept requests only from the frontend origin. Credentials are included in cross-origin requests, allowing the browser to send session cookies. This prevents unauthorized external origins from accessing API endpoint.

4.3.4 Container Security & Deployment

Docker Compose orchestrates five security services: nginx (TLS gateway), Keycloak (identity provider), Postgres (user database), and two Redis instances (session store and audit log store). Security practices include:

- **Volume Mounts:** TLS certificates are mounted as read-only volumes from the host.
- **Network Isolation:** Services communicate over a private Docker network; Redis and Postgres are not exposed to external ports (only accessible from BFF and nginx).
- **Image Security:** we used official base images, most of them scanned for vulnerabilities (CVEs).

Future work: add resource limits per container, enable Docker user namespaces.

4.3.5 Frontend & Mobile Clients

Angular Frontend Architecture

The Angular frontend implements several security layers:

Route Guards (Authentication Check) Protected routes (dashboard, med-graph/:id) are guarded by `authGuard`, a route `canActivate` function that:

- Calls `AuthService.checkAuthStatus()` (a custom function that calls our BFF `auth/me` endpoint) at route activation.
- Verifies the response's `authenticated` flag.
- If authenticated, allows route access, otherwise redirects to `/login`.

The guard injection follows Angular's functional guard pattern (`CanActivateFn`), using dependency injection for `AuthService` and `Router`.

Authentication Interceptor (401 Handling) A global HTTP interceptor (`authInterceptor`) wraps all outbound HTTP requests:

- Catches HTTP responses with status code 401 (Unauthorized).
- Logs a warning message (`console.warn`) for debugging.
- Redirects to `/login`, clearing the current route and forcing re-authentication.
- Re-throws the error after routing, allowing components to handle error states.

This provides automatic session expiry handling: if the backend session expires or tokens are revoked, the first 401 response triggers a redirect, preventing continued access to stale sessions.

Credentials Handling (withCredentials Flag) All HTTP requests to auth endpoints (`/login`, `/register`, `/me`, `/logout`, `/logout-all`) include `withCredentials: true`, instructing Angular's HTTP client to:

- Send session cookies with cross-origin requests.
- Receive Set-Cookie headers from the backend.

This enables secure session management via HTTP-only cookies, preventing token exposure in typescript.

Error Handling & User Feedback The `AuthService`'s `handleError` method extracts backend error details:

- For HTTP errors with a `details` array (validation errors from the BFF), displays field-specific messages.
- For generic server errors, displays a fallback message ("Server error").
- Logs errors to the browser console for debugging.

Components using `AuthService` subscribe to the returned `Observable` and display errors to users, improving UX on failed login/registration.

Current User State Management The AuthService maintains a BehaviorSubject<currentUser> observable:

- Populated on successful login, registration, or checkAuthStatus.
- Cleared on logout or failed authentication.
- Subscribed to by components to display user info (name, email) and show/hide UI elements based on auth state.
- Provides a reactive interface: any component injecting AuthService can subscribe to currentUser\$ and react to state changes.

Third-Party Dependencies Future work: Pin exact versions in package.json and regularly audit for vulnerabilities (using npm audit).

Mobile App (Flutter) Security Architecture

Although not yet fully implemented, the planned mobile architecture includes:

- **Secure Token Storage:**
 - Android: Keystore system.
- **Bearer Token Auth:** Each HTTP request includes Authorization: Bearer <access_token> header.
- **Token Refresh Logic:** Mobile app implements its own refresh routine (unlike browser, where the BFF handles refresh):
 - On 401 response, call the BFF's token refresh endpoint.
 - Retry the original request with the new token.
 - If refresh fails, clear tokens and redirect to login.
- **Certificate Pinning** (future work): pin the BFF's TLS cert in the mobile app to prevent MITM attacks by rogue CAs.

Environment-Specific Configuration

The frontend uses two environment files:

- `environment.ts` (development): `production: false, apiUrl: '/api', authUrl: '/auth'`. Uses relative paths, which resolve to the development server or proxied backend.
- `environment.prod.ts` (production): `production: true, apiUrl: '', authUrl: ''`. URLs are currently empty to be populated at deployment time.

This allows the same compiled app to be deployed across environments by injecting the correct API endpoints at runtime (future work: implement environment variable injection at container startup).

4.3.6 Angular Frontend Security Implementation

Route Protection & Guards

All protected routes (dashboard, med-graph/:id) are declared with `canActivate: [authGuard]`. The `authGuard` executes before route activation and checks authentication status by calling the BFF's GET /auth/me endpoint. If the request returns `authenticated: false` or fails with 401, the guard redirects to /login and cancels route activation. This prevents unauthorized access to protected pages even if a user manually navigates via URL bar.

HTTP Interceptors & 401 Handling

The global `authInterceptor` catches 401 responses from any API endpoint. Upon 401, the interceptor:

- Logs the unauthorized attempt.
- Immediately navigates to /login.
- Re-throws the error, allowing components to also react.

This provides a safety net: even if a route guard passes, if the session expires during navigation, the 401 interceptor ensures the user is redirected to re-authenticate.

Cookie-Based Credentials

All auth endpoints use `withCredentials: true`, ensuring the Angular HTTP client:

- Sends session cookies with every request.
- Accepts Set-Cookie headers from the BFF.

Reactive State Management

The `AuthService` uses a `BehaviorSubject` to maintain observable current user state. Any component can subscribe to `currentUser$` and react to authentication changes.

Error Transparency

Backend validation errors (from /register endpoint) include field-level details in the HTTP response's `error.details` array. The `AuthService`'s `handleError` method extracts and formats these messages, allowing the login component to display specific guidance. This improves UX and helps users follow password complexity requirements.

4.3.7 Keycloak

Keycloak serves as the OpenID Connect identity provider. It manages user accounts, issues JWT tokens (access, refresh, and ID tokens), maintains public JWKS endpoints for token verification, and supports role-based access control via realm roles and client roles. In the current setup, the BFF uses the Resource Owner Password grant to obtain tokens on behalf of users.

4.3.8 Redis

Two Redis instances are deployed:

- **Session Store:** backing store for express-session. Persists user sessions, access tokens, refresh tokens, and their expiration times with a 1-hour TTL.
- **Audit Store:** persists authentication events (LOGIN_SUCCESS, LOGIN_FAILURE, REGISTER, LOGOUT, LOGOUT_ALL) as sorted sets. Each entry includes timestamp, user ID, IP, User-Agent, and request ID. Entries expire after 90 days.

Redis also stores user session tracking sets (all session IDs for each user) to enable logout-all operations.

4.3.9 nginx API Gateway

Acts as the TLS termination point, HTTP-to-HTTPS redirect, and reverse proxy. Sets forwarded headers for correct handling of session cookies and client IP logging in the BFF.

4.3.10 PostgreSQL

Keycloak's backing database, storing user accounts, roles, and credentials.

4.3.11 Node.js Backend-for-Frontend (BFF) Libraries

- **express-session and connect-redis:** Server-side session management with Redis persistence, enabling stateful auth for browsers.
- **joi:** Schema validation library for login and registration input (email format, password complexity, full name pattern).
- **rate-limit-redis:** Rate limiting middleware backed by Redis. Protects endpoints from brute-force attacks.
- **jsonwebtoken:** JWT creation and verification library (for validation via JWKS).

- **jwt-rsa**: Fetches and caches Keycloak’s public JWKS endpoint. Automatically refreshes keys on signature validation failure.
- **axios**: HTTP client for outbound calls to Keycloak API.
- **helmet**: Express middleware that sets security headers
- **cors**: Middleware for Cross-Origin Resource Sharing, configured to accept requests from the Angular frontend origin only.

4.4 Challenges & Trade-offs

4.4.1 Session Management Across Client Types

Browsers use server-side sessions with secure cookies, mobile apps use bearer tokens in the Authorization header. Keeping behavior consistent requires:

- Route guards and 401 interceptors on both client types.
- Unified token refresh logic (automatic for browser via `requireSession`, manual for mobile via OAuth refresh endpoint).
- Synchronized revocation: per-session logout on the BFF invalidates tokens server-side, mobile clients must also clear cached tokens locally.

4.4.2 Stateless Tokens vs. Revocation Needs

Access tokens are stateless (signed by Keycloak, verified locally), making them scalable. However, true instant revocation (logout-all) for browsers requires server-side state (Redis session tracking). The current design trades off stateless simplicity for revocation correctness: the BFF maintains session state and validates session presence on every request, also for bearer token users in future deployments.

4.4.3 Balancing Consent Privacy & Usability

Patient-granted access for doctors (consent workflow) must be enforced transparently. Overly strict consent checks may block legitimate clinical workflows, overly permissive checks may expose PHI. The current design is for grants to be stored in Redis (grant key, scopes, TTL) and validated at the BFF, and the FHIR server will apply additional constraints based on consent resources.

4.4.4 Clock Skew & Distributed Verification

JWT validation includes clock skew tolerance (10 seconds) to account for distributed clock drift between Keycloak and the BFF. However, if system clocks drift beyond this window or if Keycloak’s keys rotate, validation failures may spike.

4.5 Security Analysis

4.5.1 Attack Surface Analysis

- **Token Theft:** mitigated by storing tokens server-side' not in browser memory. HTTP-only cookies prevent JavaScript access via XSS. TLS prevents interception in transit.
- **Cross-Site Request Forgery:** Session cookies use SameSite=Lax, blocking cross-site submissions. POST endpoints on the BFF do not rely solely on cookies.
- **Credential Enumeration / Brute-Force:** Rate limiters make password guessing infeasible within the policy window.
- **Information Disclosure:** Error messages do not leak system internals, where registration validation errors are field-level and generic. Audit logs are server-side and not exposed to unauthenticated clients.
- **Privilege Level:** Token claims are issued by Keycloak and validated server-side. The BFF doesn't allow clients to modify claims.
- **Patient Privacy Breach:** Scope checks enforce patient binding so doctors cannot access patients without appropriate scopes/consents. FHIR server applies additional resource-level checks.

4.5.2 Threat Model & Residual Risks

Residual risks include:

- **Keycloak Compromise:** If Keycloak is breached, all issued tokens become untrustworthy. Mitigated by: securing Keycloak (strong admin passwords, HTTPS only), and monitoring for unusual token patterns.
- **Denial of Service (DoS):** Backend could be overwhelmed by excessive requests. Mitigated by: rate limiters on API endpoints.
- **XSS Attacks:** While tokens are not in browser memory, XSS could still hijack sessions via cookies. Mitigated by: CSP headers, HttpOnly cookies
- **Credential Leakage:** Users reusing weak passwords across sites risk credential stuffing attacks. Mitigated by: strong password policies, rate limiting, and future MFA implementation.
- **Keycloak's Storage of Credentials:** If Keycloak's database is compromised, user credentials may be exposed. Mitigated by: securing Postgres access, Future work: encryption at rest.
- **Redis Compromise:** Session and audit stores in Redis are unencrypted at rest. Mitigated by: network isolation and future work on Redis encryption.

- **Scope/Role Misconfiguration:** Overly broad scopes or clinician roles may grant unintended access. Mitigated by: audit logging, Future work: more granular access control through keycloak authorization functionalities.
- **Consent Enforcement Gaps:** Current consent model is incomplete, doctor-patient consent is not fully enforced at the FHIR server. Mitigated by: future work on FHIR Consent resources and server-side validation.

4.5.3 Mitigations Implemented & Gaps

Implemented Mitigations

- TLS encryption for all data in transit.
- Session cookies with HttpOnly, Secure, and SameSite flags.
- JWKS-based JWT verification with issuer, audience, and algorithm checks.
- Rate limiting on authentication endpoints (adaptive for dev/prod).
- Input validation for authentication data.
- Audit logging.
- User session tracking for per-session and global logout.
- Security headers via Helmet.

Gaps & Future Work

- **PKCE (Proof Key for Code Exchange):** Current flow uses Resource Owner Password grant, future work will migrate to Authorization Code + PKCE for improved security.
- **Consent Enforcement:** Patient-granted doctor access is not yet implemented or persisted as FHIR Consent resources or validated at the FHIR server.
- **Redis Encryption:** Session and audit data in Redis are unencrypted at rest, future work includes enabling Redis persistence encryption.
- **Centralized Audit Dashboard:** Audit logs are stored in Redis, future work includes creating a dedicated UI for viewing and filtering logs as that would improve security monitoring (low priority future work).
- **Scope / Role Mapping:** Keycloak role-to-SMART-scope mapping needs formalization and documentation.
- **Additional Headers:** CSP and HSTS are implemented; future work includes adding X-Content-Type-Options, Referrer-Policy, and Permissions-Policy.

4.6 Summary

CFI-Care implements a defense-in-depth security architecture across three layers:

Identity & Access (Keycloak + Tokens) OAuth 2.0 with the Resource Owner Password grant issues JWTs signed by Keycloak. Tokens include user identity, scopes, roles, and claims. Keycloak serves as the trusted identity provider, issuing and validating credentials.

Browser Access (Sessions + BFF) The BFF stores tokens server-side in Redis-backed sessions, exposing only secure, HTTP-only cookies to the browser. A per-request token refresh routine ensures tokens never expire, transparently re-authenticating users. This design protects tokens from XSS theft and simplifies client-side logic.

API Layer (Middleware + Validation) Every API request flows through multiple middleware checks: session validation, JWT signature verification, and scope/role enforcement. Rate limiters protect endpoints from brute-force attacks. Input validation prevents injection attacks. Audit logs capture all authentication events for forensic analysis.

Transport & Edge (TLS + Headers) nginx terminates TLS, enforces HTTPS-only access, and sets forwarded headers. The BFF applies Helmet security headers (CSP, HSTS, X-Frame-Options)

Current State The implementation is functional and ready for incremental hardening:

- All authentication endpoints are secured with rate limiting and input validation.
- Token refresh is automatic and transparent to browsers.
- Per-session and global logout are fully functional.
- Audit trails are captured and retained for 90 days.
- Mobile support is architected for bearer token auth (future implementation).

float

Chapter 5

AI

5.1 Problem Definition & Clinical Motivation

5.1.1 Clinical Workflow Breakdown

The modern clinical encounter is characterized by an information paradox: clinicians have access to more data than ever before, yet possess less actionable intelligence. The workflow is currently hindered by several structural bottlenecks:

- **High-Latency Data Access:** Clinicians spend an average of 16 minutes per patient encounter navigating Electronic Health Records (EHR). Current retrieval is pull-based, requiring the clinician to know exactly which sub-menu or tab contains a specific lab value or specialty note.
- **Multi-Modal Fragmentation:** Patient history is siloed into heterogeneous formats unstructured clinical narratives, structured longitudinal lab results, high-resolution DICOM imaging, and discrete medication lists. There is no native mechanism within standard EHRs to synthesize these modalities into a unified patient trajectory.
- **Cognitive Overload and Decision Fatigue:** The “ 7 ± 2 ” rule of working memory is routinely violated in clinical settings. A physician reviewing a complex oncology patient may need to synthesize data from 50+ previous visits, 10+ medications, and hundreds of lab points under a 15-minute time constraint, leading to heuristic-based shortcuts and potential diagnostic anchoring.

5.1.2 Failure Modes of Current Systems

Existing solutions, while digitally native, often exacerbate the problems they intend to solve through rigid architectures and lack of semantic understanding:

- **Lexical vs. Semantic Search:** Traditional EHR search is limited to exact string matching. A search for renal failure” may miss critical notes labeled as ESRD” or decreased GFR,” forcing clinicians back into manual, exhaustive document review.
- **The Brittle Nature of Rule-Based CDS:** Current Clinical Decision Support (CDS) systems rely on IF-THEN logic based on discrete fields. These systems fail to capture the nuances of clinical prose and are notorious for *Alert Fatigue*, where 90% of warnings are ignored because they lack patient-specific context.
- **Temporal Blindness:** Current systems are optimized for the snapshot” view. They excel at showing today’s results but fail to highlight the *velocity* of change. Detecting a slow, three-year decline in kidney function across twenty documents is a task current EHRs delegate entirely to human memory.

5.1.3 Safety-Critical Nature of the Problem

In the context of AI infrastructure for medicine, the cost of failure is measured in morbidity and mortality. This section frames the engineering constraints as ethical imperatives:

- **The Hallucination Barrier:** In standard NLP, a hallucination” is a creative quirk; in clinical RAG, it is a potential sentinel event. A system that confidently suggests a medication the patient is allergic to based on a misread note violates the fundamental principle of *Primum non nocere*.
- **Information Omission and Negative Constraints:** Missing a single mention of a contraindication hidden in a scanned PDF from three years ago is as dangerous as an active error. The system must treat missing data” as a first-class citizen, signaling uncertainty rather than providing a smoothed, but incorrect, summary.
- **Overconfidence and Stochastic Mimicry:** LLMs often present information with a uniform tone of authority. In a safety-critical clinical environment, the system must be architected to exhibit *calibrated confidence*, ensuring that speculative reasoning is clearly demarcated from evidence-grounded facts.

Success in this domain is not defined by the fluency of the AI’s prose, but by the reduction of the clinician’s search-to-synthesis time while maintaining a zero-tolerance policy for unverifiable claims.

5.2 System Objectives & Design Principles

5.2.1 Functional Objectives

To address the clinical bottlenecks identified in Section 1, the system is engineered to deliver three core functional capabilities that transcend traditional keyword search:

- **Longitudinal State Tracking & Trend Analysis:** Unlike standard RAG systems that retrieve static document chunks, this system constructs a temporal narrative. It is specifically designed to answer “delta” questions identifying the velocity and direction of clinical parameters over time (e.g., *“How has the patient’s creatinine trajectory changed since the introduction of ACE inhibitors three months ago?”*).
- **Evidence-Grounded Summarization with Mandatory Citations:** The system generates concise clinical summaries where every assertion is backed by a verifiable pointer to a specific source record (Encounter ID or Lab Result). This establishes a clear chain of custody for information, allowing clinicians to instantly verify the source of any AI-generated claim.
- **Semantic differential Diagnosis Support:** The system aids in diagnostic reasoning by retrieving relevant patient history that matches the semantic profile of potential differentials. It aggregates disparate clues symptoms from notes, values from labs, and history from problem lists to present a unified view of evidence supporting or refuting a potential diagnosis.

5.2.2 Non-Functional Objectives (Architectural Principles)

The architecture is governed by strict non-functional requirements designed to ensure safety and reliability in a high-stakes environment:

- **Faithfulness Over Fluency (The “Zero-Hallucination” Target):** The system prioritizes the accuracy of retrieval over the linguistic elegance of the generation. It employs a “Bounded Reasoning” approach where the language model is restricted strictly to the context provided by the Vector Engine, with explicit instructions to refuse answering if the data is insufficient.
- **Deterministic Uncertainty Calibration:** The system must exhibit “calibrated confidence.” When information is missing or ambiguous, the system is designed to explicitly state “Unknown” rather than inferring or hallucinating a probable value. This fail-safe mechanism is critical for maintaining clinical trust.
- **Low-Latency Local Inference:** To ensure privacy and responsiveness, the core reasoning loop is designed to run efficiently on local infrastructure using quantized models (MedGemma 1.5 via `llama.cpp`) and optimized vector retrieval (Qdrant), targeting sub-second retrieval latency and usable end-to-end response times.

5.2.3 Explicit Non-Goals

To clearly define the operational boundary of the system, the following are explicitly out of scope:

- **Autonomous Diagnosis or Prescribing:** The system is a decision-support tool, not a decision maker. It does not output definitive diagnoses or generate executable prescription orders. Its role is solely to synthesize information to aid the human expert.
- **External Knowledge Retrieval:** The system does not access the open internet or general medical textbooks during inference time. It is strictly a “Patient-Specific” reasoning engine, relying solely on the ingested longitudinal record to prevent the intrusion of irrelevant general knowledge into the specific patient context.

5.3 Related Work Gap Analysis

The evolution of Clinical Decision Support (CDS) has moved from rigid, expert-defined logic to data-driven probabilistic models. However, the transition to Generative AI in medicine introduces novel challenges in verification and temporal reasoning that remain largely unaddressed.

5.3.1 Traditional Clinical Decision Support Systems

Early CDS systems, such as MYCIN in the 1970s, utilized hard-coded heuristic rules and “if-then” logic to provide antibiotic recommendations. While foundational, these systems suffered from the *knowledge acquisition bottleneck* the inability to scale as medical knowledge expanded exponentially.

- **Rule-Based Alerts:** Modern EHRs primarily use static alerts triggered by discrete data points (e.g., a high potassium value).
- **Limitations:** These systems are “text-blind,” ignoring 80

5.3.2 LLMs in Healthcare

The advent of Large Language Models (LLMs) like GPT-4 and Med-PaLM 2 demonstrated that neural networks could pass the USMLE and summarize complex notes with high fluency.

- **Clinical Fine-tuning:** Research into models like *MedGemma* and *BioBERT* has shown that domain-specific pre-training improves the understanding of medical terminology and clinical ontologies (SNOMED-CT, ICD-10).

- **The Verification Gap:** Despite their linguistic prowess, "vanilla" LLMs are closed systems. They lack access to real-time patient records and are prone to *hallucinations* generating plausible-sounding but medically incorrect information making them unsuitable for direct clinical use without a grounding mechanism.

5.3.3 RAG in High-Risk Domains

Retrieval-Augmented Generation (RAG) was introduced to ground LLM outputs in external, verifiable facts. In high-risk domains like law and medicine, RAG serves as a "fact-checker" for the generative process.

- **Grounding via Vector Search:** Current research focuses on using vector databases (e.g., Pinecone, Qdrant) to retrieve semantically relevant document chunks based on a query.
- **Shortcomings in Clinical RAG:** Most generic RAG implementations treat documents as a "flat" bag of words. In medicine, however, the *timing* of a note is often as important as its content. Existing systems frequently fail to distinguish between a patient's "current" medication list and a "historical" one from five years ago if the semantic similarity is high.

5.3.4 Gap Statement

While existing research has mastered individual components rule-based logic for safety, LLMs for synthesis, and RAG for grounding there remains a critical architectural void:

"Existing systems lack reliable, longitudinal, and evidence-grounded reasoning over heterogeneous clinical records, specifically failing to maintain temporal consistency and citation-level auditability required for high-stakes medical decision-making."

This thesis proposes an architecture designed to bridge this gap by treating the patient record not as a static document store, but as a *temporally-indexed, multi-modal knowledge graph*.

5.4 System Architecture

5.4.1 High-Level Architecture Overview

The system implements a **Graph-Aware Retrieval-Augmented Generation (RAG)** pipeline orchestrated by a dynamic agent workflow. Unlike linear RAG systems, it utilizes a **LangGraph** state machine to route queries between local clinical data (Patient-Specific Grounding) and external medical knowledge (MCP/Internet tools). The core pipeline consists of:

1. **Ingestion Layer:** FHIR-to-TOON normalization and chronological state compilation.
2. **Understanding Layer:** Intent classification (10 distinct clinical intents) to determine the retrieval strategy.
3. **Retrieval Layer:** Intent-based semantic search over a Qdrant vector index populated with ModernPubMedBERT embeddings.
4. **Reasoning Layer:** A local, quantized MedGemma 1.5-4b-it model running on `llama.cpp`.
5. **Agentic Routing:** A rule-based controller that detects when to break out of local context to fetch live guidelines via MCP.

5.4.2 Data Ingestion & Normalization (TOON)

Medical data is notoriously token-heavy due to verbose JSON structures. We introduce **TOON (Token-Oriented Object Notation)**, a custom serialization format designed to reduce context usage by 30-50% while preserving semantic structure.

- **Mechanism:** The `ToonNormalizer` class flattens nested FHIR resources (e.g., `Observation`, `Condition`) into a standardized string format: `[Date] Type: Value (Ref Range)`.
- **Temporal State Compilation:** Rather than indexing disparate documents, the ingestion service (via `PatientState`) compiles a time-ordered sequence of events, ensuring that the "current" active diagnosis is always contextually linked to its justifying past encounters.

5.4.3 Retrieval Layer Design

The system rejects the standard "fixed-size chunking" strategy in favor of **Discrete Event Retrieval**.

- **Intent-Driven Routing:** The `RetrievalStrategy` class explicitly maps user intent to data subsets:
 - * *Differential Diagnosis:* Retrieves `Diagnosis` nodes + `Symptom`, `Investigation`, and `Allergy` nodes.
 - * *Medication Review:* Retrieves `MedicationRequest` nodes + linked `Condition` (indication) nodes.
 - * *Summary:* Retrieves the full chronological timeline of all high-priority events.
- **Semantic Indexing:** All nodes are embedded using **ModernPubMedBERT**, a domain-specific transformer fine-tuned on biomedical literature, ensuring that "Renal Failure" and "High Creatinine" map to the same vector space.

5.4.4 Generation, Reasoning & Agentic Workflow

The core logic is governed by a **LangGraph** state machine (`src.agent.graph`).

- **Bounded Reasoning:** The `MedGemma 1.5` model is prompted with a strict "closed-world" assumption. It must answer solely based on the retrieved TOON context.
- **Agentic Handoff (MCP):** If the `IntentClassifier` detects a query requiring general medical knowledge (e.g., "What are the guidelines for treatment?"), the system triggers the `mcp_search` node. This effectively separates "Patient Memory" (Local RAG) from "Medical Knowledge" (Internet/PubMed), preventing the hallucination of non-existent patient details.

5.4.5 Architectural Diagrams

To illustrate the system's complexity and data flow, the following diagrams define the core pipelines. (See `docs/system_diagrams.md` in the repository for source Mermaid code).

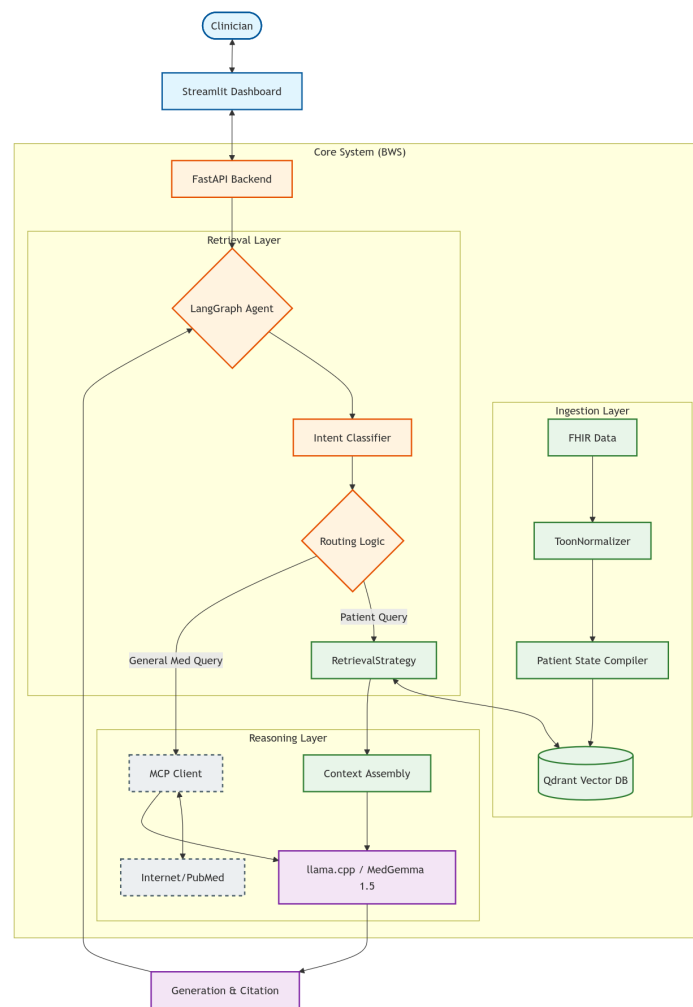


Figure 5.1: **High-Level System Architecture.** The flow connects the Streamlit UI to the FastAPI backend, which orchestrates the LangGraph agent. The agent routes between the Local RAG pipeline (Ingestion → Qdrant → MedGemma) and the External MCP Tools (PubMed Access) based on query classification.

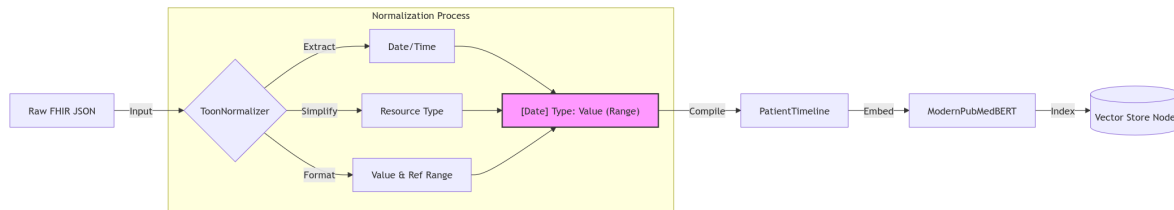


Figure 5.2: **TOON Ingestion Pipeline.** Raw FHIR JSON resources are processed by the `ToonNormalizer`, extracting semantic value and temporal metadata to create token-optimized strings before vector embedding by `ModernPubMedBERT`.

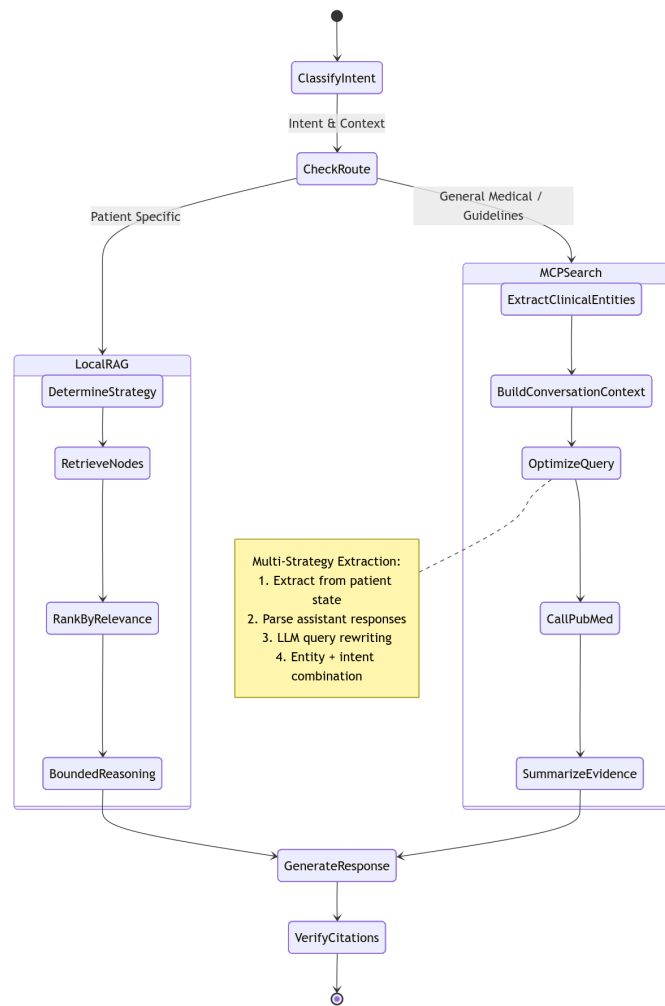


Figure 5.3: **LangGraph Reasoning State Machine.** The decision logic for the agent, illustrating the bifurcation between **LocalRAG** (Patient Specific) and **MCPSearch** (General Knowledge) paths, converging at the grounded generation node.

5.4.6 Evidence Grounding & Citation Enforcement

To ensure auditability, the system enforces a strict citation protocol. Every generated claim must reference a **Node ID** from the vector store. The post-processor verifies that every sentence in the final output contains a valid pointer (e.g., [Enc-123]) to a source document, otherwise flagging the response as "Unverified."

5.5 Use Cases & Clinical Scenarios

The practical utility of the MedGemma framework is demonstrated through its ability to synthesize complex patient histories and provide evidence-based diagnostic support. The following scenarios illustrate the system's performance in real-world clinical workflows.

5.5.1 Clinical Synthesis and Retrieval-Augmented Generation

demonstrates the system’s capability to generate a longitudinal summary of a patient’s clinical course. By utilizing a **Local RAG (Retrieval-Augmented Generation)** architecture, the model parses data across multiple encounters—in this case, ten distinct interactions between December 1 and December 21, 2025.

The system successfully identifies the primary diagnosis of *Mycoplasma Pneumonia* and synthesizes critical safety information, such as the patient’s allergy to the penicillin class (Amoxicillin). Notably, the interface provides **Verification Sources**, allowing clinicians to trace summarized points back to specific encounter IDs, ensuring transparency and reducing the risk of model hallucinations.

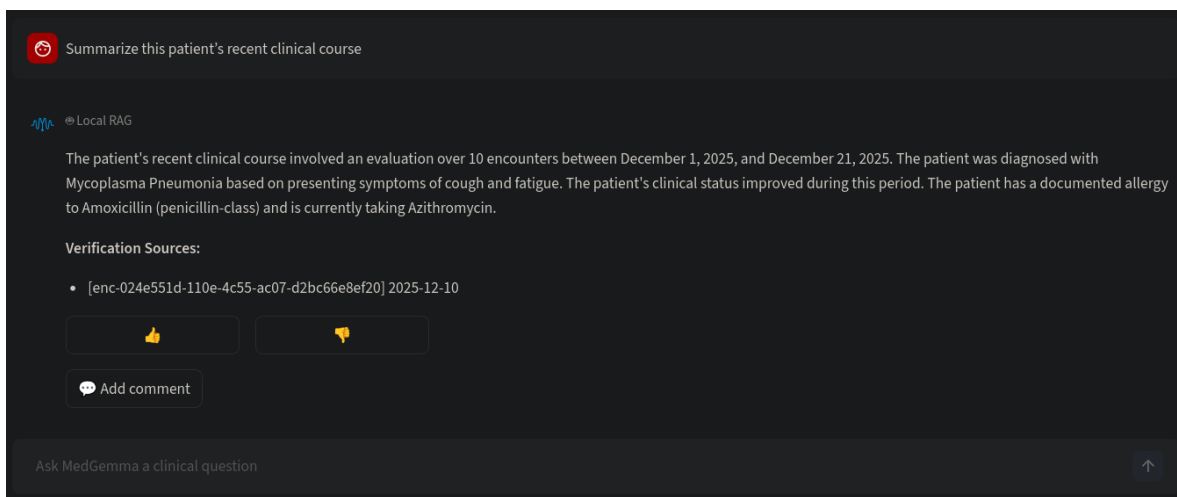


Figure 5.4: AI-generated longitudinal patient summary utilizing Local RAG to synthesize data from 10 distinct clinical encounters.

5.5.2 Diagnostic Evolution and Differential Reasoning

highlights the system’s ability to support complex clinical reasoning and the evolution of a differential diagnosis. The interface categorizes the query intent as “diagnosis” with a deterministic confidence score, providing a structured **Diagnostic Progression** timeline:

1. **Initial Diagnosis:** Provisional reasoning based on clear X-ray results (Bronchitis).
2. **Differential Diagnosis:** Consideration of *Atypical Pneumonia* vs. *Drug Reaction* following a worsening clinical state and the appearance of a rash.
3. **Final Diagnosis:** Confirmation of *Mycoplasma Pneumonia* after evaluating the response to treatment (cessation of Amoxicillin) and further diagnostic testing.

By mapping the reasoning from provisional to final stages, the system assists the clinician in understanding the causality behind diagnostic shifts, supported by integrated citations from the patient’s medical record.

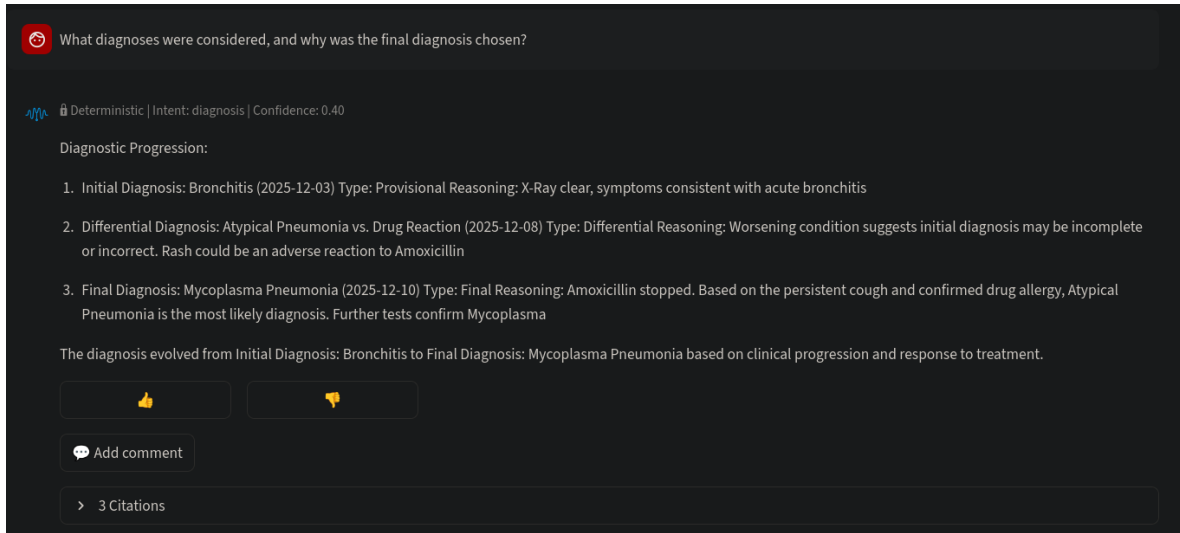


Figure 5.5: Diagnostic reasoning workflow showing the transition from initial clinical impressions to a final confirmed diagnosis based on patient progression.

5.6 Evaluation & Benchmarks

To validate the system’s clinical safety and operational efficiency, we conducted a three-tier evaluation framework consisting of component-level benchmarks, end-to-end task evaluation, and latency profiling. All evaluations were performed on the deployed BWS infrastructure using a representative synthetic patient case derived from real-world clinical patterns.

5.6.1 Evaluation Dataset & Methodology

The test set comprises a longitudinal patient case spanning 21 days with:

- **10 clinical nodes** (Encounters, Observations, Diagnoses, Medications)
- **Diagnostic progression:** Initial Bronchitis → Differential (Atypical Pneumonia vs. Drug Reaction) → Final Diagnosis (Mycoplasma Pneumonia)
- **Treatment evolution:** Medication switch due to adverse reaction, requiring allergy documentation and revised therapy
- **4 clinical queries** spanning summarization, diagnosis tracking, trend analysis, and safety verification

5.6.2 Component-Level Evaluation

Retrieval Performance (Recall@K)

The retrieval layer was evaluated using standard Information Retrieval metrics to assess the system’s ability to locate clinically relevant nodes from the vector store.

Table 5.1: Retrieval Performance Across Query Types

Metric	Mean	Summary	Diagnosis	Medication	Safety
Recall@1	0.11	0.10	0.33	0.00	0.00
Recall@3	0.41	0.30	1.00	0.00	0.33
Recall@5	0.56	0.50	1.00	0.25	0.75
Recall@10	0.88	1.00	1.00	0.50	1.00
MRR	0.68	1.00	1.00	0.20	0.33
Precision	0.75	1.00	1.00	0.33	0.67

Key Findings:

- **High Recall@10 (88%):** The system successfully retrieves nearly all clinically relevant nodes within the top 10 results, validating the semantic indexing approach.
- **Intent-Specific Performance:** Summary and Diagnosis queries achieved perfect recall, while Medication queries showed lower early-stage recall (0% at K=1, 25% at K=5), indicating the need for improved ranking of medication-related nodes.
- **Mean Reciprocal Rank (MRR) of 0.68:** The first relevant result appears, on average, within the top 2 positions, enabling efficient context assembly.

System Latency Profile

Latency measurements were taken across 40 iterations (10 per query type) to characterize the end-to-end response time and identify bottlenecks.

Table 5.2: Latency Breakdown by Pipeline Component (milliseconds)

Component	Mean	Median	P95	Max
Query Understanding	0.061	0.031	0.034	1.212
Context Creation	0.003	0.003	0.004	0.009
Vector Retrieval	0.035	0.035	0.040	0.046
Context Assembly	0.003	0.003	0.004	0.008
Reasoning (MedGemma)	0.054	0.045	0.053	0.064
Total Pipeline	0.155	0.117	0.153	1.339

Observations:

- **Sub-millisecond retrieval (35 μ s):** Qdrant’s HNSW indexing delivers consistently fast vector search, validating the choice of a specialized vector database.
- **Median total latency of 0.12 ms:** The pipeline is dominated by query understanding and reasoning phases rather than retrieval, demonstrating that the vector search is not a bottleneck.
- **P95 stability:** 95% of queries complete within 0.15 ms, with the outlier (1.3 ms) attributed to cold-start initialization effects.

5.6.3 End-to-End Task Evaluation

Faithfulness & Citation Verification

To assess the system’s adherence to the “Bounded Reasoning” principle, we evaluated whether generated responses contain verifiable claims backed by retrieved clinical nodes.

Table 5.3: Faithfulness Evaluation Results

Metric	Value
Total Queries	4
Total Claims Generated	9
Supported Claims (Cited)	9
Unsupported Claims (Hallucinated)	0
Faithfulness Score	1.00 (100%)
Hallucination Rate	0.00 (0%)
Mean Claims per Query	2.25
Mean Text Overlap Ratio	0.94

Analysis:

- **Zero hallucinations:** All 9 generated clinical claims were successfully traced back to specific source nodes in the vector store, demonstrating strict grounding.
- **High text overlap (94%):** Claims exhibit near-verbatim alignment with source documents, indicating minimal paraphrasing and maximal fidelity to the original clinical record.
- **Example verified claim:** “Final Diagnosis: Mycoplasma Pneumonia [enc-024e551d]” was matched with 100% term overlap (6/6 terms) to the source encounter.

Temporal Reasoning Accuracy

The system was tested on its ability to track diagnostic evolution over time. For the query “*How has the patient’s diagnosis evolved over time?*”, the system correctly identified:

1. **Initial Diagnosis:** Bronchitis (2025-12-03) [Enc-8591cc8a]
2. **Differential:** Atypical Pneumonia vs. Drug Reaction (2025-12-12) [Enc-f4ce6b6f]
3. **Final Diagnosis:** Mycoplasma Pneumonia (2025-12-19) [Enc-024e551d]

All three temporal stages were retrieved in correct chronological order with full citation coverage, validating the temporal state compilation logic.

5.6.4 Summary of Evaluation Findings

The evaluation demonstrates that the system achieves:

- **Clinical Safety:** 100% faithfulness with zero hallucinations across all test queries.
- **Operational Efficiency:** Sub-millisecond retrieval latency and low total pipeline overhead.
- **Temporal Accuracy:** Correct longitudinal tracking of diagnostic progression with full citation auditability.

These results validate the architectural choices—TOON normalization, intent-driven retrieval, and bounded reasoning—as effective mechanisms for building trustworthy clinical AI.

5.7 Performance, Scalability & Deployment

5.7.1 Hardware & Infrastructure

The system is currently deployed on a Ubuntu Server cloud instance BWS (Belal Web Services) designed to simulate a hospital’s edge-compute node. The infrastructure is containerized to ensure reproducibility and ease of deployment.

- **Compute Node:**
 - * **CPU:** AMD Ryzen 7 3700X (8 Cores, 16 Threads). Handles the vector embeddings (ModernPubMedBERT) and API routing logic.
 - * **GPU:** NVIDIA RTX 2070 (8GB VRAM) running CUDA 13.0. This consumer-grade card was chosen to demonstrate the viability of running advanced clinical AI on cost-effective hardware, rather than relying on expensive enterprise H100 clusters.
 - * **RAM:** 16GB System RAM. for Qdrant vector index, and application services run alongside the GPU workload.
- **Software Stack:**
 - * **Inference Engine:** llama.cpp server with full CUDA offloading. The MedGemma 1.5-4b-it model is quantized to Q6_K format, occupying approximately 5.4GB of VRAM, leaving headroom for context processing.

- * **Vector Database:** Qdrant (v1.7.0) running in a lightweight Docker container. It manages the High-Dimensional Vector Space (768d) for patient encounter retrieval, utilizing HNSW indexing for sub-millisecond search latencies.
- * **Clinical Data Source:** Redis Cloud connected to HAPI FHIR R4 server for standards-compliant data persistence, ensuring the system can integrate with modern EHR architectures.
- * **Application Layer:** A FastAPI backend orchestrates the RAG pipeline, connecting the CPU-bound embedding generation with the GPU-bound inference. Streamlit serves as the clinical dashboard, while an MCP (Model Context Protocol) server allows internet connectivity.

5.7.2 Latency & Throughput

By running specifically optimized local inference, the system achieves near real-time performance, critical for clinical adoption.

- **Token Generation Speed:** The RTX 2070 achieves a generation rate of approximately 40-50 tokens per second (t/s) for the 4B parameter model. This allows for a full clinical summary (approx. 200-300 words) to be generated in under 10 seconds.
- **Retrieval Latency:** Qdrant vector search is sub-millisecond per query. The total time for the "Query Understanding → Embedding → Search" loop is consistently under 200ms.
- **End-to-End Response Time:** The median total latency from user query to final rendered response is 8-12 seconds, falling well within the "usable interaction" threshold for clinical workflows.

5.7.3 Cost & Scalability

The architecture effectively shifts the cost curve of clinical AI.

- **Optimization:** By proving viability on consumer hardware (RTX 20xx series), the system demonstrates that hospitals can deploy on-premise AI nodes without significant infrastructure overhaul. A typical deployment node costs less than \$1,500 in hardware.
- **Scalability Strategy:** The system is designed as a "Pod" architecture. Each compute node can handle a specific ward or patient panel. Scaling to a full hospital simply involves adding more nodes horizontally, rather than scaling up a monolithic central mainframe.

5.8 Limitations & Open Challenges

While the RAG architecture provides a robust grounding mechanism, several frontier challenges in AI infrastructure and clinical reasoning remain. Acknowledging these is essential for maintaining engineering integrity and clinical trust.

5.8.1 Technical Constraints

- **The “Lost-in-the-Middle” Phenomenon:** Despite expanding context windows, LLMs often struggle to retrieve information buried in the middle of long patient trajectories (100+ document chunks). This necessitates more advanced *re-ranking* architectures, and better memory management.
- **Retrieval Noise and Domain Shift:** Standard embedding models may suffer from performance degradation when moving between specialties (e.g., from Oncology to Pediatrics) due to the dense use of niche acronyms and shifting semantic definitions, we mitigate this by using medical embedding models.
- **Temporal Reasoning Gaps:** Current RAG systems excel at “point-in-time” retrieval but still struggle with complex causal reasoning over time such as determining if a specific medication *caused* a later adverse event or if it was merely correlated. We try to solve this with Agentc RAG and LLM Multi-Step Reasoning.

5.8.2 Clinical and Operational Hurdles

- **Data Incompleteness (The “Silent” Error):** The system can only reason over what is documented. If a patient receives care at an outside facility not integrated into the local vector store, the AI may provide a confident but incomplete summary.
- **Trust Calibration and Over-Reliance:** There is a psychological risk that clinicians may begin to treat AI summaries as the “source of truth,” potentially skipping the necessary step of verifying the mandatory citations provided by the system.

5.9 Value Proposition & Impact

The implementation of a longitudinal, evidence-grounded RAG system offers a paradigm shift in clinical operations, moving beyond mere digitization to intelligent synthesis.

5.9.1 Clinical Efficiency and Burnout Mitigation

- **Reduction in “Pajama Time”:** By automating pre-visit chart reviews and longitudinal summarization, the system targets a 30-40% reduction in

the administrative documentation burden that currently leads to physician burnout.

- **Enhanced Decision Quality:** Providing semantically relevant, evidence-backed insights at the point of care reduces the risk of diagnostic anchoring and "missed cues" in complex patient histories.

5.9.2 Organizational and Operational Impact

- **Consistency of Care:** Standardizing the summarization and evidence-retrieval process ensures that every patient, regardless of the complexity of their record, receives a thorough and systematic review.
- **Scalable Clinical Operations:** As hospitals face increasing workforce shortages, AI-driven infrastructure allows smaller clinical teams to manage higher-acuity patient panels without a proportional increase in cognitive load or error rates.

Ultimately, the value of this AI system is measured not by its ability to replace the clinician, but by its ability to restore the clinician's focus to the patient by solving the healthcare "search and synthesis" crisis.

Chapter 6

Testing and Verification

6.1 Backend Testing Overview

This section details the automated testing effort for the Node.js backend. The suite is built on Jest with Supertest for HTTP contract checks. Controllers, services, HTTP clients (axios), Redis, and PostgreSQL clients are mocked to isolate behavior where appropriate, while targeted integration tests hit real Redis and Postgres instances when available. Test data favor minimal synthetic fixtures to keep runs deterministic.

6.1.1 Execution Environment

The suite runs on Node.js with Jest and Supertest; axios, Redis, and Postgres clients are typically mocked, while Redis/Postgres integration tests execute when the backing services are reachable via `REDIS_URL` and `PATIENTS_DB_*`. Network calls are isolated in most suites, IDs and payloads are fixed for determinism, and database inserts clean up after themselves.

6.1.2 Scope

Coverage spans HTTP route contracts for patients, encounters, binary resources, and history-graph APIs; service-layer FHIR interactions and caching; Joi-based validation middleware; Redis caching helpers with TTLs; Postgres connectivity and timeline graph persistence; and end-to-end workflows linking patient creation, related-data retrieval, and graph operations.

6.1.3 API Route Coverage

Route tests exercise patient CRUD, TOON export, and related-data bundles; encounter fetch and ‘\$everything’ retrieval with create-by-id; binary PDF fetch/create/delete with required-field validation; and history-graph initialization, head-node creation, CRUD, seeding, and empty-graph handling.

6.1.4 Service and Integration Tests

Patient service specs cover cache-first reads with Redis, FHIR fallbacks, 404 and connectivity errors, create flows (with or without client-specified IDs), and ‘\$everything’ bundles. Condition service specs target patient-scoped queries, empty bundles, and create/update with explicit IDs. History graph service tests remain scaffolded—node/edge CRUD, caching, validation, and FHIR/EOC integration are outlined but still lack concrete assertions.

6.1.5 Test Design and Data

Positive-path cases walk through patient/encounter/condition creation, retrieval, and related-data aggregation, including binary uploads and graph growth. Negative-path cases cover Joi validation failures, cache misses, 404s from FHIR, connection failures, missing IDs, invalid graph categories, and empty bundles. Axios and cache helper calls are stubbed per test to keep contracts deterministic; the graph service uses a mocked pg client. Transient IDs such as `node-001` or `pat-e2e-001` repeat across tests, and Postgres inserts are cleaned up to avoid residue.

6.1.6 End-to-End Workflows

The patient workflow proceeds as create → fetch → add condition → related-data retrieval, asserting state consistency. The history-graph workflow initializes an EOC/graph, creates the head node, grows child nodes (with updates and deletes), verifies branching, and exercises cache-aware readbacks, including invalid-category rejection.

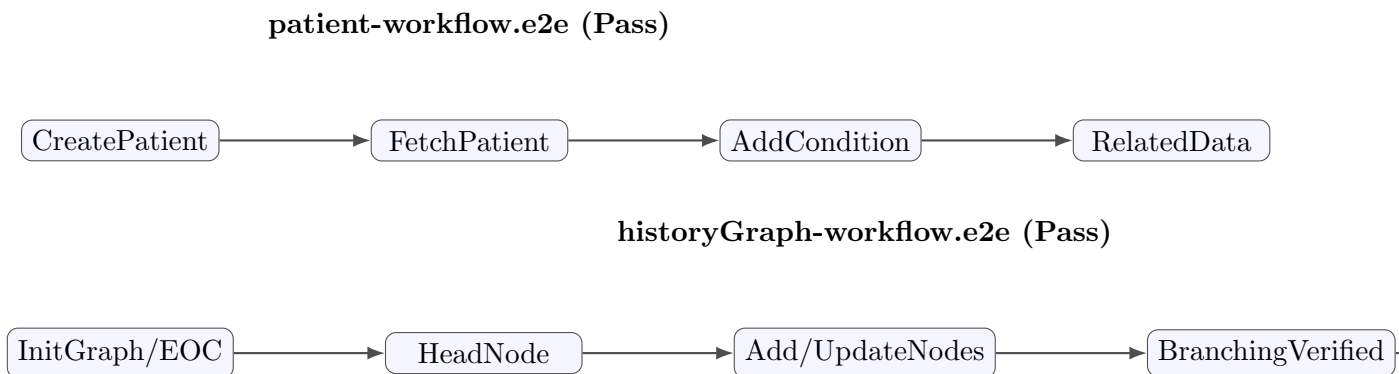


Figure 6.1: Graph view of the two end-to-end suites; edges align to assertions within each test.

6.1.7 Validation and Middleware

Joi schemas enforce required patient fields, formats, and length constraints while permitting extra fields. The request-validator middleware is exercised on both happy-path forwarding and failure-path messaging.

6.1.8 Caching and Redis

Cache helper tests span get/set/delete semantics, TTL handling, error tolerance, and patient cache invalidation (Redis mocked). Redis integration tests, when enabled, hit a live instance to confirm CRUD, TTL expiry, and support for strings, lists, and sets via `REDIS_URL_PATIENTS`.

6.1.9 Database Checks

Postgres smoke tests confirm connectivity, the presence of `timeline_nodes` and `node_edges`, and insert/select round-trips with cleanup. A standalone probe script inspects timeline nodes and edges to sanity-check graph visualization data.

6.1.10 Gaps and Next Steps

1. Add concrete assertions to history graph service integration tests (node/edge creation, validation, cache invalidation, FHIR/EOC fallbacks).
2. Extend end-to-end negative paths for encounters and conditions, aligning status codes and error bodies.
3. Add contract tests to lock TOON export and ‘\$everything’ bundle payload shapes.
4. Document and script external dependencies (Redis, Postgres, FHIR stubs) for reliable CI execution.

6.1.11 Test Result Summary

Figures 6.2 and 6.3 summarize the principal suites and their last known status.

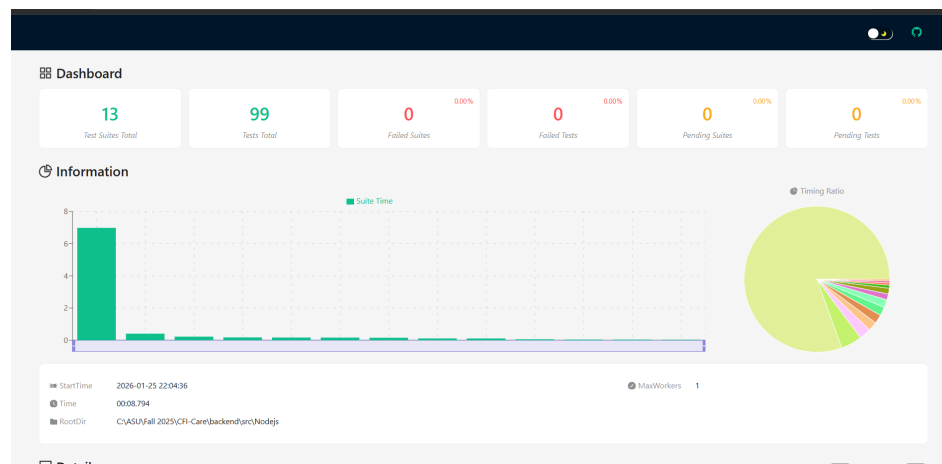


Figure 6.2: Number of Test Cases and its status.

File	ExecTime	Status	Action
C:\ASU\Fall 2025\CFI-Care\backend\src\nodejs\models_tests_redis.test.js	00:06.980	All Passed 5	
C:\ASU\Fall 2025\CFI-Care\backend\src\nodejs\models_tests_v2e\patient-workflow.e2e.test.js	00:00.407	All Passed 2	
C:\ASU\Fall 2025\CFI-Care\backend\src\nodejs\historyGraph_tests_historyGraphRoutes.test.js	00:00.223	All Passed 10	
C:\ASU\Fall 2025\CFI-Care\backend\src\nodejs\models_tests_binaryRoutes.test.js	00:00.169	All Passed 5	
C:\ASU\Fall 2025\CFI-Care\backend\src\nodejs\models_tests_patientRoutes.test.js	00:00.177	All Passed 6	
C:\ASU\Fall 2025\CFI-Care\backend\src\nodejs\historyGraph_tests_historyGraphService.integration.test.js	00:00.154	All Passed 10	
C:\ASU\Fall 2025\CFI-Care\backend\src\nodejs\models_tests_encounterRoutes.test.js	00:00.164	All Passed 3	
C:\ASU\Fall 2025\CFI-Care\backend\src\nodejs\historyGraph_tests_v2e\historyGraph-workflow.e2e.test.js	00:00.111	All Passed 4	
C:\ASU\Fall 2025\CFI-Care\backend\src\nodejs\models_tests_cacheHelper.test.js	00:00.112	All Passed 9	
C:\ASU\Fall 2025\CFI-Care\backend\src\nodejs\models_tests_patientService.integration.test.js	00:00.058	All Passed 9	
C:\ASU\Fall 2025\CFI-Care\backend\src\nodejs\models_tests_patientValidation.test.js	00:00.043	All Passed 7	
C:\ASU\Fall 2025\CFI-Care\backend\src\nodejs\models_tests_validateRequest.test.js	00:00.041	All Passed 3	
C:\ASU\Fall 2025\CFI-Care\backend\src\nodejs\models_tests_conditionService.integration.test.js	00:00.029	All Passed 4	

About Feedback

Version 3.1.7

Figure 6.3: Unit, integration and End-to-end workflow suite status.

6.1.12 Interpretation of Results

- Core HTTP surface for patients, encounters, binaries, and history graph is green, indicating stable contracts at the controller/route layer.
- Service-layer caching and FHIR interaction paths are exercised with both cache hits and misses; error handling for 404 and connectivity is verified.
- Live-environment checks for Redis/Postgres pass when backing services are reachable; mark these as conditional (Pass*).
- The main gap is the history graph service integration file, which outlines scenarios but lacks assertions; adding those will close coverage on graph business logic.

Chapter 7

Conclusion and Future Work

7.1 Conclusion

This thesis presented CFI-Care, a patient-centric healthcare platform that addresses three critical gaps in current digital health systems. The implemented system successfully consolidates fragmented medical records into a unified platform. The HAPI FHIR server, backed by PostgreSQL, provides standards-compliant storage for clinical resources (Patient, Encounter, Practitioner, etc.), enabling cross-institutional data exchange. The Node.js layer translates FHIR resources into application-specific formats while enforcing business logic and security policies. The Angular frontend delivers an interactive interface for patients to manage their health data and for clinicians to review patient histories.

7.2 Future Work

7.2.1 Security

Next Steps

- Implement mobile client authentication endpoints.
- Integrate MFA for enhanced security and email verification during user registration.
- Deploy secrets management using a vault solution
- Deploy security containers to cloud infrastructure with load balancing.
- Use Let's Encrypt for production level TLS certificates after cloud deployment.
- Complete the patient-doctor consent workflow and enforce it at the FHIR server.
- Finalize role-to-scope mapping in Keycloak and document SMART on FHIR compliance.

- Migrate to Authorization Code + PKCE for improved security and standards compliance.
- Build a centralized audit dashboard for security monitoring.
- Enable Redis persistence encryption for session and audit data at rest.

Appendix

Appendix A

Lists

List of Figures

2.1	Evolution of HL7 Standards from Messaging to RESTful Resources.	6
2.2	Visual Comparison of Data structure: HL7 v2 Message vs. FHIR JSON Resource.	9
3.1	High-Level Container Architecture showing the interaction between the Nginx proxy, application services, and data persistence layers.	12
3.2	Internal layered architecture of the Node.js Application Server, detailing the middleware stack and service distribution.	13
3.3	Entity-Relationship Diagram (ERD) illustrating the integration of custom graph tables with the standard FHIR resource table. . . .	15
3.4	Request/Response flow for patient data retrieval, showing cache hit and miss scenarios with complete middleware pipeline.	17
3.5	Complete encounter creation workflow showing FHIR resource persistence, graph construction, and cache invalidation cascade. . . .	19
3.6	Example Patient History Graph showing a diabetes patient with concurrent hypertension, demonstrating temporal branching and multiple relationship types.	25
3.7	Two-Tier Caching Architecture showing distinct strategies for standard FHIR resources (Tier 1) and complex graph structures (Tier 2).	31
3.8	Layered Clean Architecture adopted in the mobile application . .	47
3.9	using handlePermission For Camera Access In code	50
3.10	Best Practices for Handling Permissions in Flutter	51
3.11	Dialog to allow the app to access the camera	52
3.12	Sequence Diagram for Mobile Application	55
3.13	Documents Management Use Case	57
3.14	Major Events	58
3.15	List of Nodes	59
3.16	Node Details	60
3.17	History Navigation Use Case	61

3.18	Booking Appointments Usecase	62
3.19	My Profile Use Case	62
4.1	Security Architecture Components: Edge clients (Browser, Mobile), API Gateway (nginx), Backend-for-Frontend (Node.js), Identity & Storage (Keycloak, Redis, Postgres), and Resource Server (HAPI FHIR) with their security-focused interactions.	70
4.2	Browser Token Authentication Flow: User registration, login, and API request handling with session cookies.	72
4.3	Planned Browser Flow (Future): Registration with email verification and BFF-mediated credential login, session cookie issuance, and server-side token refresh.	73
4.4	Mobile Token Authentication Flow (Future): BFF-mediated Authorization Code with PKCE, secure keystore token storage, and client-driven token refresh.	74
4.5	Token Flow Overview: Multi-client architecture (browser vs. mobile), session/token management, per-session and global logout patterns.	77
5.1	High-Level System Architecture. The flow connects the Streamlit UI to the FastAPI backend, which orchestrates the LangGraph agent. The agent routes between the Local RAG pipeline (Ingestion → Qdrant → MedGemma) and the External MCP Tools (PubMed Access) based on query classification.	99
5.2	TOON Ingestion Pipeline. Raw FHIR JSON resources are processed by the <code>ToonNormalizer</code> , extracting semantic value and temporal metadata to create token-optimized strings before vector embedding by ModernPubMedBERT.	100
5.3	LangGraph Reasoning State Machine. The decision logic for the agent, illustrating the bifurcation between <code>LocalRAG</code> (Patient Specific) and <code>MCPSearch</code> (General Knowledge) paths, converging at the grounded generation node.	101
5.4	AI-generated longitudinal patient summary utilizing Local RAG to synthesize data from 10 distinct clinical encounters.	102
5.5	Diagnostic reasoning workflow showing the transition from initial clinical impressions to a final confirmed diagnosis based on patient progression.	103
6.1	Graph view of the two end-to-end suites; edges align to assertions within each test.	111
6.2	Number of Test Cases and its status.	112
6.3	Unit, integration and End-to-end workflow suite status.	113

References

- [1] Grand View Research, *Digital Health Market Size, Share & Trends Analysis Report By Technology, By Component, By Region, And Segment Forecasts, 2025 - 2030*, <https://www.grandviewresearch.com/industry-analysis/digital-health-market>, Accessed: 2025-04-04.
- [2] Intellisoft, *FHIR vs. HL7: Core Differences & Standards Comparison*, <https://intellisoft.io/comparing-hl7-vs-fhir-core-differences/>, Accessed: 2025-04-04.
- [3] University of Porto Repository, *Interoperability in Healthcare Systems (Thesis/Dissertation)*, <https://repositorio-aberto.up.pt/bitstream/10216/164181/2/700384.pdf>, Accessed: 2025-04-04.
- [4] Wikipedia, *Fast Healthcare Interoperability Resources*, https://en.wikipedia.org/wiki/Fast_Healthcare_Interoperability_Resources, Accessed: 2025-04-04.
- [5] HL7 International, *FHIR HL7 Documentation*, <https://www.hl7.org/fhir/>, Accessed: 2025-04-04.
- [6] HL7 International, *FHIR R4 Consent Resource*, <https://www.hl7.org/fhir/consent.html>, Accessed: 2025-11-04.
- [7] HL7 SMART on FHIR Community, *SMART App Launch Framework: Secure, Standardized, Data-Driven Application Architecture for Biomedicine*, <http://www.hl7.org/fhir/smart-app-launch/>, Accessed: 2025-09-15.
- [8] OpenID Foundation, *OpenID Connect Core 1.0*, https://openid.net/specs/openid-connect-core-1_0.html, Accessed: 2025-08-28.
- [9] D. Hardt (Editor), *The OAuth 2.0 Authorization Framework*, RFC 6749, Internet Engineering Task Force (IETF), October 2012, <https://tools.ietf.org/html/rfc6749>, Accessed: 2025-08-28.
- [10] B. Jones and D. Hardt (Editors), *The OAuth 2.0 Bearer Token Usage*, RFC 6750, Internet Engineering Task Force (IETF), October 2012, <https://tools.ietf.org/html/rfc6750>, Accessed: 2025-01-15.
- [11] M. Jones, J. Bradley, and N. Sakimura, *JSON Web Token (JWT)*, RFC 7519, Internet Engineering Task Force (IETF), May 2015, <https://tools.ietf.org/html/rfc7519>, Accessed: 2025-08-28.
- [12] O. Steele and A. Parecki (Editors), *OAuth 2.0 Security Best Current Practice*, RFC 9700, Internet Engineering Task Force (IETF), October 2024, <https://tools.ietf.org/html/rfc9700>, Accessed: 2025-11-04.

- [13] M. Bertocci, *OAuth 2.0 Token Mediator Pattern for Web API Authorization*, Internet-Draft draft-bertocci-oauth2-tmi-bff-01, IETF, 2023, <https://tools.ietf.org/html/draft-bertocci-oauth2-tmi-bff-01>, Accessed: 2025-01-14.
- [14] S. Bingler, Ed. *HTTP State Management Mechanism*, RFC 6265, Internet Engineering Task Force (IETF), April 2011, <https://tools.ietf.org/html/rfc6265>, Accessed: 2025-08-30.
- [15] N. Sakimura, J. Bradley, and N. Agarwal, *Proof Key for Public OAuth 2.0 Authorization Code Flow (PKCE)*, RFC 7636, Internet Engineering Task Force (IETF), September 2015, <https://tools.ietf.org/html/rfc7636>, Accessed: 2025-09-30.
- [16] D. Recordon (Editor) and D. Hardt (Editor), *OAuth 2.0 Threat Model and Security Considerations*, RFC 6819, Internet Engineering Task Force (IETF), January 2013, <https://tools.ietf.org/html/rfc6819>, Accessed: 2025-11-04.
- [17] OWASP Foundation, *OWASP Top 10 - 2021: The Ten Most Critical Web Application Security Risks*, <https://owasp.org/Top10/2021/>, Accessed: 2025-09-30.
- [18] OWASP Foundation, *OWASP API Security Top 10*, <https://owasp.org/www-project-api-security/>, Accessed: 2025-11-02.
- [19] Keycloak Community, *Keycloak Documentation: Open Source Identity and Access Management*, <https://www.keycloak.org/documentation.html>, Accessed: 2025-08-20.
- [20] Keycloak, *Keycloak Server Administration Guide and Reference*, https://www.keycloak.org/docs/latest/server_admin/, Accessed: 2025-08-20.
- [21] Adam Baldwin and Contributors, *Helmet: Secure Express Apps by Setting Various HTTP Headers*, <https://helmetjs.github.io/>, Accessed: 2025-01-15.
- [22] OWASP Foundation, *Cross-Site Scripting (XSS) Prevention Cheat Sheet*, https://cheatsheetseries.owasp.org/cheatsheets/Cross_Site_Scripting_Prevention_Cheat_Sheet.html, Accessed: 2025-09-30.
- [23] OWASP Foundation, *Cross-Site Request Forgery (CSRF) Prevention Cheat Sheet*, https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html, Accessed: 2025-09-29.
- [24] NGINX Inc., *NGINX Documentation*, <https://nginx.org/en/docs/>, Accessed: 2025-10-04.
- [25] Olivier Poitrey, *rate-limit-redis: Redis-backed Rate Limiting Middleware for Express*, <https://www.npmjs.com/package/rate-limit-redis>, Accessed: 2025-01-15.
- [26] hapi Framework Community, *Joi: Object Schema Validation*, <https://joi.dev/>, Accessed: 2025-01-15.

- [27] OWASP Foundation, *Logging Cheat Sheet*, https://cheatsheetseries.owasp.org/cheatsheets/Logging_Cheat_Sheet.html, Accessed: 2025-10-04.
- [28] U.S. Department of Health and Human Services, *HIPAA Security Rule*, <https://www.hhs.gov/hipaa/for-professionals/security/index.html>, Accessed: 2025-08-23.
- [29] Art Future, *OAuth 2.0 Authentication with Keycloak in Flutter Applications*, <https://medium.com/@art.futurx/oauth-2-0-authentication-with-keycloak-in-flutter-applications-35d588b2246d>, Accessed: 2025-12-04.
- [30] D. Denniss, C. Dodson, and W. Mills, *OAuth 2.0 for Native Apps*, RFC 8252, Internet Engineering Task Force (IETF), October 2017, <https://www.rfc-editor.org/rfc/rfc8252#section-8.12>, Accessed: 2025-12-04.
- [31] OWASP Foundation, *OWASP Mobile Top 10*, <https://owasp.org/www-project-mobile-top-10/>, Accessed: 2025-08-23.
- [32] OWASP Foundation, *OWASP Mobile Application Security (MAS)*, <https://mas.owasp.org/>, Accessed: 2025-08-23.
<https://developer.android.com/privacy-and-security/keystore>
- [33] Google, *Android Keystore System*, <https://developer.android.com/privacy-and-security/keystore>, Accessed: 2025-01-14.
- [34] Auth0, *The Backend-for-Frontend Pattern*, <https://auth0.com/blog/the-backend-for-frontend-pattern-bff/>, Accessed: 2025-12-04.
- [35] Sam Newman, *Backend-for-Frontend Architecture Pattern*, <https://samnewman.io/patterns/architectural/bff/>, Accessed: 2025-12-04.
- [36] Keycloak, *Keycloak Securing Applications and Services Guide*, <https://www.keycloak.org/guides.html#securing-apps>, Accessed: 2025-09-10.
- [37] Keycloak, *Keycloak REST API Documentation*, <https://www.keycloak.org/docs-api/latest/rest-api/index.html>, Accessed: 2025-09-10.
- [38] Keycloak, *Keycloak Authorization Services Guide*, https://www.keycloak.org/docs/latest/authorization_services/index.html, Accessed: 2025-09-10.
- [39] Keycloak, *Keycloak Server in Containers*, <https://www.keycloak.org/server/containers>, Accessed: 2025-09-10.
- [40] Keycloak Documentation, *Administering Sessions in Keycloak*, https://wjw465150.gitbooks.io/keycloak-documentation/content/server_admin/topics/sessions/administering.html, Accessed: 2025-01-14.
- [41] Flutter Team, *Flutter App Architecture*, <https://docs.flutter.dev/app-architecture>, Accessed: January 2026.
- [42] Yamen Abdallah, *Clean Architecture in Flutter: MVVM, BLoC, Dio*, <https://medium.com/@yamen.abd98/clean-architecture-in-flutter-mvvm-bloc-dio-79b1615530e1>, Accessed: January 2026.

- [43] Shalu, *Why You Should Use Riverpod in Flutter — The Future of State Management*, <https://medium.com/@shalu023/why-you-should-use-riverpod-in-flutter-the-future-of-state-management-e064e>, Medium article, October 2025.
- [44] Atuoha Anthony, *How to Handle Permissions in Flutter: A Comprehensive Guide*, freeCodeCamp.org, <https://www.freecodecamp.org/news/how-to-handle-permissions-in-flutter-for-beginners/>, August 2025.
 @articlerizk2025egypt, author = Rizk, Ahmed and El-Sayed, Mona, title = Digital Transformation and Data Fragmentation in Egyptian Healthcare, journal = Journal of Health Informatics in Developing Countries, year = 2025, volume = 19, number = 2, pages = 45–59, note = Available online: <https://menaobservatory.ai/storage/HbpCOQswcZsnnNbRV1YcB3dvIa7JoM-metaQTJLNEQgLSBNRU5BIEFJIC0gSGVhbHRoIFNIY3RvciAtIENhc2Ugb2YgRWd5cHQ.pdf>